University of Staffordshire | A·P·I·I·T Inspire love for learning

ASSIGNMENT

LEVEL 6

COMP60010: Enterprise Cloud and Distributed Web Applications

Hand in Date: 5th October 2026

Submitted by: Sharini Nirmalan (CB014426)

INSTRUCTION TO CANDIDATES

1. **Late submission will be awarded zero (0) unless extenuating circumstances (EC) are upheld.**
2. **Cases of plagiarism will be penalized.**
3. **The assignment should be submitted as softcopy via LMS**
4. **All evidences related to the sprint implementation in group assignment must be show cased in the final documentation.**

Contents

1. Introduction 3
2. Current Infrastructure Analysis and Cloud Adoption (Task 1) 3
2.1 Limitations of the current infrastructure 3
2.2 Security and compliance risk 3
2.3 Monolith, manual operations and cost 4
2.4 Mapping challenges to AWS services 4
3. Cloud Migration Strategy (Task 2) 5
3.1 Phased approach 5
3.2 Migration approach by workload 5
3.3 Automation and Infrastructure as Code 6
3.4 Risks and mitigation 6
4. Target AWS Architecture (Task 3) 6
4.1 Design overview 6
4.2 Does the design reach 99.99%? 9
4.3 Region strategy 9
5. Security, Governance and Compliance (Task 4) 9
5.1 Layered controls 9
5.2 GDPR and healthcare compliance 10
5.3 Risk assessment 10
6. Cost Optimisation and Support Strategy (Task 5) 11
6.1 Estimated monthly cost 11
6.2 Optimisation techniques 12
6.3 Support strategy 12
7. Data Migration and Business Continuity (Task 6) 12
7.1 Database migration with AWS DMS 12
7.2 Historical data to S3 13
7.3 Validation 13
7.4 Backup, restore and disaster recovery 13
8. Hybrid Connectivity and Edge Integration (Task 7) 13
8.1 Site-to-Site VPN and Direct Connect 13
8.2 Hybrid DNS 14
8.3 IoT Core and Greengrass 14
9. AI and Analytics Integration 15
10. Conclusion 15
References 16
Appendices 19

Appendix A: Account and cost controls 19
Appendix B: Network 19
Appendix C: Load balancing and security groups 21
Appendix D: Data tier and storage 24
Appendix E: Content delivery and messaging 28
Appendix F: Monitoring 29
Appendix G: Security and governance 31
Appendix H: Cost estimation evidence 39
Appendix I: Migration and continuity evidence 41
Appendix J: Hybrid connectivity and edge evidence 46
Appendix K: Infrastructure as Code 49
Appendix L: Analytics evidence 53

1. Introduction

CloudFusion Healthcare Analytics Ltd (CHA) sells patient monitoring, telemedicine and analytics services to hospitals, clinics and laboratories across South Asia and the Middle East. It all runs from one data centre: about 220 VMware virtual machines hosting a monolithic web application, with Microsoft SQL Server and MySQL behind it. Nothing scales automatically, deployments and backups are manual, monitoring is thin and there is no second site. The board wants 99.99% availability, more than 100,000 concurrent users, running costs at least 40% lower, GDPR-aligned compliance, wearable device support and AI-driven risk prediction.

This report has been written in the perspective of the CHA's Cloud Solutions Architect. It covers Tasks 1 to 7 and AI and analytics for the Patient Monitoring Platform (PMP) and the Telemedicine and Patient Portal (TPP) on Amazon Web Services (AWS). Design choices are tested against the six pillars of the AWS Well-Architected Framework (AWS, 2024). Additionally, the proof of concept (PoC) of the network, data, messaging and governance tiers has been built in AWS account, in us-east-1 (N. Virginia), chosen for cost. Evidence is in the appendices, and design-only items are labelled.

2. Current Infrastructure Analysis and Cloud Adoption (Task 1)

2.1 Limitations of the current infrastructure

Scalability. Capacity on premises is bought ahead of demand and sized for a peak approved months earlier. Adding to a VMware cluster takes procurement and racking, so a surge in remote consultations meets a fixed ceiling. Mell and Grance (2011) name rapid elasticity as a defining property of cloud computing, and Armbrust et al. (2010) stress paying only for what is used. CHA has neither.

Reliability. One site is one failure domain: a single power feed, carrier and building. A 99.99% target allows about 52 minutes of downtime a year, which Beyer et al. (2016) would call an error budget, and one failed storage array can use it up in an afternoon.

Performance. Every user reaches the same site, so a clinician far from the data centre pays the round-trip delay on every page, and with no CDN or cache the application servers rebuild content that an edge cache could serve.

Maintenance. Each of the 220 VMs needs patching, capacity planning and eventually a hardware refresh, mostly by hand. On AWS the provider looks after everything beneath the guest operating system on EC2, and much more on managed services such as RDS, Fargate and Lambda.

2.2 Security and compliance risk

Health records are special category data under Article 9 of the GDPR, and healthcare has had the costliest breaches of any sector for thirteen years running, averaging USD 6.64 million in IBM's 2026 study (European Union, 2016; IBM, 2026). Limited logging makes incidents hard to detect and scope, let alone report within the 72 hours Article 33 allows, and untested backups, a branch VPN with unclear segmentation and no central audit trail weaken the Article 32 duty to apply appropriate technical measures. Local law adds more: India's Digital Personal Data Protection Act 2023, and the UAE's ICT Health Law, which restricts storing health data abroad (Government of India, 2023; Al Tamimi and Company, 2021).

2.3 Monolith, manual operations and cost

In a monolith every feature ships in one release. A fix to appointment booking redeploys the video consultation code too, so releases grow large, rare and risky, and one faulty module can take down the whole application (Fowler and Lewis, 2014; Newman, 2021). Without infrastructure as code, environments drift and rollback depends on memory. Forsgren, Humble and Kim (2018) found that teams who deploy often and automatically also have lower change failure rates.

Cost is harder to judge than it looks. CHA carries hardware depreciation, VMware and SQL Server licences and idle headroom for rare peaks. AWS presents the case as trading capital expense for variable expense, benefiting from economies of scale and no longer guessing capacity. Weinman (2012) argues that pay-per-use suits variable demand, but cloud is not cheaper by default, and an always-on estate copied across without right-sizing can cost more. Section 6 therefore prices the design and does not assume a 40% saving.

2.4 Mapping challenges to AWS services

Table 1 maps each limitation to the AWS services named in the brief (EC2, S3, RDS, Lambda, CloudFront, Route 53, ECS or EKS and IAM) and to the supporting services the design depends on.

Table 1: Traceability from on-premises limitations to AWS services

Limitation today	AWS service	How it helps
Fixed capacity, no auto-scaling	ECS on Fargate with Service Auto Scaling; Lambda	Task count follows CPU and request load
Legacy VMs not yet containerised	EC2 in an Auto Scaling Group	Unhealthy servers are replaced automatically
Single data centre	Multi-AZ VPC, ALB, Aurora with a reader in a second AZ	Failover to a healthy zone without manual work
Distant users, no caching	CloudFront, Route 53	Edge caching and health-checked DNS routing
File shares and documents on local storage	Amazon S3	Durable object storage with versioning and lifecycle tiers; static content served through CloudFront
Manual patching of 220 VMs	RDS and Aurora, Fargate, Lambda	AWS operates the underlying platform
Weak audit and access control	IAM, CloudTrail, KMS	Least-privilege roles, tamper-evident logs, encryption
Monolith coupling	ECS (Fargate) services, with EKS as the option once service count grows; API Gateway, SQS, SNS	Components deploy and fail independently
Manual deployment, no rollback	CloudFormation or Terraform	Repeatable, reviewable, reversible builds
Manual backups, no DR	S3 lifecycle, AWS Backup, Aurora Global Database	Automated, tiered, cross-Region copies
Capital cost, idle capacity	Pay-as-you-go pricing, Savings Plans	Spend follows use (Section 6)

The case is not one-sided. Cloud moves risk more than it removes it: misconfiguration becomes the usual cause of exposure, managed services such as Aurora, DynamoDB and IoT Core raise the price of leaving, and egress charges and skills gaps are real. A Region is also a physical place, and the

Middle East incidents showed that a Multi-AZ design can lose more than one zone at once. The later sections therefore add cross-Region and in-country recovery options.

3. Cloud Migration Strategy (Task 2)

3.1 Phased approach

The plan has six phases, each ending at a gate where the Well-Architected pillars serve as a review checklist (AWS, 2024). No wave starts until the previous gate is closed. The AWS Cloud Adoption Framework adds the non-technical view (AWS, 2021b): its People and Governance perspectives become training before wave 1 and residency controls. A Well-Architected Tool review of the PoC (all 57 questions) returned 40 high-risk and 15 medium-risk items, mostly in Reliability, Security and Operational Excellence. Most are missing processes, such as runbooks and tested recovery, so they become the pilot's exit criteria.

Discovery and assessment. AWS discovery tooling (Application Discovery Service, now succeeded by AWS Transform) inventories the VMware estate and records CPU, memory and disk use (AWS, n.d.k). After about 90 days the 220 VMs can be sorted into idle machines to retire, oversized ones to right-size and busy ones to plan with care; AWS treats servers averaging 5 to 20 per cent CPU and memory over 90 days as retirement candidates (AWS, n.d.a).

Dependency analysis. The Discovery Agent captures network connections, and the output becomes move groups such as a web tier, its database and the file share it mounts. Data is also classified by jurisdiction here, because that decides which Region each group may land in.

Pilot. The landing zone comes first: VPC, IAM, logging and guardrails as code. The pilot is one low-risk workload, such as the internal reporting application, moved end to end to prove the pipeline, VPN throughput, monitoring and rollback before anything clinical moves.

Database migration. AWS DMS runs a full load then change data capture, so the source stays live until cutover (Section 7).

Waves and cutover. Cutover uses weighted Route 53 records, shifting traffic 5, 25 then 100 per cent with health checks at each step, and the on-premises copy stays read-only for 14 days.

Rollback and post-migration. Rollback means moving the DNS weight back and, for databases, running a reverse DMS task so the source stays current. Each wave ends with validation and optimisation: right-sizing, a Compute Optimizer review and a fixed decommissioning date.

3.2 Migration approach by workload

AWS advises against refactoring during a large migration and prefers rehosting, relocating or replatforming first, then modernising (AWS, n.d.a). The PMP ingest path is the exception, and it is really new build: wearable traffic at IoT scale needs an event-driven design, so it is built cloud-native beside the legacy path, which is switched off once the new one has proved itself. I rejected Relocate (moving VMware as it stands) because it keeps the hypervisor licensing and the monolith, delivering neither the cost target nor better scaling.

Table 2: Migration approach for each workload

Workload	Approach	Reasoning
TPP web application	Replatform	Containerise the existing code on ECS Fargate behind an ALB. No rewrite under deadline; auto-scaling from day one.

Workload	Approach	Reasoning
PMP ingest	Refactor (new build)	Wearable traffic needs an event-driven path: IoT Core, SQS, Lambda, DynamoDB. Built beside the legacy path, which is retired after cutover.
MySQL databases	Replatform	DMS to Aurora MySQL. Same engine, so low conversion risk, plus Multi-AZ and no patching.
SQL Server databases	Replatform, then evaluate Refactor	DMS to RDS for SQL Server first. Aurora PostgreSQL would cut licence cost but needs T-SQL and schema work, so it waits.
Idle and legacy VMs, file shares	Retire or Rehost	Idle servers are switched off. The rest replicate to EC2 in an Auto Scaling Group with AWS Transform MGN, formerly Application Migration Service (AWS, n.d.p); file shares go to S3.
Branch VPN, monitoring tools	Repurchase	Site-to-Site VPN and Direct Connect replace the legacy VPN; CloudWatch and X-Ray replace on-premises monitoring.

3.3 Automation and Infrastructure as Code

Automation is what makes a rollback believable. The network, security and data tiers are written in Terraform. In production the code would be held in a Git repository and changed only through pull requests that show the terraform plan output (Morris, 2025), and a pipeline would build images, push them to Amazon ECR and deploy to ECS, keeping the previous task definition ready for rollback. In the PoC Terraform was run locally from the command line rather than from a repository and pipeline; Appendix K holds the Terraform for the network and data-tier foundations, with the plan, apply and destroy runs (Figures K2 to K4).

3.4 Risks and mitigation

Table 3 lists the risks most likely to hurt the programme.

Table 3: Migration risk register

Risk	Likelihood	Impact	Mitigation
Data loss or corruption at database cutover	Medium	High	DMS validation; writes frozen only for the cutover; source read-only for 14 days; reverse replication ready
Hidden dependency breaks an application after a move	High	Medium	Connection-level dependency mapping; every wave rehearsed; reversible weighted DNS cutover
Team unfamiliar with AWS and IaC	High	Medium	Pilot first; managed services over self-run ones; peer reviewed Terraform; training before wave 1
Data lands in the wrong jurisdiction	Medium	High	Classify data first; one Region per jurisdiction; service control policies; legal review
Cost overrun while both estates run	Medium	Medium	Budgets and alerts; dated decommissioning plan; Savings Plan review after each wave
Loss of a whole Region, as in the Gulf in 2026	Low	High	Warm standby in a second Region where law allows; in-country secondary otherwise

4. Target AWS Architecture (Task 3)

4.1 Design overview

Figures 1 and 2 show the layout, security boundaries and data flows.

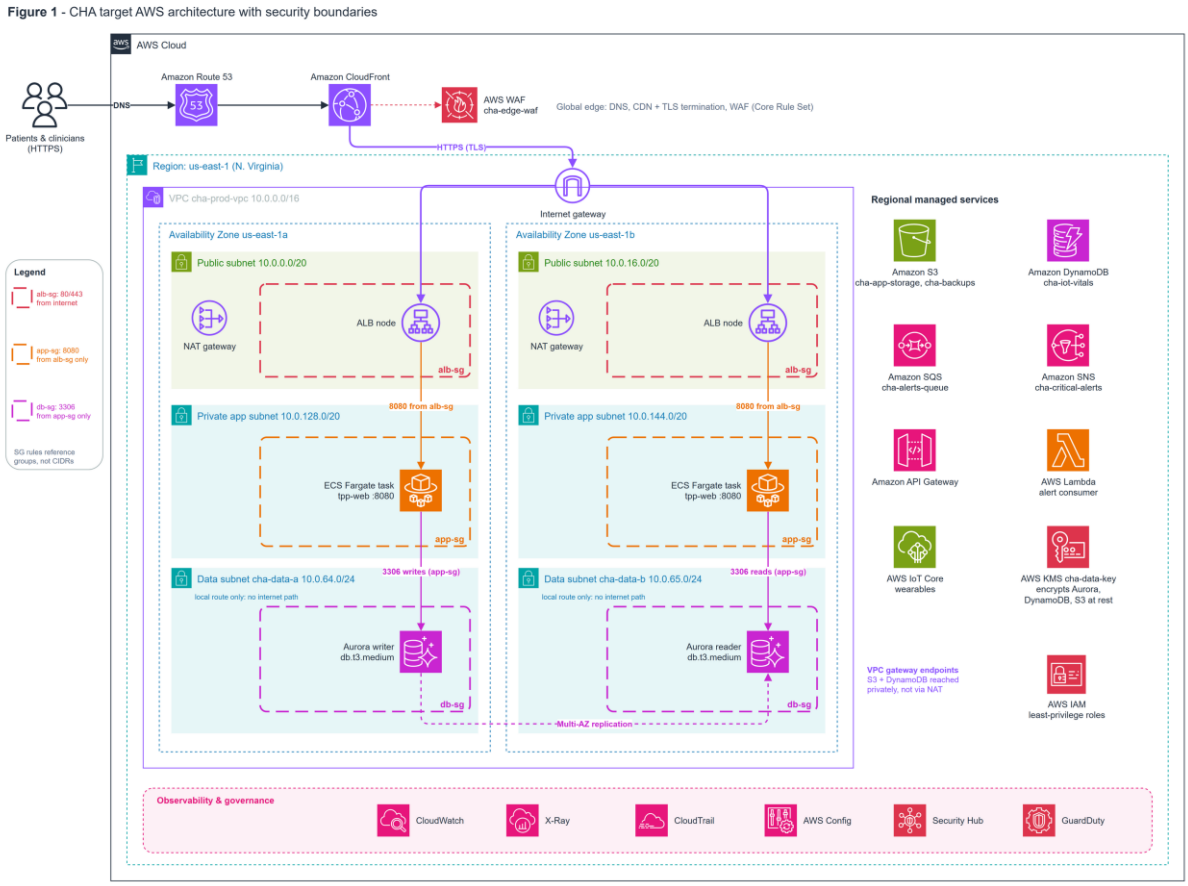


Figure 1: Target AWS architecture with security boundaries

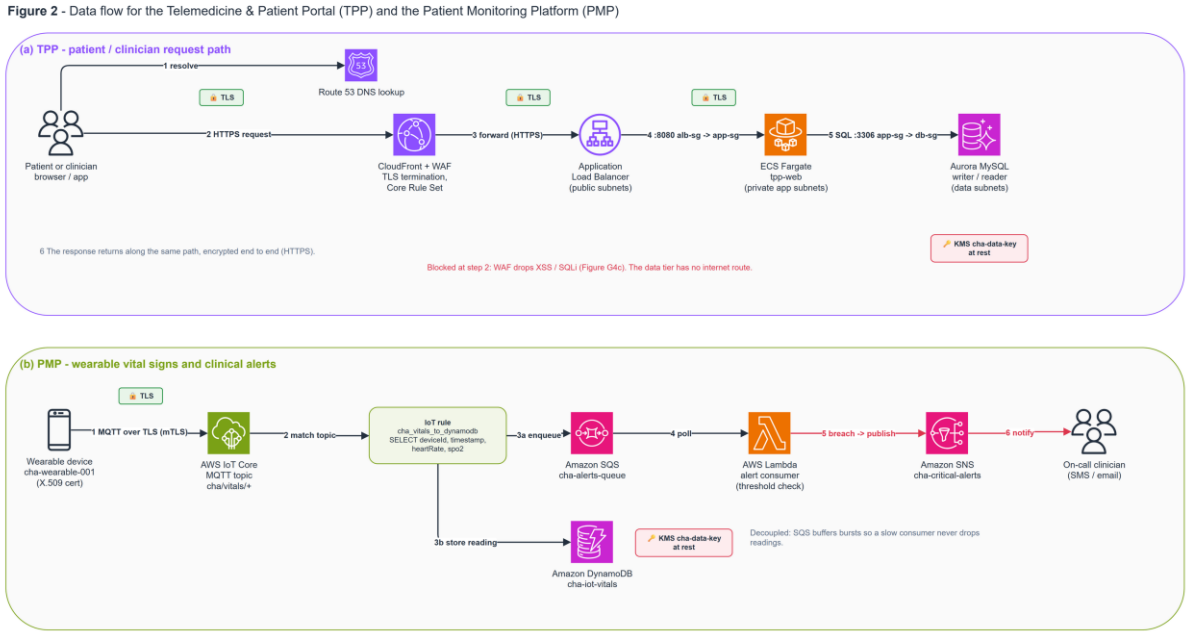


Figure 2: Data flow for the TPP and PMP

Network. The VPC uses 10.0.0.0/16 across two Availability Zones in three tiers: the public tier holds the ALB and one NAT gateway per zone, the application tier holds the ECS tasks, and the data tier holds Aurora. Only the public subnets route to the Internet Gateway. A NAT gateway per zone was

chosen despite the doubled hourly charge, because with a shared gateway one zone failing would cut outbound access for the private subnets in the other. The data subnets (cha-data-a and cha-data-b, 10.0.64.0/24 and 10.0.65.0/24) have a route table with only the local route, so the database tier has no path to the internet (Appendix B, Figure B3).

Traffic. Users resolve through Route 53 to CloudFront, with WAF attached, then to the ALB (alb-sg), which forwards to Fargate tasks on port 8080 (app-sg), which reach Aurora MySQL on port 3306 (db-sg). Each security group admits traffic only from the group before it, referenced by group and not by IP range.

Compute. The TPP web and API services run on ECS Fargate, so there are no hosts to patch. Application Auto Scaling adjusts task count on CPU target tracking, with a floor of two tasks, one per zone. Auto Scaling Groups still serve rehosted legacy servers that cannot be containerised yet. Appointment reminders, report generation and IoT rule actions run on API Gateway and Lambda, and video uses a managed real-time media service such as the Amazon Chime SDK so media bypasses the application tasks. The serverless and media parts are design only.

Data. Aurora MySQL holds patient and appointment records, with a writer in one zone and a reader in the other. DynamoDB in on-demand mode takes IoT vitals and session data, with deviceId as partition key and timestamp as sort key, so writes spread by device and there is no capacity to plan. S3 holds documents, reports and backups with versioning, blocked public access and encryption; the backup bucket moves objects to Standard-IA at 30 days and Glacier Flexible Retrieval at 90 (Appendix D).

Messaging and observability. IoT rules place messages on an SQS queue, which absorbs bursts, and SNS sends critical alerts to clinicians by email or SMS. CloudWatch collects metrics and logs, Container Insights covers the cluster, and X-Ray traces requests across services. In the PoC a CPU alarm on the ECS service notifies the cha-critical-alerts topic (Appendix F, Figure F3).

Table 4 lists each component and its security boundary.

Table 4: AWS components in the target architecture

Component	Role in the design	Tier or boundary
Multi-AZ VPC (10.0.0.0/16)	Private network across two Availability Zones, so one zone is one failure domain	Regional boundary
Public and private subnets	Public tier for ALB and NAT; private application and data tiers with no inbound internet path	Three tiers per AZ
Internet Gateway, NAT Gateways	Inbound path to the ALB; outbound-only path for private subnets, one NAT gateway per AZ	Public subnets
Application Load Balancer	Terminates TLS, health-checks targets and spreads traffic across zones	alb-sg
Auto Scaling Groups	Replace unhealthy EC2 hosts for rehosted legacy servers; scale on CPU	app-sg, private subnets
ECS on Fargate	Runs TPP web and API containers; Service Auto Scaling; no hosts to patch	app-sg, private subnets
API Gateway and Lambda	Appointment reminders, report generation and IoT rule actions; scale to zero	Serverless, IAM-authorised
Aurora MySQL; RDS for SQL Server	Patient, appointment and clinical records; writer and reader in separate AZs	db-sg, data subnets
DynamoDB	IoT vitals and session state; on-demand capacity, keyed by device and time	Gateway VPC endpoint

Component	Role in the design	Tier or boundary
Amazon S3	Documents, reports, backups and archive; versioning and lifecycle tiers	Bucket policy, KMS, Block Public Access
CloudFront	Edge caching and TLS termination for TPP users; WAF attached	Edge, in front of the ALB
SQS and SNS	Absorbs IoT bursts; alerts clinicians and operators	IAM-scoped queue and topic policies
CloudWatch and X-Ray	Metrics, logs, alarms and dashboards; end-to-end request tracing	Account-wide

4.2 Does the design reach 99.99%?

Aurora's Multi-AZ SLA commits to 99.99% monthly uptime (AWS, 2025), but an SLA is a credit scheme and not a promise about CHA's users. What users experience is the product of every component in the request path: four tiers at 99.99% each, in series, give about 99.96%, or roughly 3.5 hours of downtime a year. Therefore 99.99% is treated as an objective to measure with synthetic checks, not a property the diagram already has.

4.3 Region strategy

Region choice follows the law before latency. For South Asia Mumbai is proposed as primary and Hyderabad as an in-country recovery Region, a pairing AWS describes for Indian data sovereignty (Singh and Pandey, 2023). UAE health data may not be stored abroad without an approved exception (Al Tamimi and Company, 2021), the Bahrain Region is gone and the UAE Region is still recovering (Markovic, 2026). Therefore, new Gulf production workloads will be held out until AWS publishes a restoration date and design Gulf tenancy with an in-country secondary (Section 7).

5. Security, Governance and Compliance (Task 4)

5.1 Layered controls

Identity. Workloads use IAM roles and never long-lived keys. People are IAM users in groups by job function (federated in production) and assume roles to reach data. MFA is enabled for every human login, starting with root, and it is set up on the root user and the PoC user, alongside an account password policy (Appendix G, Figures G3 and G12). TPP users sign in through Amazon Cognito with MFA available. Listing 1 is the ClinicalDataAnalyst policy: two read actions on DynamoDB and one on S3, each tied to a named resource, in place of an AWS managed wildcard policy. In production the ARN wildcards would give way to the real Region and account, and a permissions boundary would cap the role.

```
{
 "Version": "2012-10-17",
 "Statement": [
   {
    "Effect": "Allow",
    "Action": ["dynamodb:GetItem", "dynamodb:Query"],
    "Resource": "arn:aws:dynamodb:*:*:table/cha-iot-vitals"
   },
   {
    "Effect": "Allow",
    "Action": ["s3:GetObject"],
    "Resource": "arn:aws:s3:::cha-app-storage-sn/*"
   }
 ]
}
```

Listing 1: Least-privilege policy for the ClinicalDataAnalyst role

Network. Security groups chain from alb-sg to app-sg to db-sg (Appendix C). Security groups are stateful, so return traffic is allowed automatically; network ACLs add a stateless layer on the data subnets: TCP 3306 in from the two application subnet ranges, ephemeral ports out to the same ranges, everything else denied. The ACL backs up the security groups and does not replace them. The PoC data subnets carry exactly this ACL (Appendix G, Figure G8).

Edge. AWS WAF with the AWS managed Common Rule Set filters common web exploits on the CloudFront distribution (Appendix G, Figure G4). Shield Standard covers network-layer DDoS; Shield Advanced is reserved for patient-facing endpoints given its fixed fee.

Encryption. Data at rest uses a customer-managed KMS key, cha-data-key, with annual rotation and a key policy separating administrators from users; Aurora, DynamoDB and S3 use it (Appendix G, Figure G1). In transit, viewers reach CloudFront over TLS, CloudFront reaches the ALB over HTTPS with an ACM certificate, and Aurora connections require TLS through the require_secure_transport parameter. In the PoC the ALB listener is HTTP only, because no domain was available to validate a certificate; production would require HTTPS throughout and redirect port 80.

Logging and governance. CloudTrail records API activity with log file validation, so tampering can be detected. AWS Config evaluates managed rules such as rds-storage-encrypted, and AWS Security Hub pulls findings into one view. Its posture-management component, Security Hub CSPM, evaluates the account against the AWS Foundational Security Best Practices standard (AWS, n.d.h). In the PoC the trail writes to a dedicated cha-audit-logs bucket; in production that bucket would sit in a separate log-archive account with Object Lock, so an attacker who compromises the workload account cannot also erase the evidence (Appendix G, Figures G5 to G7, with a sample event in Figure G9). GuardDuty raised one low-severity finding, root credential use during account set-up, which was reviewed and closed by moving daily work to an MFA-protected IAM user (Figure G10), and IAM Access Analyzer found no resources shared outside the account (Figure G11). Under the shared responsibility model every control in this section is CHA's to configure, while AWS secures the platform (AWS, n.d.e).

5.2 GDPR and healthcare compliance

Three points shape the design. Residency: each jurisdiction’s data stays in a Region its law allows, enforced by service control policies that deny other Regions, and large-scale health data processing needs a data protection impact assessment under Article 35. Roles: CHA mostly acts as a processor for hospital customers, so the lawful basis (Article 9(2)(h) is the usual route for care) sits in those contracts, with AWS as sub-processor.

Article 17 lets a patient ask for erasure. The design keeps Aurora snapshots, versioned S3 objects and cross-Region disaster recovery copies, none of which can be edited record by record. The ICO accepts that backup data may be put ‘beyond use’ until it is overwritten on schedule, provided the individual is told (ICO, n.d.). That works for a 35-day snapshot rotation and far less well for long-term archives, and statutory retention periods for clinical records can override erasure under Article 17(3), so the answer differs by country. The mitigations are narrow: short retention on personal-data snapshots, a lifecycle rule that expires non-current object versions (the PoC rule covers current versions only) and a restore procedure that re-applies pending erasures.

5.3 Risk assessment

Misconfiguration is the most likely risk and credential compromise the most damaging; backups count as a security control too, since ransomware that reaches them removes the last line of defence.

Table 5 rates each risk and its controls.

Table 5: Security risk assessment for the target architecture

Risk	Likelihood	Impact	Controls
Misconfigured data store or key policy exposes records	Medium	High	Config rules; Security Hub findings; peer-reviewed Terraform; Block Public Access; SCPs
Compromised human or workload credentials	Low	High	MFA on every login; short-lived roles, no long-lived keys; CloudTrail alarms on root and IAM changes
Ransomware reaches the backups	Low	High	Object Lock; separate backup account; quarterly restore tests
Loss of an Availability Zone or a Region	Low	High	Multi-AZ everywhere; warm standby Region (Section 7); in-country secondary for Gulf data
Erasure request cannot be honoured in backups	Medium	Medium	Short snapshot retention; expire non-current versions; erasure re-applied after restore; legal review

6. Cost Optimisation and Support Strategy (Task 5)

6.1 Estimated monthly cost

Table 6 lists the services and inputs used in the AWS Pricing Calculator; Appendix H holds the exported estimate.

Table 6: Pricing Calculator inputs and monthly results

Service	Configuration entered	Monthly (USD)
ECS on Fargate	Linux/x86, 2 tasks, 0.25 vCPU, 0.5 GB, 730 h/month	18.02
EC2 Auto Scaling Group	2 × t3.medium Linux, On-Demand, 100% use, 30 GB gp3 each	65.54
Aurora MySQL, Multi-AZ	2 × db.t3.medium (writer and reader), Aurora Standard, 100 GB; 7-day backups within the free allowance	163.20
DynamoDB, on-demand	50M writes and 10M reads a month, 25 GB, 1 KB items	38.13
S3 storage classes	2 TB Standard (1M PUT, 10M GET); 5 TB Standard-IA; 10 TB Glacier Flexible Retrieval	160.55
CloudFront and data transfer out	5 TB out to the internet, 50 GB to origin, 20M HTTPS requests, pay-as-you-go	456.20
NAT gateways (2) and ALB	2 zonal NAT gateways, 730 h, 1 TB processed; 1 ALB, 1 TB processed	136.40
WAF, CloudWatch, X-Ray	WAF: 1 web ACL, 1 rule, 20M requests; CloudWatch: 20 metrics, 1 dashboard, 1 alarm, 50 GB logs; X-Ray: 5M traces	74.33
Warm standby Region	us-west-2: 1 Fargate task; 1 × db.t3.medium Aurora, 100 GB	81.82
Total		1,194.19

The brief gives no figure for CHA's current running cost, so the 40% target cannot be tested from the brief alone. I set the baseline as an explicit assumption: USD 41,000 per month, covering about 14 hosts for the 220 VMs depreciated over five years, VMware and SQL Server licences, data-centre space and power, and 2.5 full-time operations staff. The AWS estimate must come in at or below 60% of it. Support and parallel running are extra. Table 6 totals USD 1,194.19 a month but prices the PMP and TPP platform with only two rehosted legacy servers, not all 220 VMs. If, after idle machines are

retired, 150 servers were rehosted on t3.medium-class instances at about USD 33 each, the total would be roughly USD 6,100 a month, about 15% of the assumed baseline and well inside the 60% limit. The margin survives large errors, but rests on the assumed baseline.

6.2 Optimisation techniques

Compute Savings Plans suit the steady baseline. They cover Fargate and Lambda as well as EC2 with discounts up to 66%, while EC2 Instance Savings Plans reach 72% but cover EC2 only (AWS, n.d.g). Most of this design is Fargate, so the flexible plan fits. I would commit only to the always-on floor, measured over two or three months, and leave peaks on demand. Reserved Instances suit Aurora's steady writer and reader, which Compute Savings Plans do not cover. Auto Scaling is tuned with target tracking, a two-task floor for patient-facing services and a lower overnight floor for non-clinical ones. Scaling in and tiering cold data also serve the sustainability pillar.

The S3 lifecycle rule on cha-backups moves objects to Standard-IA at 30 days and Glacier Flexible Retrieval at 90. Those classes carry minimum storage durations and retrieval charges, and objects must sit in Standard for 30 days first (AWS, n.d.j), so tiering short-lived objects can cost more than leaving them. Compute Optimizer flags over-provisioned Fargate, EC2 and Lambda once weeks of metrics exist. Gateway VPC endpoints for S3 and DynamoDB are free and keep that traffic off the NAT gateways, which charge per gigabyte (Appendix B, Figure B4).

Spot suits interruptible batch work. Fargate Spot gives a two-minute warning before reclaiming a task (AWS, n.d.c), which such jobs handle by checkpointing. It does not suit the PMP or TPP: a reclaimed task drops a live video consultation or delays a critical vitals alert, and Spot capacity may not exist when demand peaks.

6.3 Support strategy

An AWS Support tier with round-the-clock access and a production-down response target measured in minutes is recommended to be purchased. Inside CHA it needs an on-call rota, runbooks tied to CloudWatch alarms, mandatory cost-allocation tags, Budgets alerts (the PoC has one at USD 20, Appendix A) and a monthly review where engineering and finance read the same Cost Explorer view. Business Support also unlocks the full AWS Trusted Advisor checks for idle resources, open security groups and quotas (AWS, n.d.f).

7. Data Migration and Business Continuity (Task 6)

7.1 Database migration with AWS DMS

DMS runs a full load of each source database and then applies ongoing changes, so the source stays live while the target catches up (AWS, n.d.l). The replication instance sits in a private subnet and reaches the source servers over the VPN. Cutover follows a fixed order: pause writes, wait for replication lag to reach zero, validate, switch connection strings. The target is a 15-minute write freeze, which the pilot must test. SQL Server is the harder case, since stored procedures and T-SQL do not convert automatically, which is why it stays on its own engine at first. In the PoC DMS migrated Amazon RDS for MySQL 8.4 to Aurora MySQL 3 (MySQL 8.0-compatible); two tables and 15 rows by full load plus one row by change data capture, every row validated (Appendix I, Figures I1 and I2).

7.2 Historical data to S3

Records older than seven years are rarely read and cost most on database storage. They move to S3 as Parquet, through a DMS task with an S3 target or, for file shares, AWS DataSync, and sit under the same lifecycle tiers. Glue and Athena keep them queryable without a restore. This part is design only.

7.3 Validation

Validation has three layers. DMS data validation compares rows between source and target. For files, a SHA-256 hash is computed at the source with openssl, the object is uploaded with put-object and the --checksum-algorithm SHA256 flag, and the checksum S3 returns from head-object must match it. Glue jobs compare record counts and sums per partition between the source extract and the Athena tables, catching errors row checks miss, such as a truncated partition. In the PoC that ran an AWS Glue Python shell job that compared the row count of the exported vitals file in S3 with the item count in DynamoDB and logged both (Appendix I, Figure I5). It reported a mismatch, 8 against 5, because the two stores hold different test data, which is the check doing its job.

Put-object was used because multipart uploads through aws s3 cp produce composite checksums that do not compare with a whole-file hash. In the PoC the two values matched (Appendix I, Figure I3).

7.4 Backup, restore and disaster recovery

Aurora takes automated backups with up to 35 days of retention, and AWS Backup copies snapshots to a second account and, where law allows, a second Region. Restores are tested quarterly by building a cluster from a snapshot and comparing row counts; an untested backup is a hope, not a control. In the PoC the cha-prod-db was restored from an automated snapshot into a new cluster, which came back encrypted with cha-data-key (Appendix I, Figure I4).

For disaster recovery warm standby is committed to. The 99.99% target leaves about 52 minutes of downtime a year for everything, and pilot light, where compute is built from nothing and the database restored after a disaster, would spend most of that on one event (AWS, 2021a). Warm standby keeps a scaled-down running copy in the recovery Region: an Aurora Global Database secondary that typically lags under a second and can be promoted in under a minute, an ECS service at minimum task count and a Route 53 failover record (AWS, n.d.b). Recovery time is then mostly DNS failover and scale-up, which is estimated in minutes, with data loss measured in seconds. These are AWS's figures and need proving in a game day (AWS, 2024). Warm standby costs more than pilot light, and Table 6 includes it.

For UAE data, the Section 4 constraint applies: a cross-Region secondary may not be permitted, so the fallback is a second in-country site holding in-country backups, with a longer recovery time. It is recorded as a known gap against 99.99% for Gulf tenants until the regulator's position or AWS's regional capacity changes.

8. Hybrid Connectivity and Edge Integration (Task 7)

8.1 Site-to-Site VPN and Direct Connect

Branch hospitals connect through Site-to-Site VPN. Each connection has two IPsec tunnels ending on AWS endpoints in different zones, and BGP reroutes around a failed tunnel without an operator (AWS, n.d.o). For dozens of branches attach every VPN has been attached to an AWS Transit Gateway hub instead of a virtual private gateway per VPC, so a new branch is one attachment and Transit Gateway route tables keep branches isolated from each other. The PoC VPN uses a

placeholder customer gateway, so its tunnels cannot come up; it shows configuration, not connectivity (Appendix J, Figures J1 and J2).

Direct Connect suits the data centre link during migration, where volume and steady latency matter more than a VPN over the internet can promise. AWS recommends connections at two separate locations for high resilience, with a Site-to-Site VPN as a cheaper backup path (AWS, n.d.d). Direct Connect could not be provisioned for a real second site from a personal account, so Figure 3 shows it as a design decision only (Appendix J, Figure J7 shows the order screen for a four-connection maximum-resiliency design, which I did not submit).

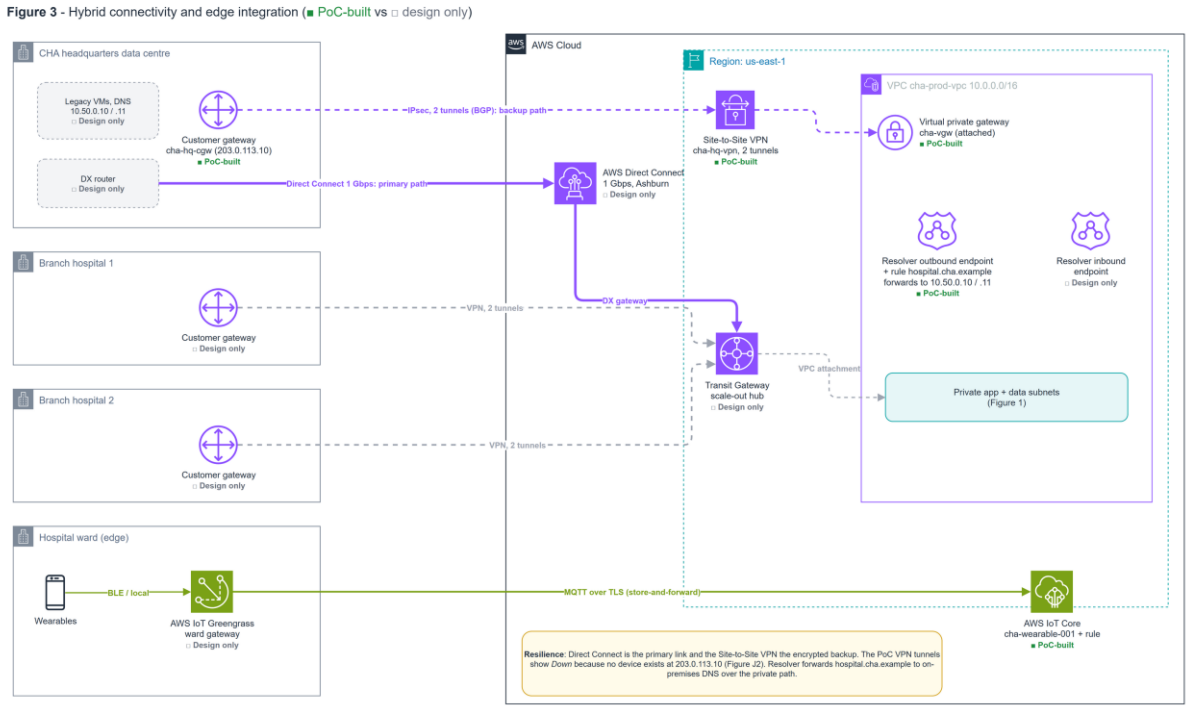


Figure 3: Hybrid connectivity and edge integration

8.2 Hybrid DNS

Route 53 Resolver joins the two DNS worlds. An outbound endpoint and forwarding rule send queries for the hospital domain (for example hospital.cha.example) to the on-premises DNS servers, and an inbound endpoint lets those servers resolve names in the AWS private hosted zone (aws.cha.example) (AWS, n.d.q). The PoC has one forwarding rule as a worked example (Appendix J, Figure J3), forwarding hospital.cha.example to two placeholder on-premises resolvers, 10.50.0.10 and 10.50.0.11.

8.3 IoT Core and Greengrass

Each wearable authenticates to AWS IoT Core with its own X.509 certificate and publishes MQTT over TLS (AWS, n.d.m). An IoT policy limits every device to its own client ID and topic through the iot:Connection.Thing.ThingName policy variable, so a compromised wearable cannot publish as another. A rule writes to the DynamoDB table cha-iot-vitals and copies each reading to the SQS queue cha-alerts-queue for a threshold-checking consumer. In the PoC a thing was registered, generated a certificate, created the rule and confirmed a test message arrived (Appendix J, Figures J4 to J6). The rule's IAM role could not write to the table until it was granted use of cha-data-key, showing that a customer-managed key enforces least privilege even for AWS services.

Greengrass adds edge processing on a gateway at each hospital ward (AWS, n.d.n). Local components score vitals and forward only exceptions, so alerts avoid a Region round trip and wards keep working through a WAN outage. The cost is operational: hundreds of edge devices to patch, secure and re-certify. Greengrass is design only here.

9. AI and Analytics Integration

Raw vitals in DynamoDB are exported to an S3 data lake as Parquet, registered in the Glue Data Catalog and queried with Athena. Amazon SageMaker trains deterioration risk models on pseudonymised data inside the same Region and KMS key hierarchy. The model runs behind a real-time endpoint or Lambda function, scores go back to DynamoDB, and a score above threshold publishes to the SNS alert topic for the care team. The same model can run on Greengrass gateways for bedside scoring, retrained in the cloud on a schedule. This is design only; no model was trained. In the PoC a Glue crawler registered the exported vitals in the Data Catalog and an Athena query aggregated them by ward, confirming the query path (Appendix L, Figures L1 and L2).

Two cautions matter more than the pipeline. Models can absorb the biases of the populations they were trained on, and performance can differ between patient groups (Rajkomar, Dean and Kohane, 2019); SageMaker Clarify reports bias metrics, but somebody has to act on them. A risk score that influences treatment may also count as medical device software, which under Regulation (EU) 2024/1689 can make it high-risk (European Union, 2024). The design keeps a clinician in the loop and monitors drift with SageMaker Model Monitor.

10. Conclusion

The current estate cannot deliver the board’s targets. One site, manual operations and a monolithic application cap scale, availability and audit, and the exposure of health data makes standing still expensive. The design answers each limitation with a specific service (Table 1). The migration moves in rehearsed waves, and a warm standby Region covers the rare events that take out a whole Region.

The limits need stating. The PoC ran in one Region on small instance classes, so it shows the design can be built, not that it copes with 100,000 concurrent users. The VPN tunnels cannot come up without a real device, Direct Connect, Greengrass and the AI pipeline are design only, and the cost result rests on an assumed baseline. The 99.99% figure is an objective to measure, not a guarantee. The erasure and backup conflict stays open, and the Gulf position depends on AWS restoring capacity and on regulators’ exceptions.

Given more time a multi-account landing zone could be built with AWS Control Tower, turn the Terraform into a pipeline with policy checks, run a failover game day to measure real recovery times, load test to 100,000 users and evaluate EKS as services multiply. Legal review of residency and erasure comes first.

References

Al Tamimi and Company (2021) *Health data transfers outside the UAE*. Available at: https://www.tamimi.com/news/health-data-transfers-outside-the-uae/ (Accessed: 19 September 2026).

Amazon Web Services (AWS) (2021a) *Disaster recovery of workloads on AWS: recovery in the cloud [Whitepaper].* Available at: https://docs.aws.amazon.com/whitepapers/latest/disaster-recovery-workloads-on-aws/disaster-recovery-workloads-on-aws.html (Accessed: 3 October 2026).

Amazon Web Services (AWS) (2021b) *An overview of the AWS Cloud Adoption Framework [Whitepaper].* Available at: https://docs.aws.amazon.com/whitepapers/latest/overview-aws-cloud-adoption-framework/welcome.html (Accessed: 3 October 2026).

Amazon Web Services (AWS) (2024) *AWS Well-Architected Framework.* Available at: https://docs.aws.amazon.com/wellarchitected/latest/framework/welcome.html (Accessed: 3 October 2026).

Amazon Web Services (AWS) (2025) *Amazon Aurora service level agreement.* Available at: https://aws.amazon.com/rds/aurora/sla/ (Accessed: 3 October 2026).

Amazon Web Services (AWS) (n.d.a) *About the migration strategies.* Available at: https://docs.aws.amazon.com/prescriptive-guidance/latest/large-migration-guide/migration-strategies.html (Accessed: 3 October 2026).

Amazon Web Services (AWS) (n.d.b) *Amazon Aurora Global Database.* Available at: https://aws.amazon.com/rds/aurora/global-database/ (Accessed: 3 October 2026).

Amazon Web Services (AWS) (n.d.c) *Amazon ECS clusters for Fargate.* Available at: https://docs.aws.amazon.com/AmazonECS/latest/developerguide/fargate-capacity-providers.html (Accessed: 3 October 2026).

Amazon Web Services (AWS) (n.d.d) *AWS Direct Connect resiliency recommendations.* Available at: https://aws.amazon.com/directconnect/resiliency-recommendation/ (Accessed: 3 October 2026).

Amazon Web Services (AWS) (n.d.e) *AWS shared responsibility model.* Available at: https://aws.amazon.com/compliance/shared-responsibility-model/ (Accessed: 3 October 2026).

Amazon Web Services (AWS) (n.d.f) *AWS Trusted Advisor.* Available at: https://docs.aws.amazon.com/awssupport/latest/user/trusted-advisor.html (Accessed: 3 October 2026).

Amazon Web Services (AWS) (n.d.g) *Compute Savings Plans and Reserved Instances.* Available at: https://docs.aws.amazon.com/savingsplans/latest/userguide/sp-ris.html (Accessed: 3 October 2026).

Amazon Web Services (AWS) (n.d.h) *Introduction to AWS Security Hub CSPM.* Available at: https://docs.aws.amazon.com/securityhub/latest/userguide/what-is-securityhub.html (Accessed: 3 October 2026).

Amazon Web Services (AWS) (n.d.i) *Six advantages of cloud computing, in Overview of Amazon Web Services [Whitepaper].* Available at: https://docs.aws.amazon.com/whitepapers/latest/aws-overview/six-advantages-of-cloud-computing.html (Accessed: 3 October 2026).

Amazon Web Services (AWS) (n.d.j) *Transitioning objects using Amazon S3 Lifecycle.* Available at: https://docs.aws.amazon.com/AmazonS3/latest/userguide/lifecycle-transition-general-considerations.html (Accessed: 3 October 2026).

Amazon Web Services (AWS) (n.d.k) *What is AWS Application Discovery Service?.* Available at: https://docs.aws.amazon.com/application-discovery/latest/userguide/what-is-appdiscovery.html (Accessed: 3 October 2026).

Amazon Web Services (AWS) (n.d.l) *What is AWS Database Migration Service?.* Available at: https://docs.aws.amazon.com/dms/latest/userguide/Welcome.html (Accessed: 3 October 2026).

Amazon Web Services (AWS) (n.d.m) *What is AWS IoT?.* Available at: https://docs.aws.amazon.com/iot/latest/developerguide/what-is-aws-iot.html (Accessed: 3 October 2026).

Amazon Web Services (AWS) (n.d.n) *What is AWS IoT Greengrass?.* Available at: https://docs.aws.amazon.com/greengrass/v2/developerguide/what-is-iot-greengrass.html (Accessed: 3 October 2026).

Amazon Web Services (AWS) (n.d.o) *What is AWS Site-to-Site VPN?.* Available at: https://docs.aws.amazon.com/vpn/latest/s2svpn/VPC_VPN.html (Accessed: 3 October 2026).

Amazon Web Services (AWS) (n.d.p) *What is AWS Transform MGN?.* Available at: https://docs.aws.amazon.com/mgn/latest/ug/what-is-application-migration-service.html (Accessed: 3 October 2026).

Amazon Web Services (AWS) (n.d.q) *What is Route 53 VPC Resolver?.* Available at: https://docs.aws.amazon.com/Route53/latest/DeveloperGuide/resolver.html (Accessed: 3 October 2026).

Armbrust, M., Fox, A., Griffith, R., Joseph, A.D., Katz, R., Konwinski, A., Lee, G., Patterson, D., Rabkin, A., Stoica, I. and Zaharia, M. (2010) 'A view of cloud computing', *Communications of the ACM*, 53(4), pp. 50–58.

Beyer, B., Jones, C., Petoff, J. and Murphy, N.R. (eds.) (2016) *Site reliability engineering: how Google runs production systems*. Sebastopol, CA: O'Reilly Media.

CNBC (2026) 'AWS says it can't restore service to Bahrain, UAE facilities 6 months after Iran strikes', *CNBC*, 15 September. Available at: https://www.cnbc.com/2026/09/15/aws-cant-restore-service-to-bahrain-uae-6-months-after-iran-strikes.html (Accessed: 19 September 2026).

European Union (2016) Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data (General Data Protection Regulation). *Official Journal of the European Union*, L 119, pp. 1–88.

European Union (2024) Regulation (EU) 2024/1689 of the European Parliament and of the Council laying down harmonised rules on artificial intelligence (Artificial Intelligence Act). *Official Journal of the European Union*, L, 2024/1689.

Forsgren, N., Humble, J. and Kim, G. (2018) *Accelerate: the science of lean software and DevOps*. Portland, OR: IT Revolution Press.

Fowler, M. and Lewis, J. (2014) *Microservices: a definition of this new architectural term*. Available at: https://martinfowler.com/articles/microservices.html (Accessed: 19 September 2026).

Government of India (2023) *The Digital Personal Data Protection Act, 2023* (Act No. 22 of 2023). New Delhi: Ministry of Law and Justice.

IBM (2026) *Cost of a data breach report 2026*. Armonk, NY: IBM Corporation. Available at: https://www.ibm.com/reports/data-breach (Accessed: 19 September 2026).

ICO (n.d.) *Right to erasure.* Available at: https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/individual-rights/individual-rights/right-to-erasure/ (Accessed: 3 October 2026).

Markovic, S. (2026) 'Iranian strikes on AWS facilities left customer data beyond recovery in Bahrain, UAE', *Help Net Security*, 17 September. Available at: https://www.helpnetsecurity.com/2026/09/17/aws-middle-east-outage-permanent-data-loss-bahrain-uae/ (Accessed: 19 September 2026).

Mell, P. and Grance, T. (2011) *The NIST definition of cloud computing*. NIST Special Publication 800-145. Gaithersburg, MD: National Institute of Standards and Technology.

Morris, K. (2025) *Infrastructure as code: designing and delivering dynamic systems for the cloud age.* 3rd edn. Sebastopol, CA: O'Reilly Media.

Newman, S. (2021) *Building microservices: designing fine-grained systems*. 2nd edn. Sebastopol, CA: O'Reilly Media.

Rajkomar, A., Dean, J. and Kohane, I. (2019) 'Machine learning in medicine', *New England Journal of Medicine*, 380(14), pp. 1347–1358.

Singh, S.P. and Pandey, A. (2023) *Use Amazon Aurora Global Database to set up disaster recovery within India.* AWS Database Blog, 4 May. Available at: https://aws.amazon.com/blogs/database/use-amazon-aurora-global-database-to-set-up-disaster-recovery-within-india (Accessed: 3 October 2026).

Weinman, J. (2012) *Cloudonomics: the business value of cloud computing*. Hoboken, NJ: Wiley.

Appendices

Appendix A: Account and cost controls

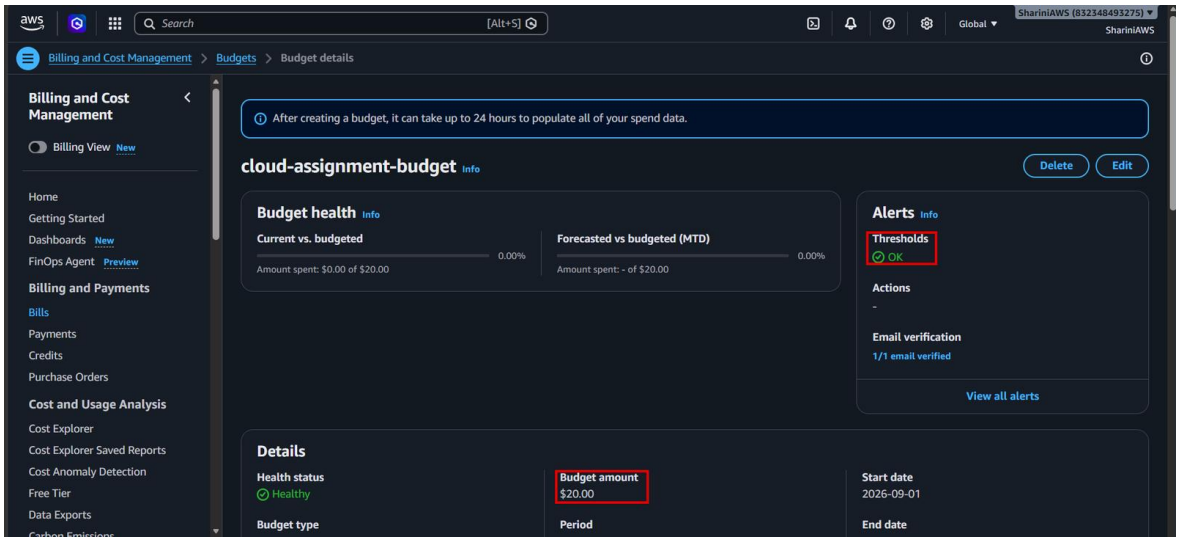


Figure A1: AWS Budgets alert for the PoC account

Appendix B: Network

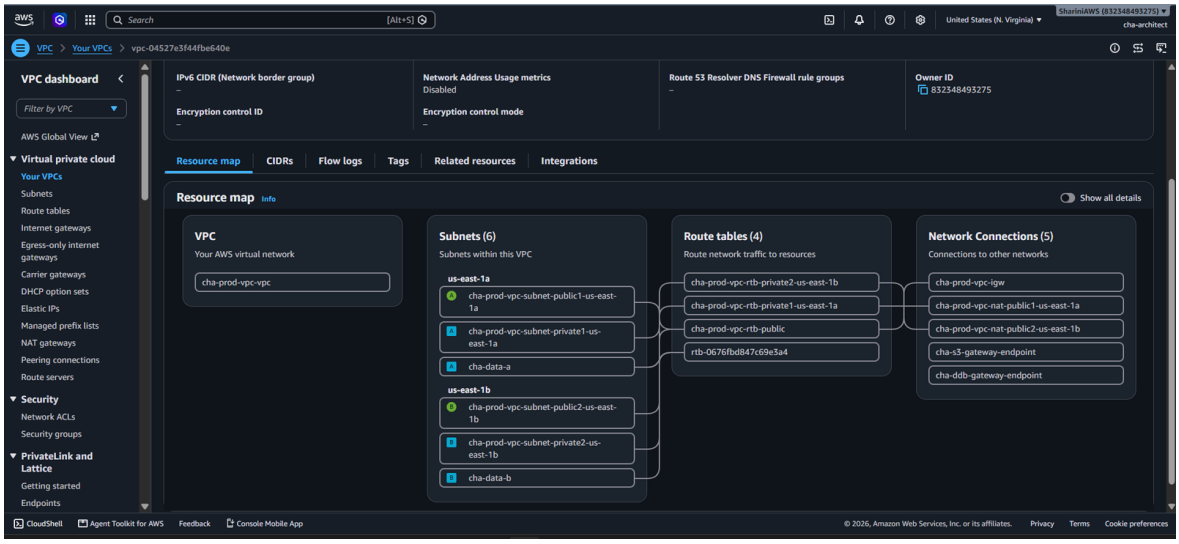


Figure B1: Resource map for cha-prod-vpc-vpc

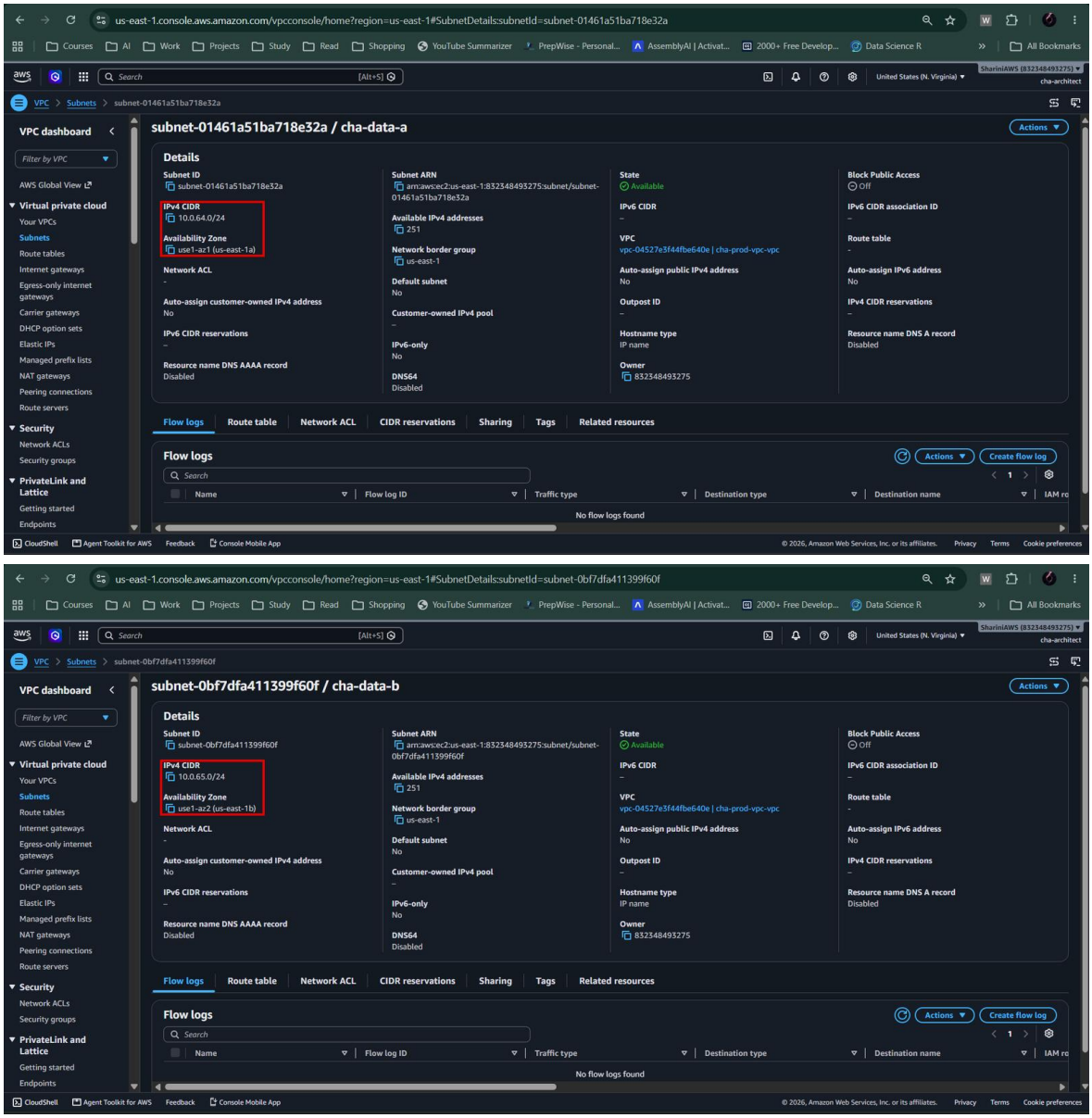


Figure B2: Subnet list showing the data-tier subnets

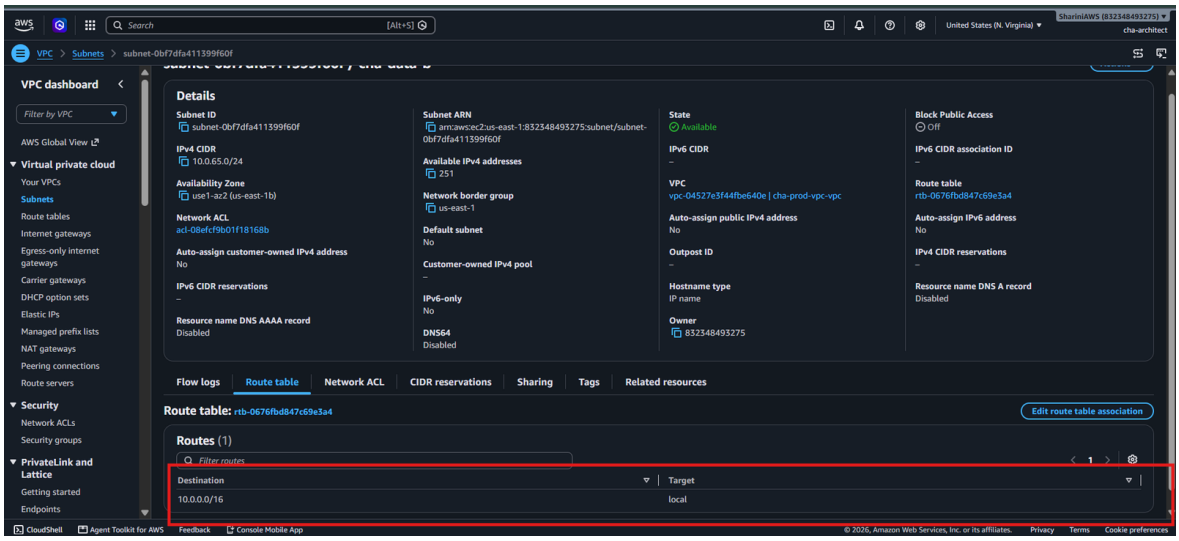


Figure B3: Route table for the data-tier subnets

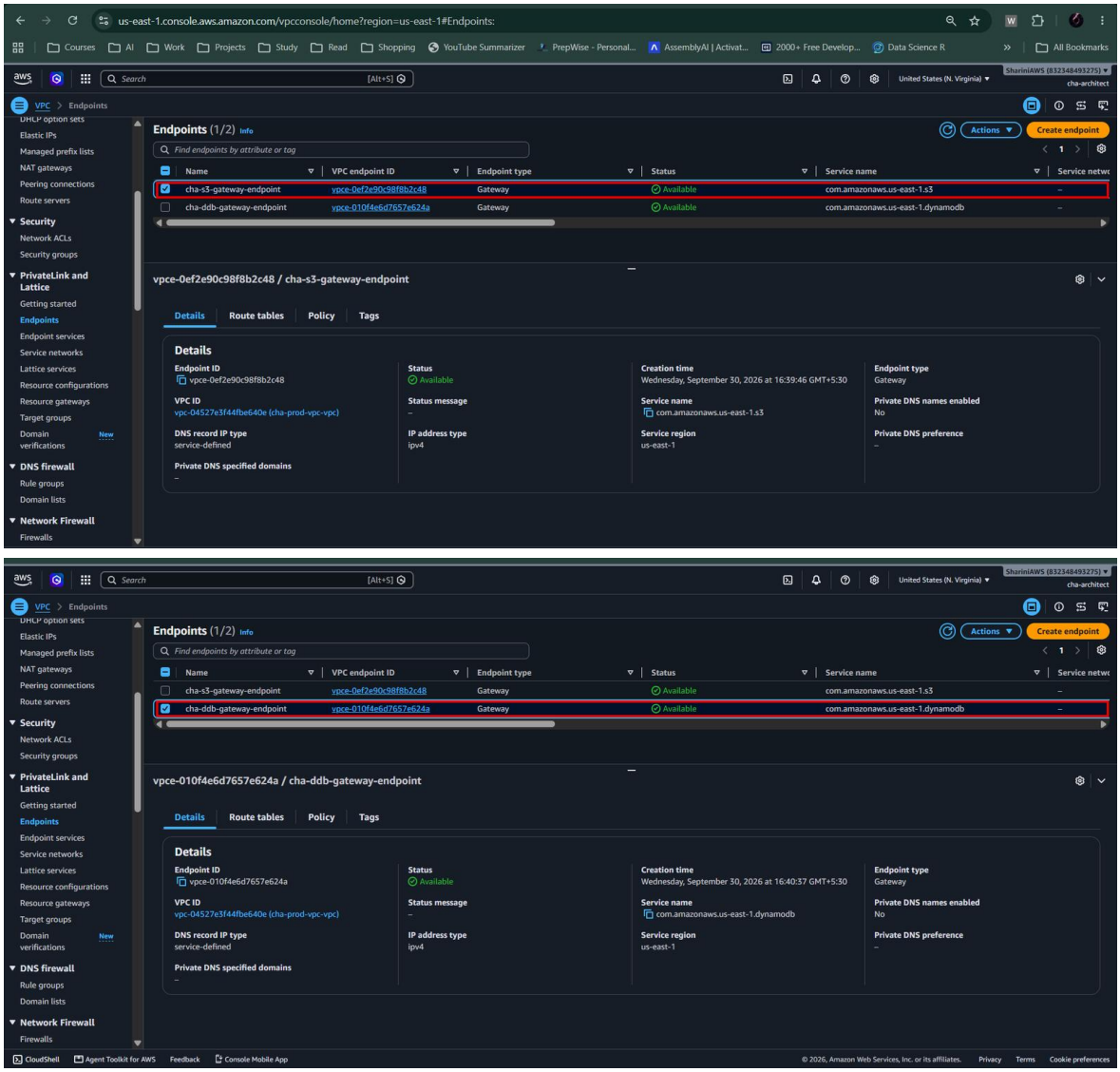


Figure B4: Gateway VPC endpoints for S3 and DynamoDB

Appendix C: Load balancing and security groups

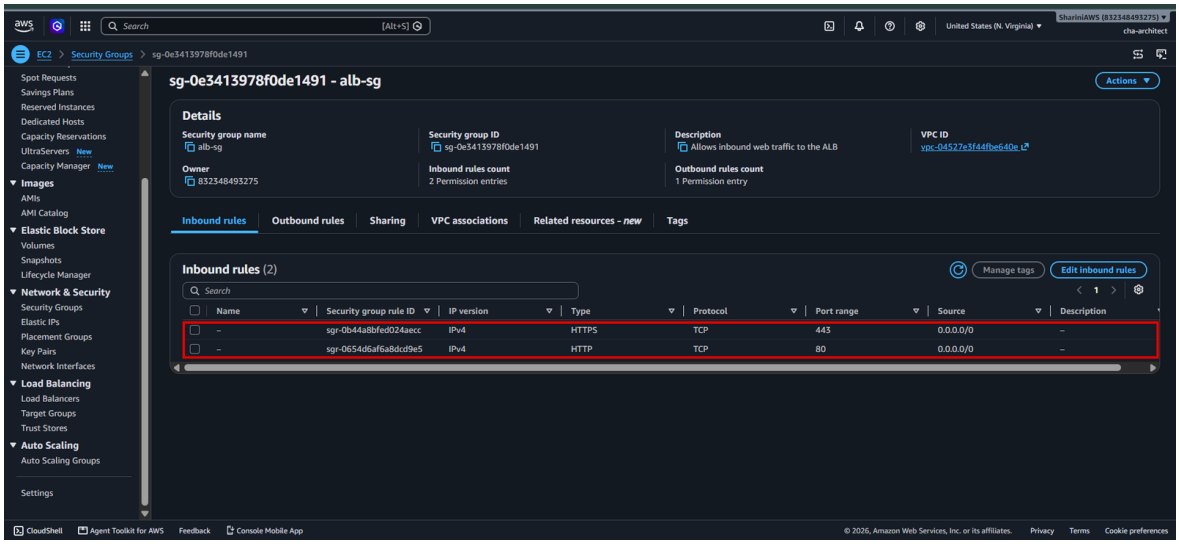


Figure C1: Security group alb-sg, inbound rules

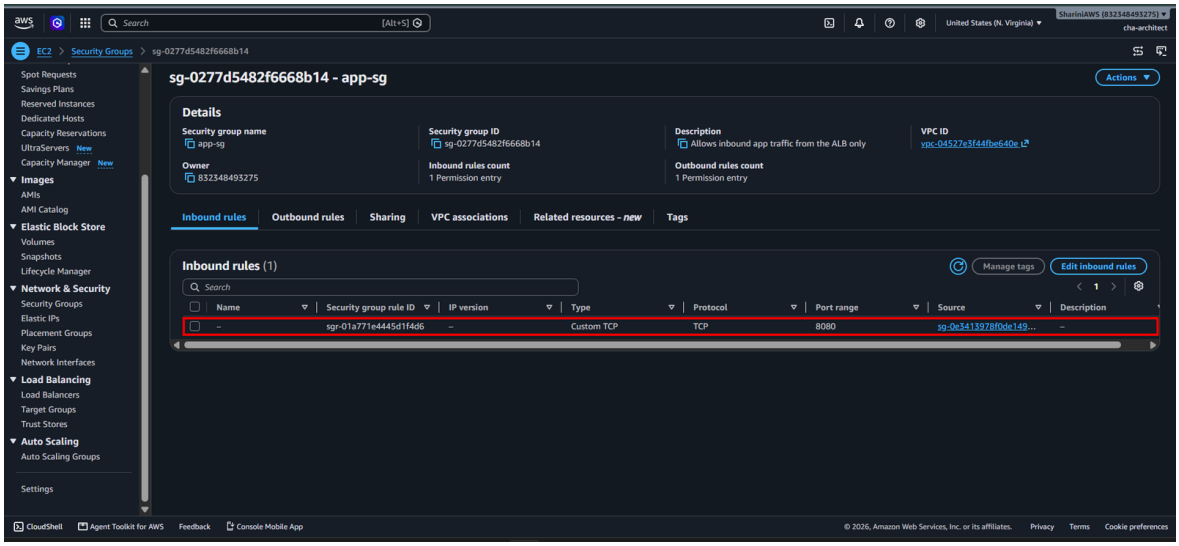


Figure C2: Security group app-sg, inbound rules

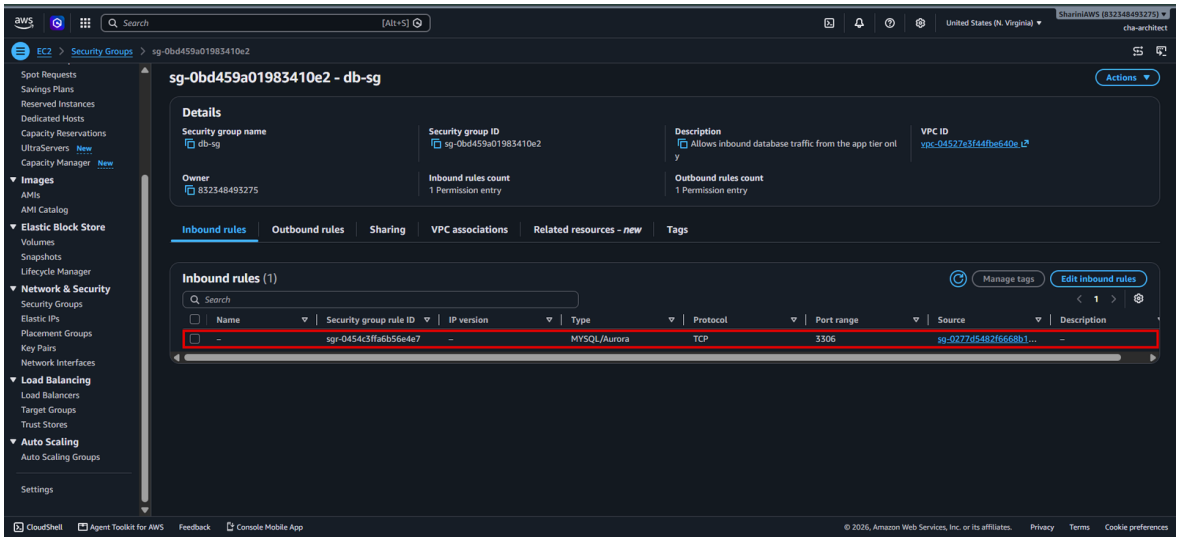


Figure C3: Security group db-sg, inbound rules

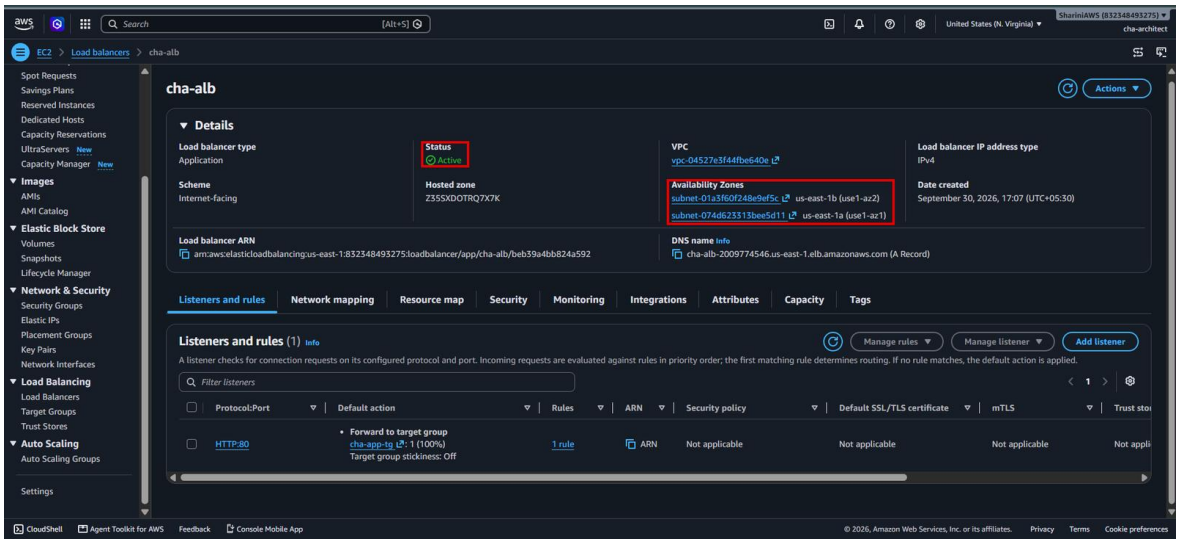


Figure C4: Application Load Balancer cha-alb

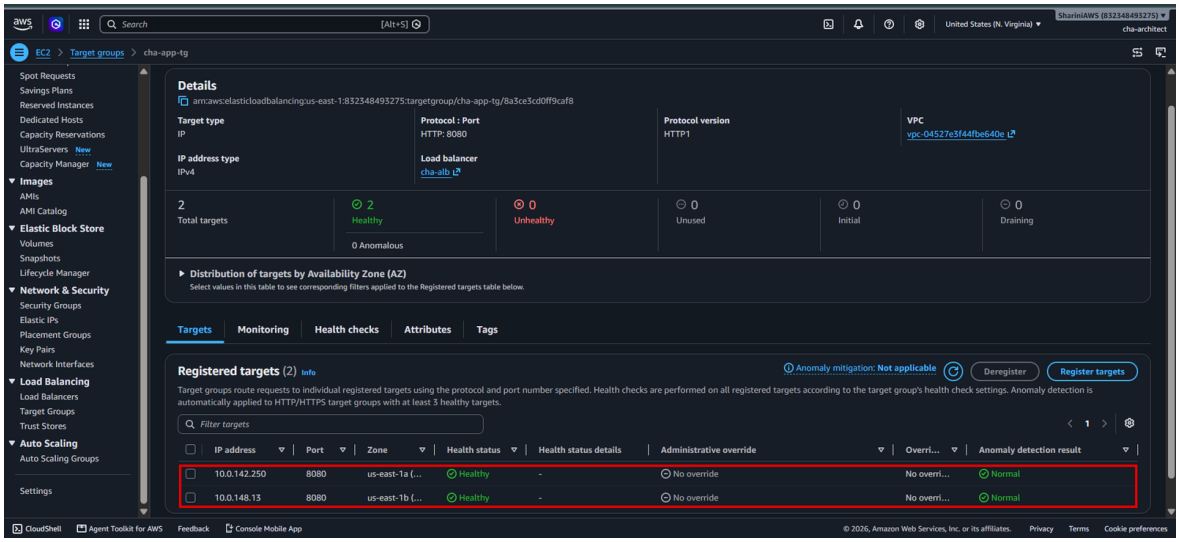


Figure C5: Target group cha-app-tg

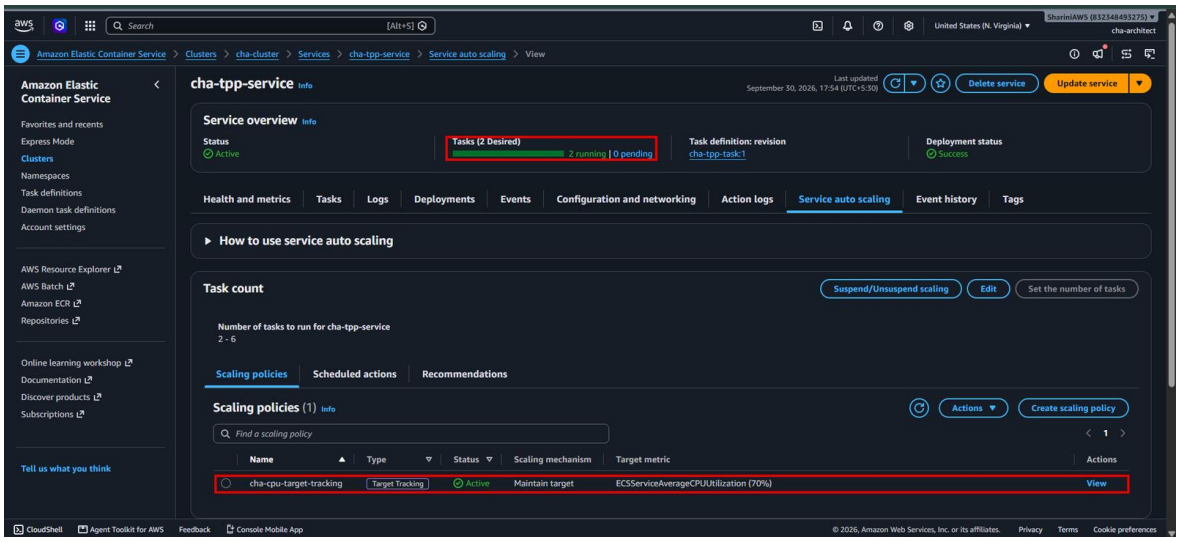


Figure C6: ECS service and Service Auto Scaling policy

Appendix D: Data tier and storage

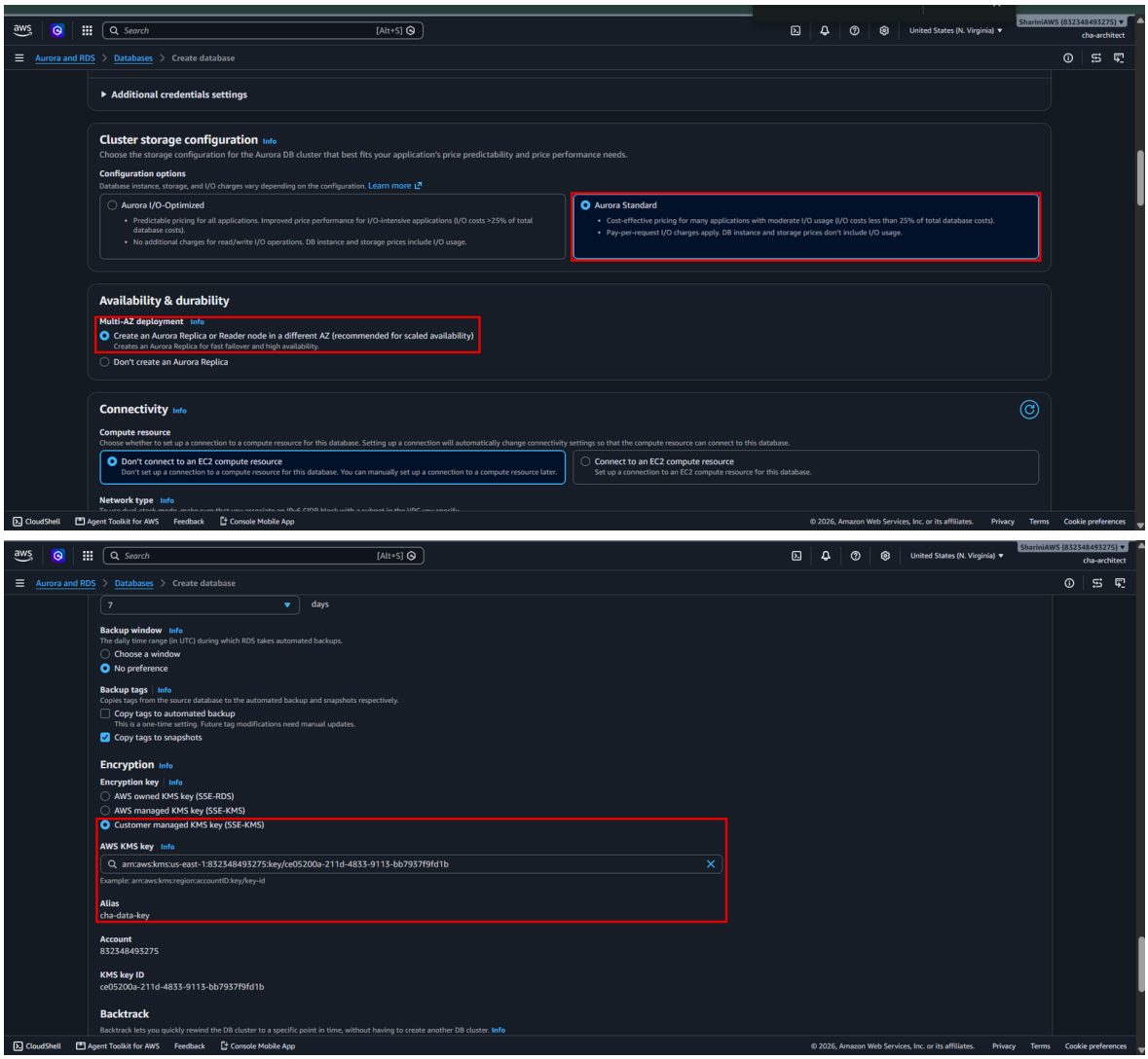


Figure D1: Aurora Multi-AZ configuration before creation

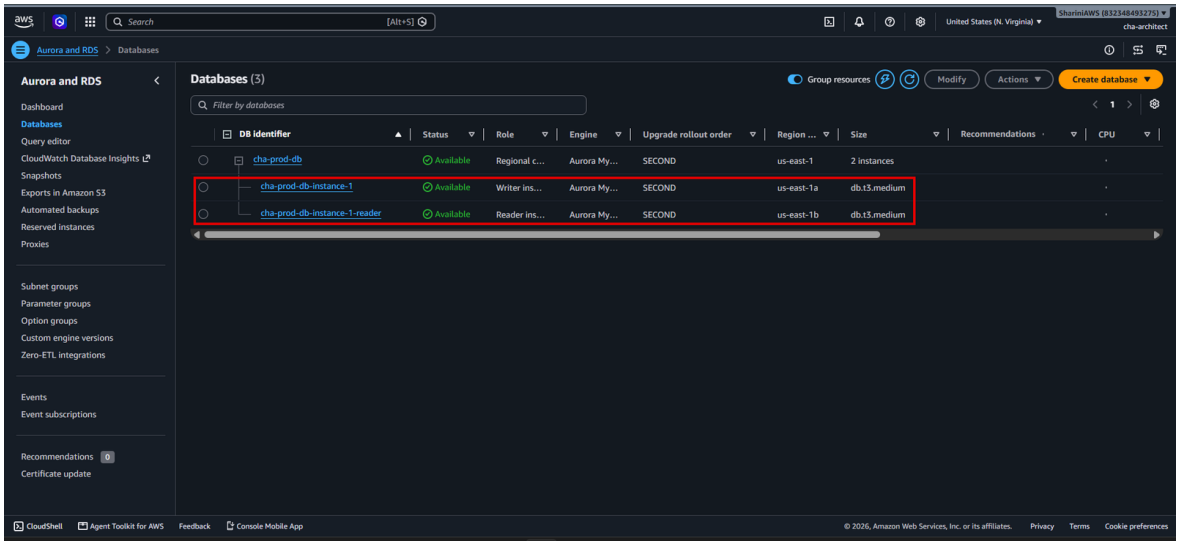


Figure D2: Aurora cluster cha-prod-db with status Available

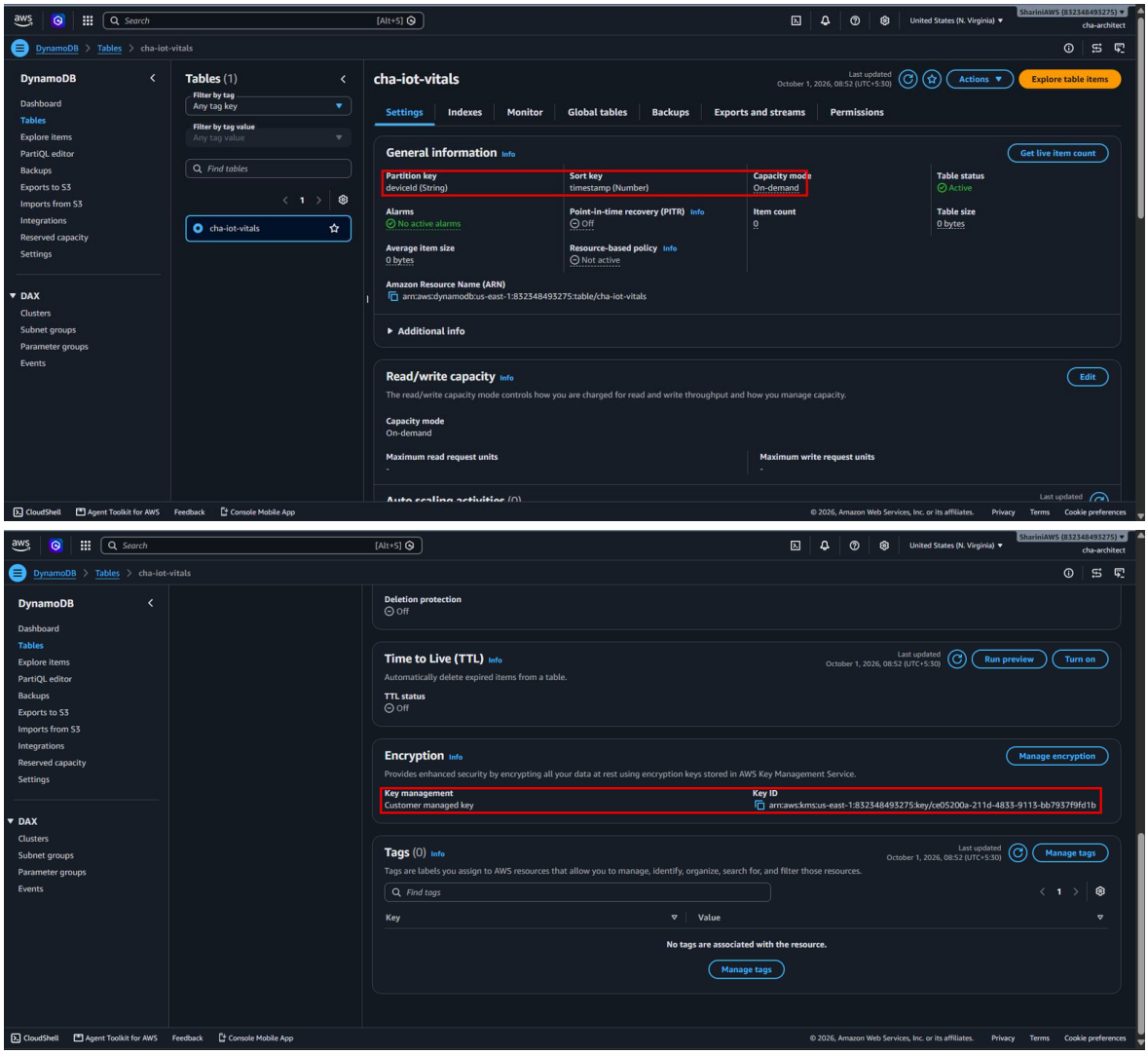


Figure D3: DynamoDB table cha-iot-vitals

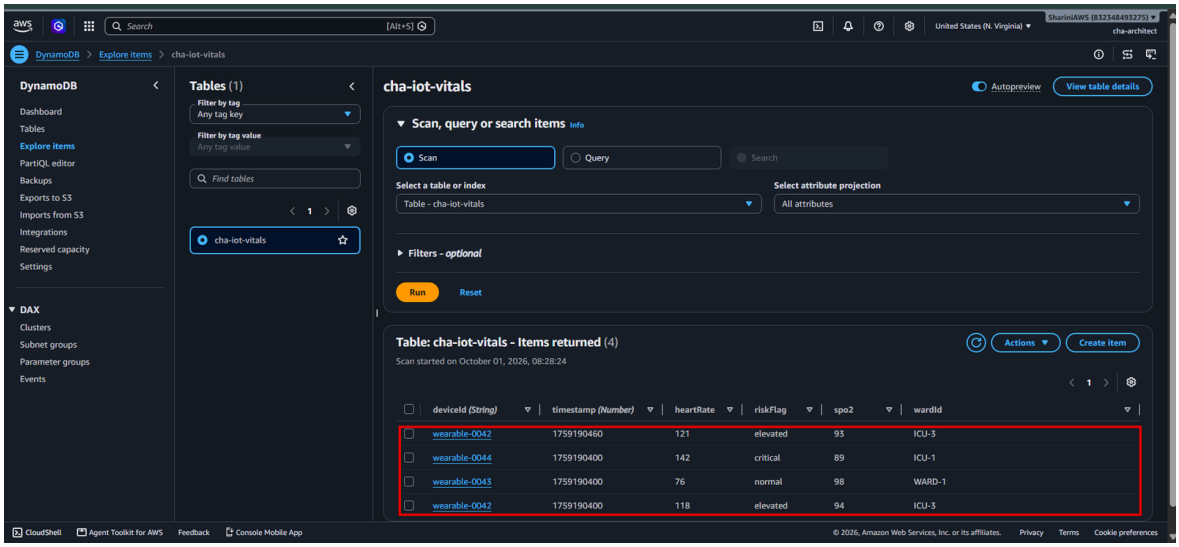
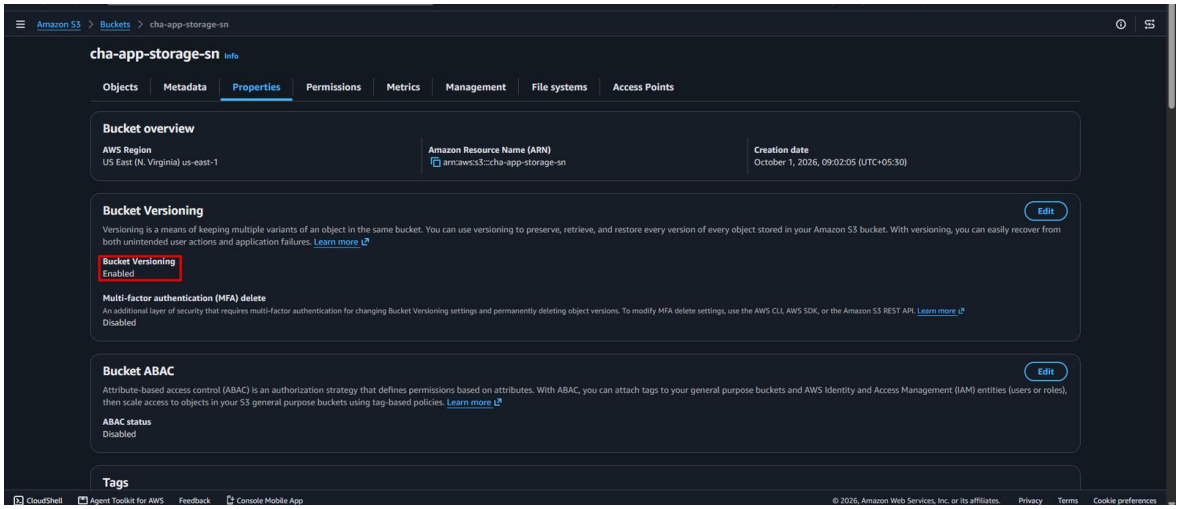
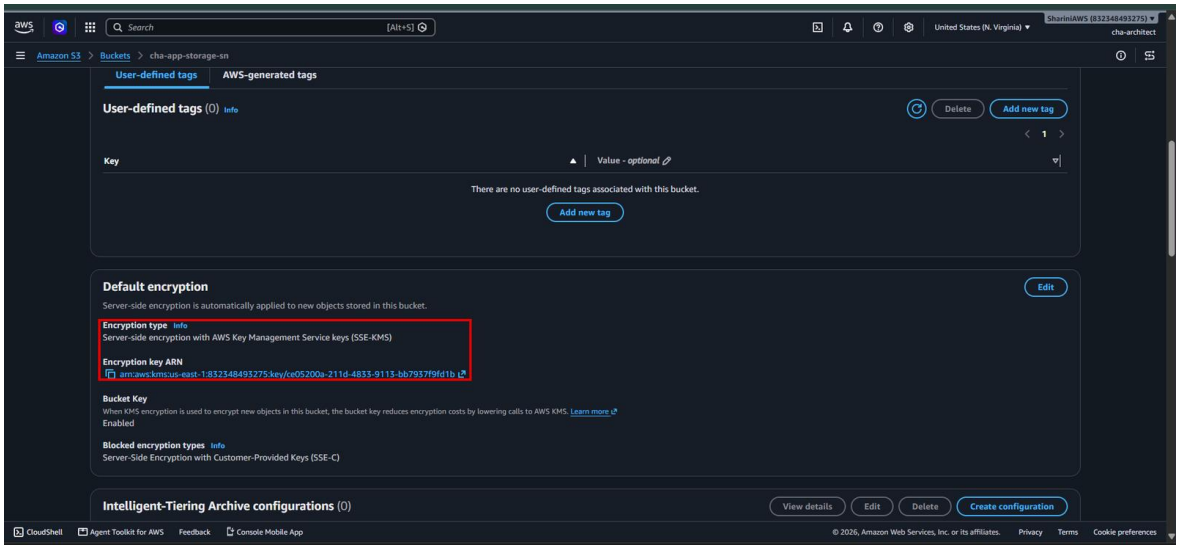
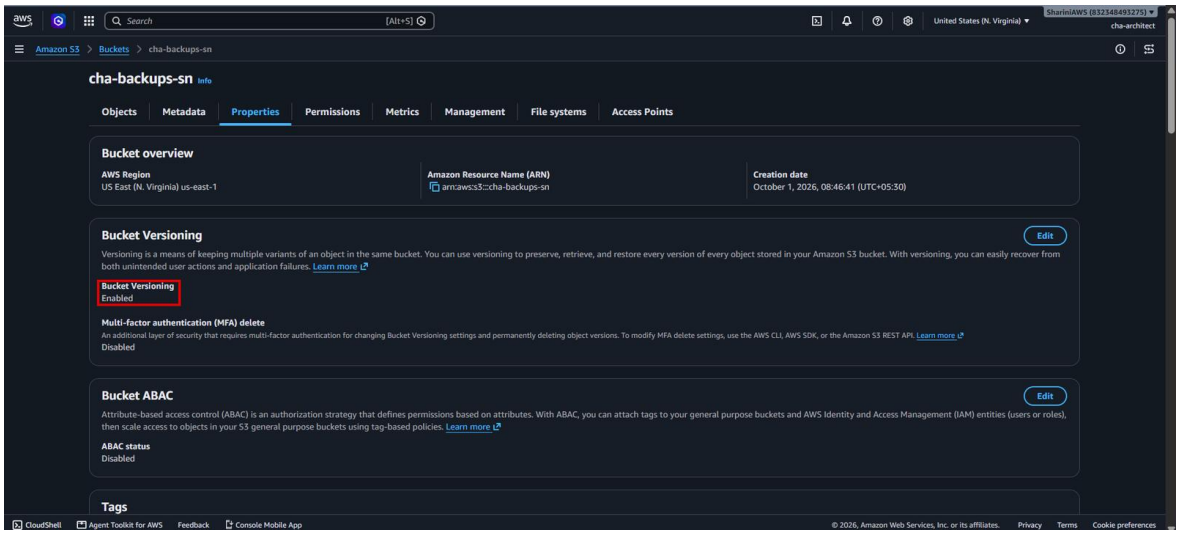


Figure D4: Sample item in cha-iot-vitals


Amazon S3 > Buckets > cha-app-storage-sn
cha-app-storage-sn Info
Objects Metadata Properties Permissions Metrics Management File systems Access Points
Bucket overview
AWS Region
US East (N. Virginia) us-east-1
Amazon Resource Name (ARN)
arn:aws:s3:::cha-app-storage-sn
Creation date
October 1, 2026, 09:02:05 (UTC+05:30)
Bucket Versioning
Edit
Versioning is a means of keeping multiple variants of an object in the same bucket. You can use versioning to preserve, retrieve, and restore every version of every object stored in your Amazon S3 bucket. With versioning, you can easily recover from both unintended user actions and application failures. Learn more
Bucket Versioning
Enabled
Multi-factor authentication (MFA) delete
An additional layer of security that requires multi-factor authentication for changing Bucket Versioning settings and permanently deleting object versions. To modify MFA delete settings, use the AWS CLI, AWS SDK, or the Amazon S3 REST API. Learn more
Disabled
Bucket ABAC
Edit
Attribute-based access control (ABAC) is an authorization strategy that defines permissions based on attributes. With ABAC, you can attach tags to your general purpose buckets and AWS Identity and Access Management (IAM) entities (users or roles), then scale access to objects in your S3 general purpose buckets using tag-based policies. Learn more
ABAC status
Disabled
Tags
CloudShell Agent Toolkit for AWS Feedback Console Mobile App
© 2026, Amazon Web Services, Inc. or its affiliates. Privacy Terms Cookie preferences


Search [Alt+S]
United States (N. Virginia)
ShariniAWS (832348493275)
cha-architect
Amazon S3 > Buckets > cha-app-storage-sn
User-defined tags AWS-generated tags
User-defined tags (0) Info
Delete Add new tag
Key
Value - optional
There are no user-defined tags associated with this bucket.
Add new tag
Default encryption
Edit
Server-side encryption is automatically applied to new objects stored in this bucket.
Encryption type Info
Server-side encryption with AWS Key Management Service keys (SSE-KMS)
Encryption key ARN
arn:aws:kms:us-east-1:832348493275:key/ce05200a-211d-4833-9113-bb7937f9fd1b
Bucket Key
When KMS encryption is used to encrypt new objects in this bucket, the bucket key reduces encryption costs by lowering calls to AWS KMS. Learn more
Enabled
Blocked encryption types Info
Server-Side Encryption with Customer-Provided Keys (SSE-C)
Intelligent-Tiering Archive configurations (0)
View details Edit Delete Create configuration
CloudShell Agent Toolkit for AWS Feedback Console Mobile App
© 2026, Amazon Web Services, Inc. or its affiliates. Privacy Terms Cookie preferences


Search [Alt+S]
United States (N. Virginia)
ShariniAWS (832348493275)
cha-architect
Amazon S3 > Buckets > cha-backups-sn
cha-backups-sn Info
Objects Metadata Properties Permissions Metrics Management File systems Access Points
Bucket overview
AWS Region
US East (N. Virginia) us-east-1
Amazon Resource Name (ARN)
arn:aws:s3:::cha-backups-sn
Creation date
October 1, 2026, 08:46:41 (UTC+05:30)
Bucket Versioning
Edit
Versioning is a means of keeping multiple variants of an object in the same bucket. You can use versioning to preserve, retrieve, and restore every version of every object stored in your Amazon S3 bucket. With versioning, you can easily recover from both unintended user actions and application failures. Learn more
Bucket Versioning
Enabled
Multi-factor authentication (MFA) delete
An additional layer of security that requires multi-factor authentication for changing Bucket Versioning settings and permanently deleting object versions. To modify MFA delete settings, use the AWS CLI, AWS SDK, or the Amazon S3 REST API. Learn more
Disabled
Bucket ABAC
Edit
Attribute-based access control (ABAC) is an authorization strategy that defines permissions based on attributes. With ABAC, you can attach tags to your general purpose buckets and AWS Identity and Access Management (IAM) entities (users or roles), then scale access to objects in your S3 general purpose buckets using tag-based policies. Learn more
ABAC status
Disabled
Tags
CloudShell Agent Toolkit for AWS Feedback Console Mobile App
© 2026, Amazon Web Services, Inc. or its affiliates. Privacy Terms Cookie preferences

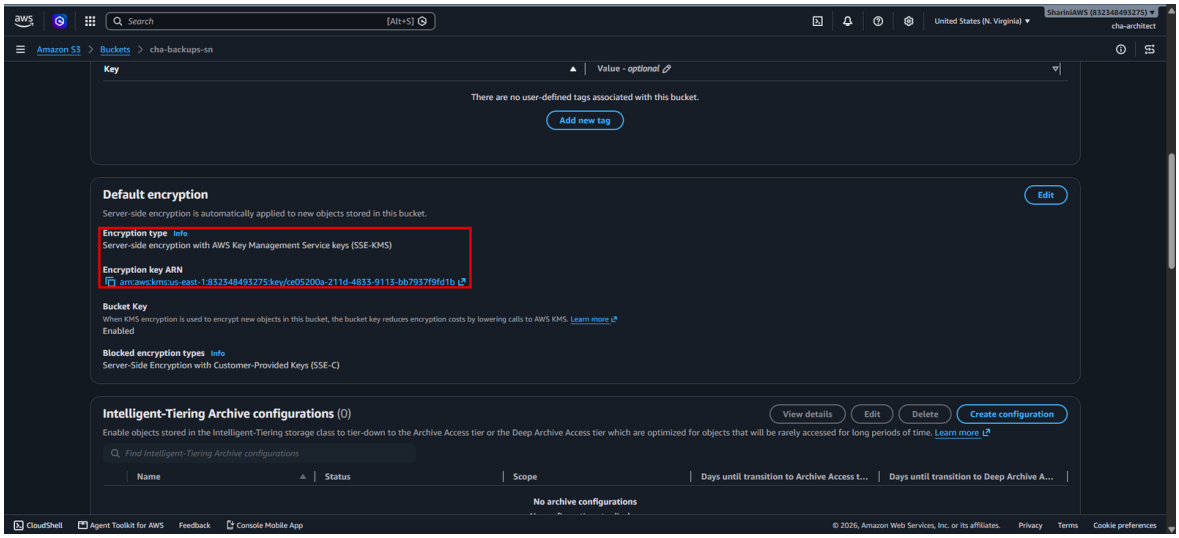


Figure D5: S3 buckets cha-app-storage and cha-backups

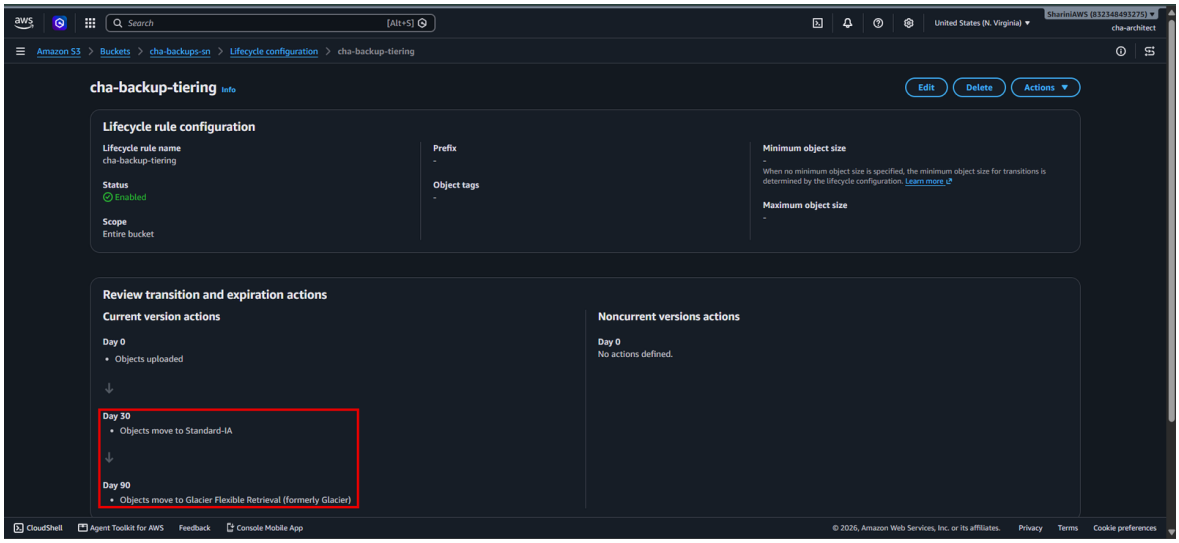


Figure D6: Lifecycle rule cha-backup-tiering

Appendix E: Content delivery and messaging

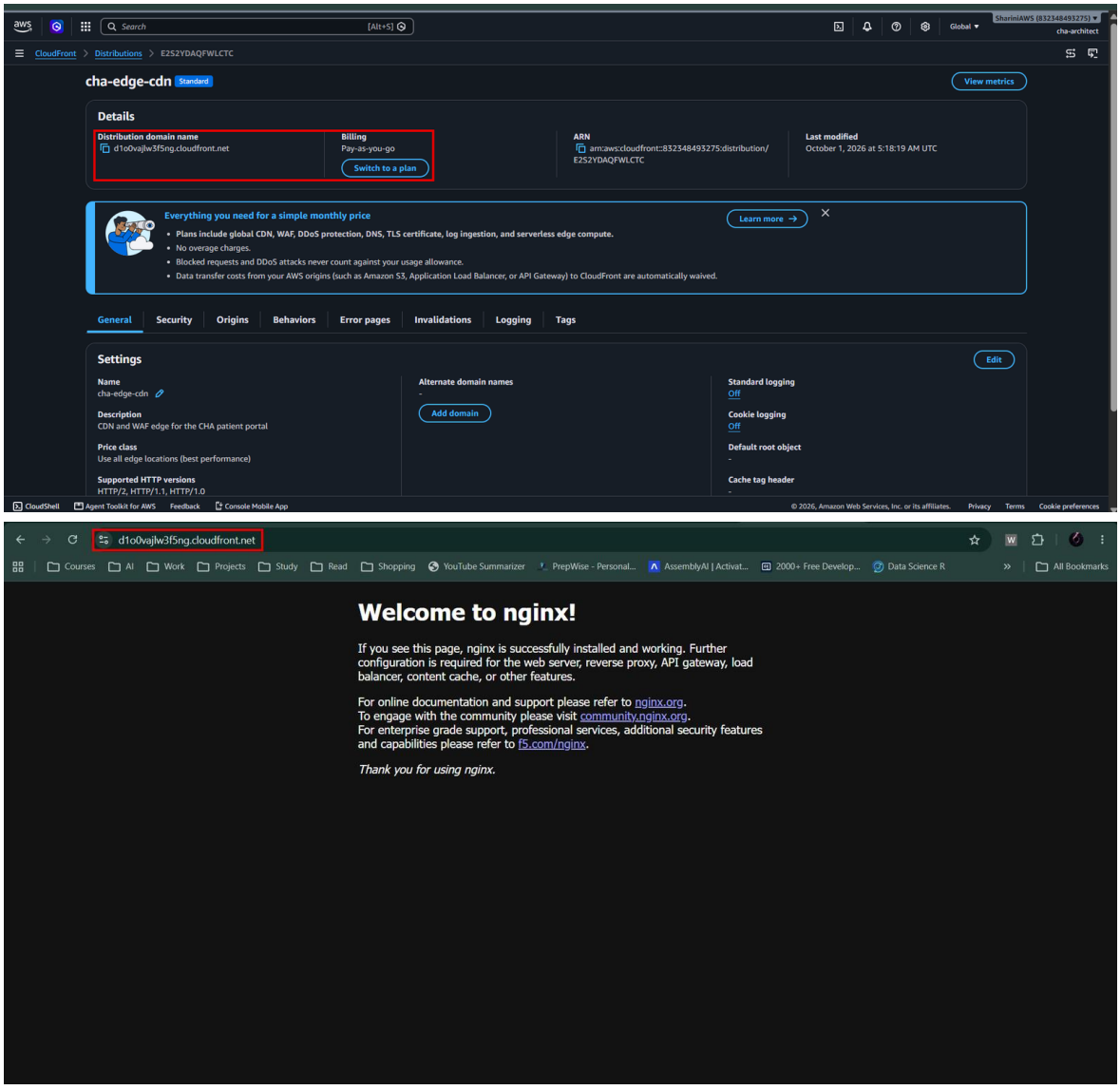


Figure E1: CloudFront distribution with status Deployed

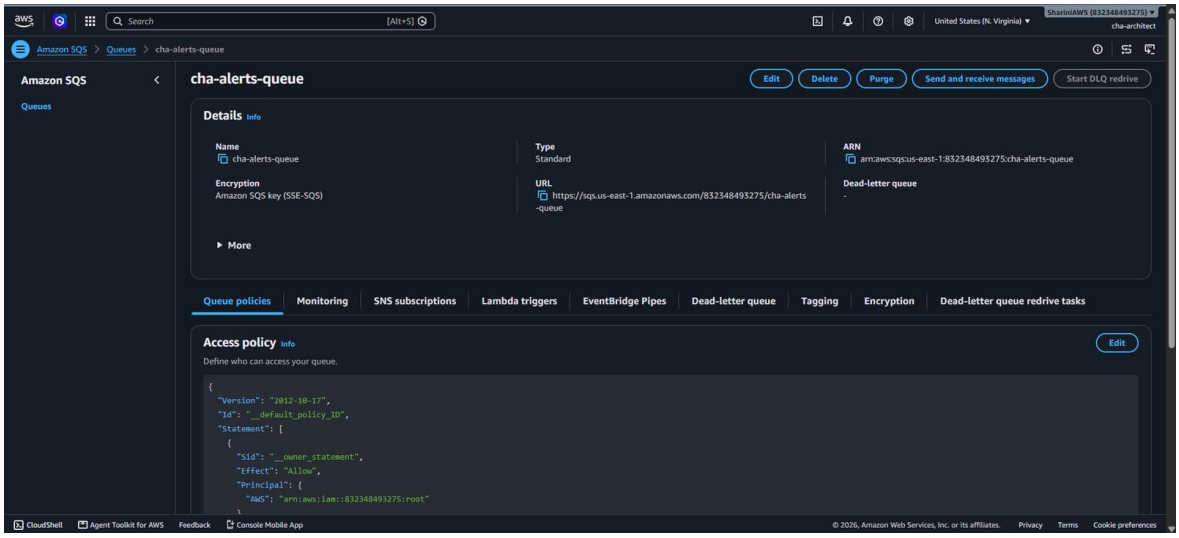


Figure E2: SQS queue cha-alerts-queue

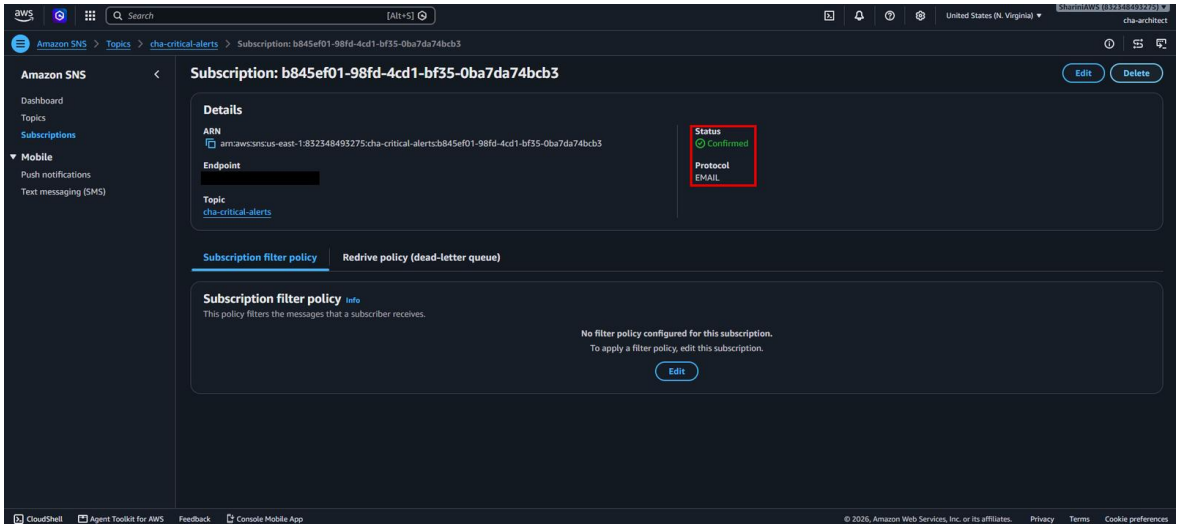


Figure E3: SNS topic cha-critical-alerts with a confirmed subscription

Appendix F: Monitoring

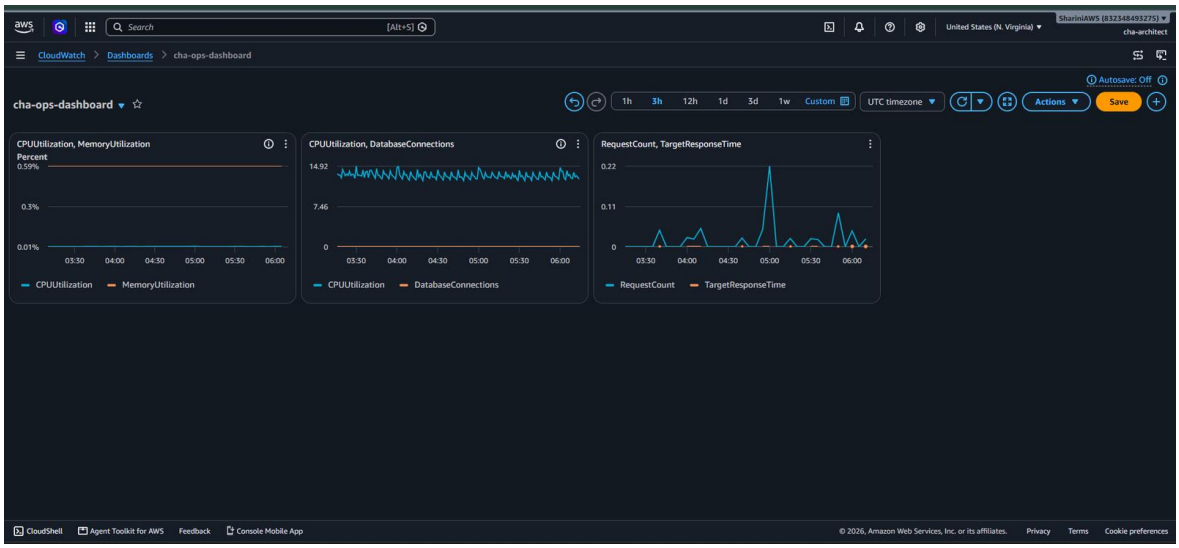


Figure F1: CloudWatch dashboard cha-ops-dashboard

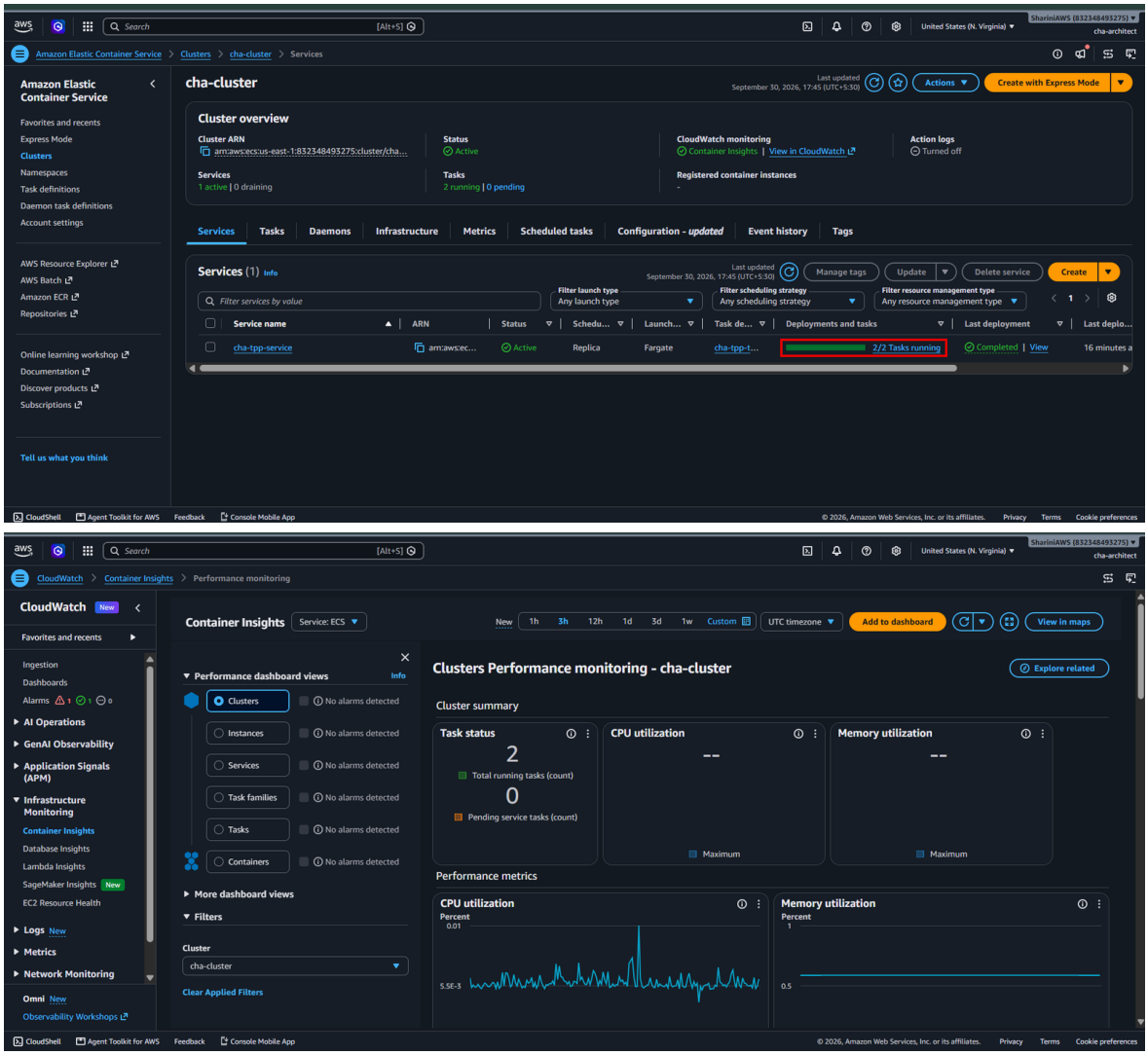


Figure F2: Container Insights for cha-cluster

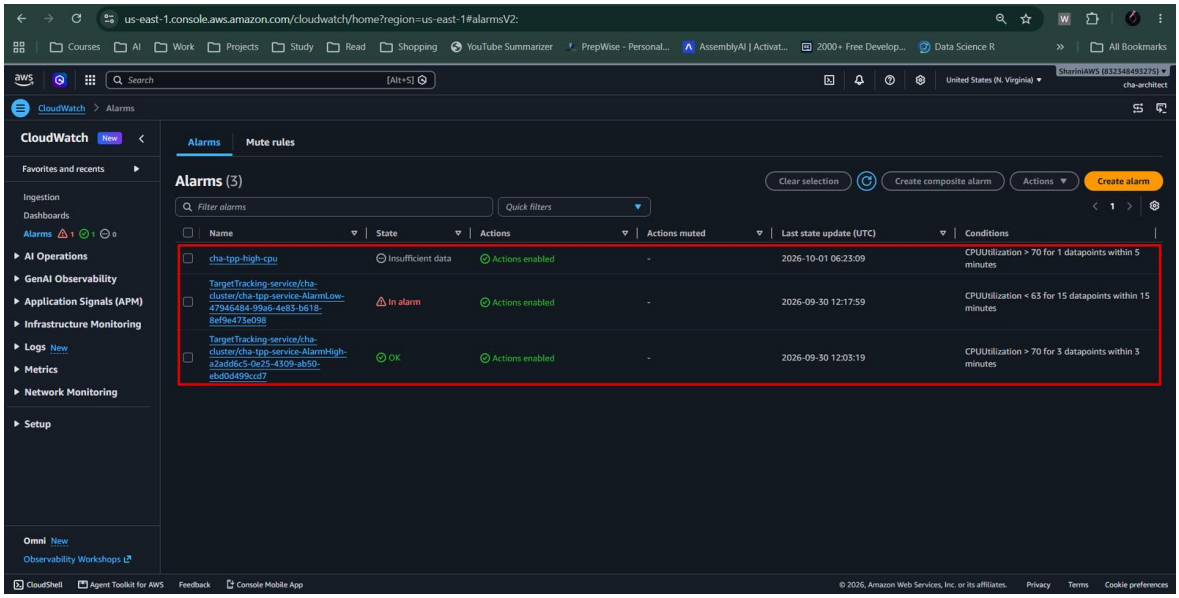


Figure F3: CloudWatch alarm cha-tpp-high-cpu with an SNS action

Appendix G: Security and governance

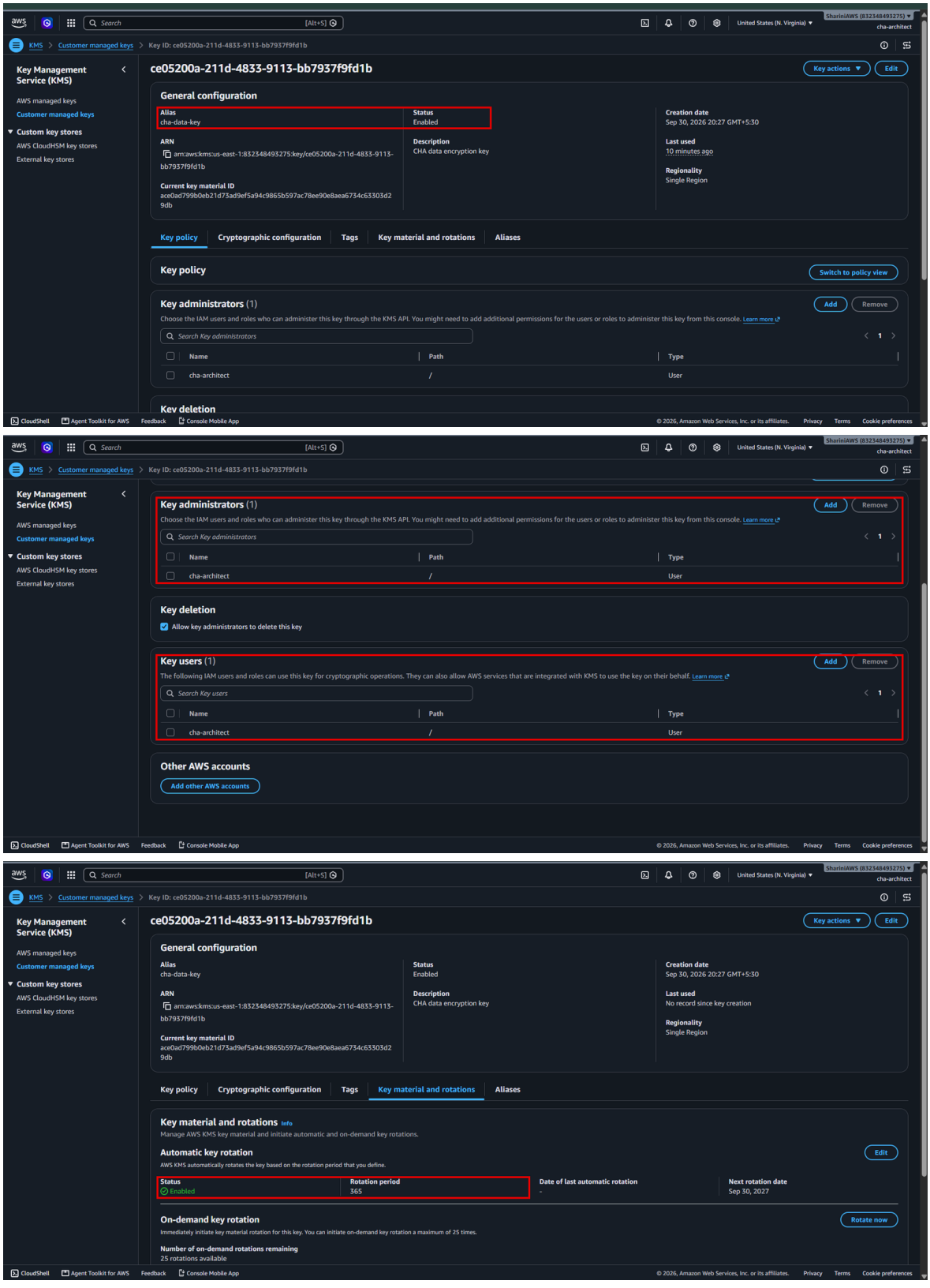


Figure G1: Customer-managed KMS key cha-data-key

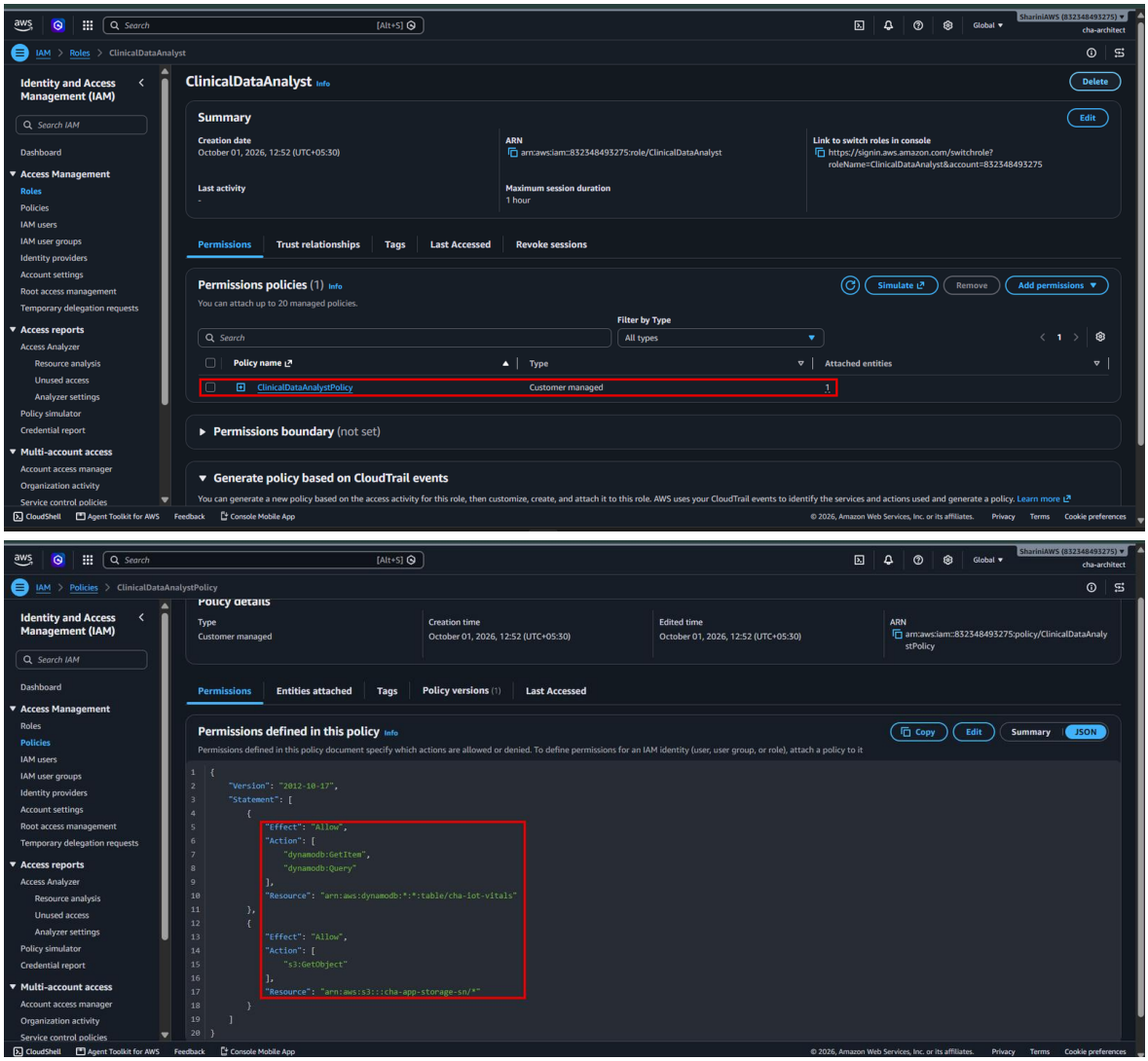


Figure G2: ClinicalDataAnalyst role and policy

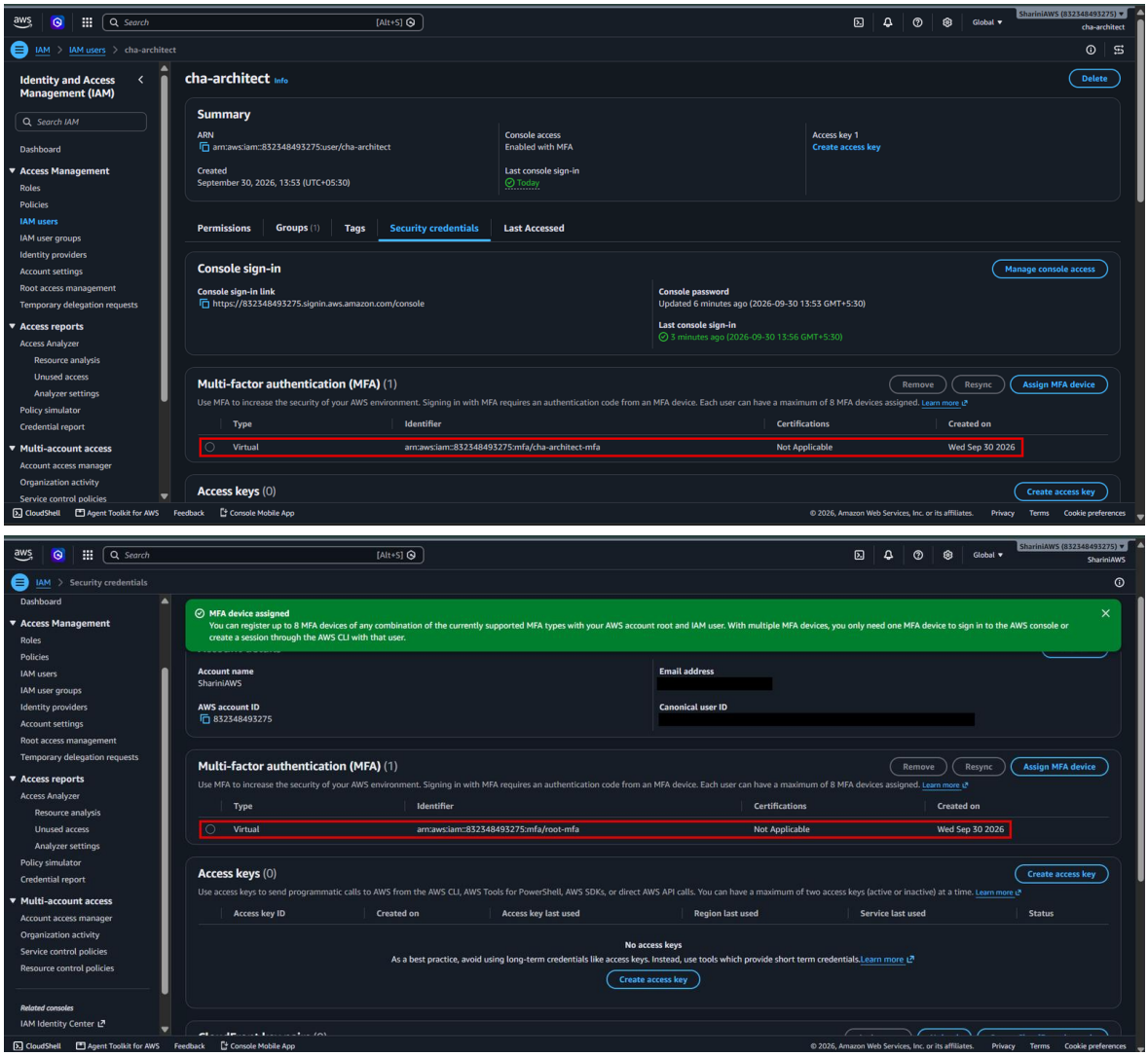


Figure G3: MFA assigned to the PoC IAM user and to the root user

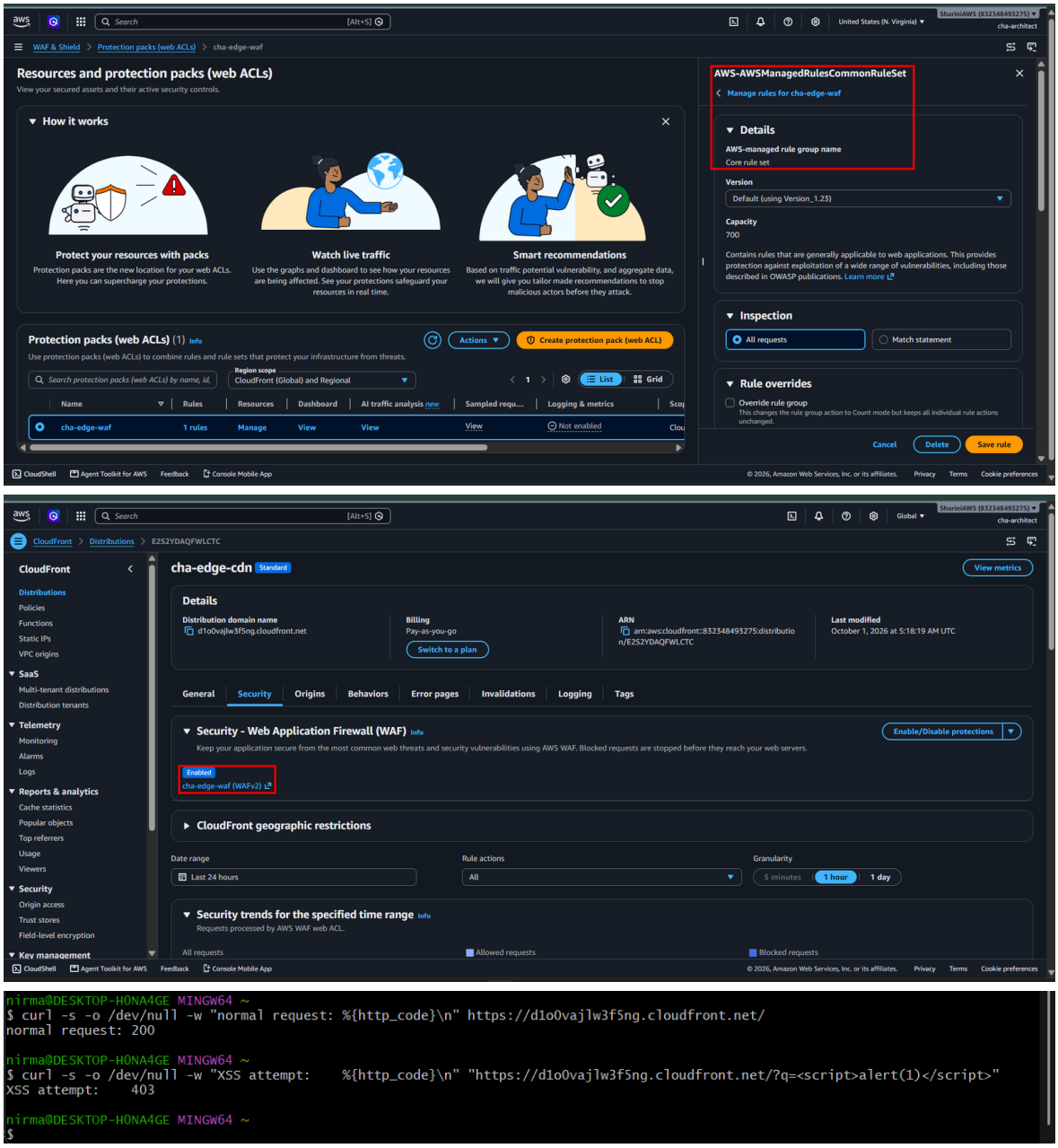


Figure G4: AWS WAF web ACL with the Common Rule Set, attached to CloudFront and blocking a test XSS request

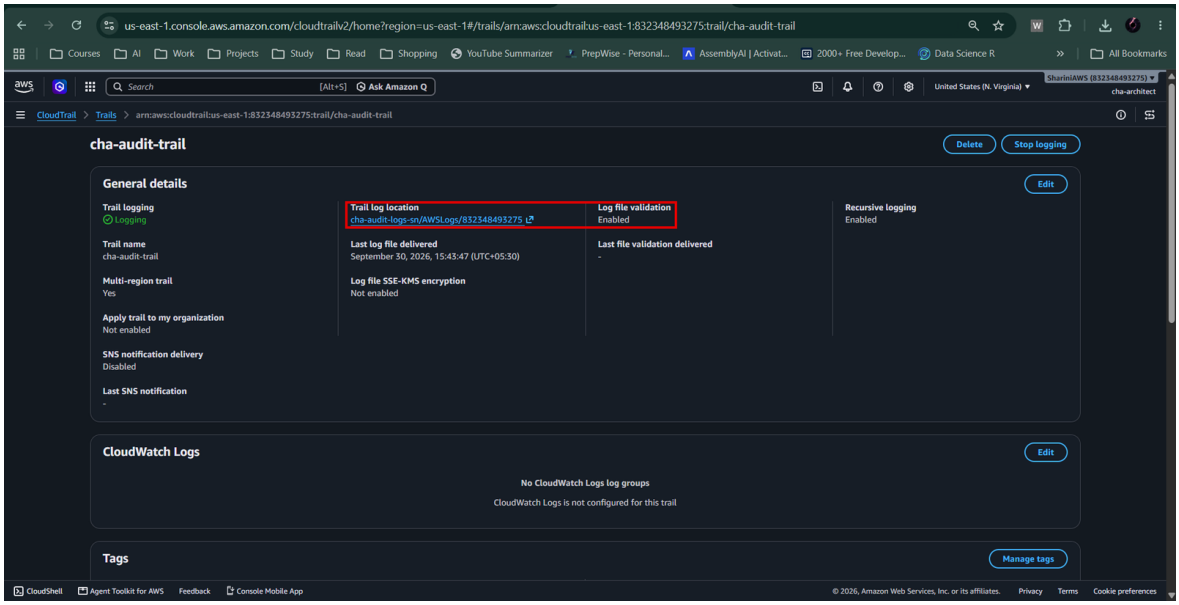


Figure G5: CloudTrail trail cha-audit-trail

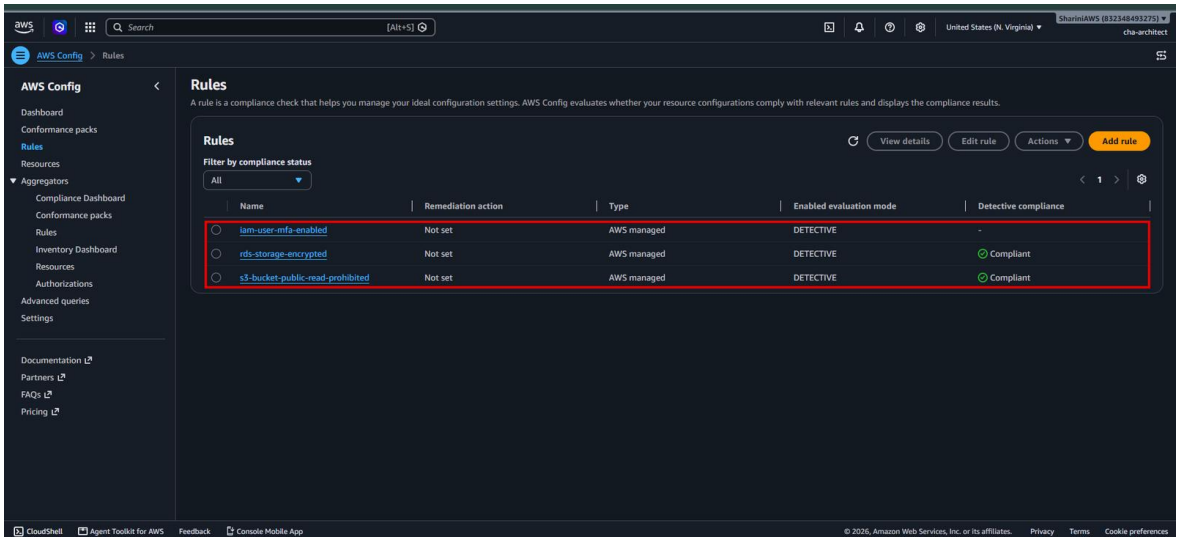


Figure G6: AWS Config recorder and rules

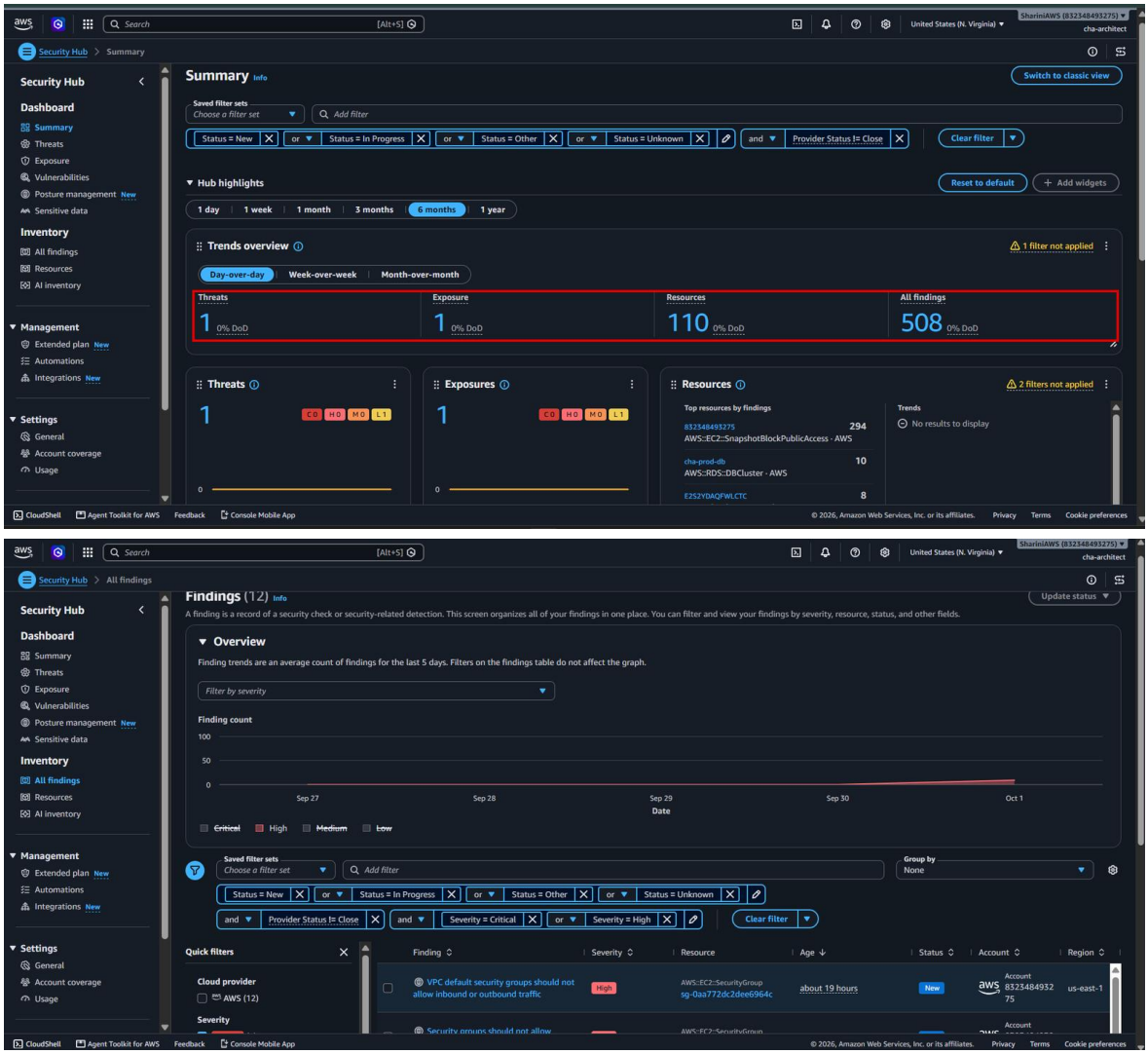


Figure G7: Security Hub summary

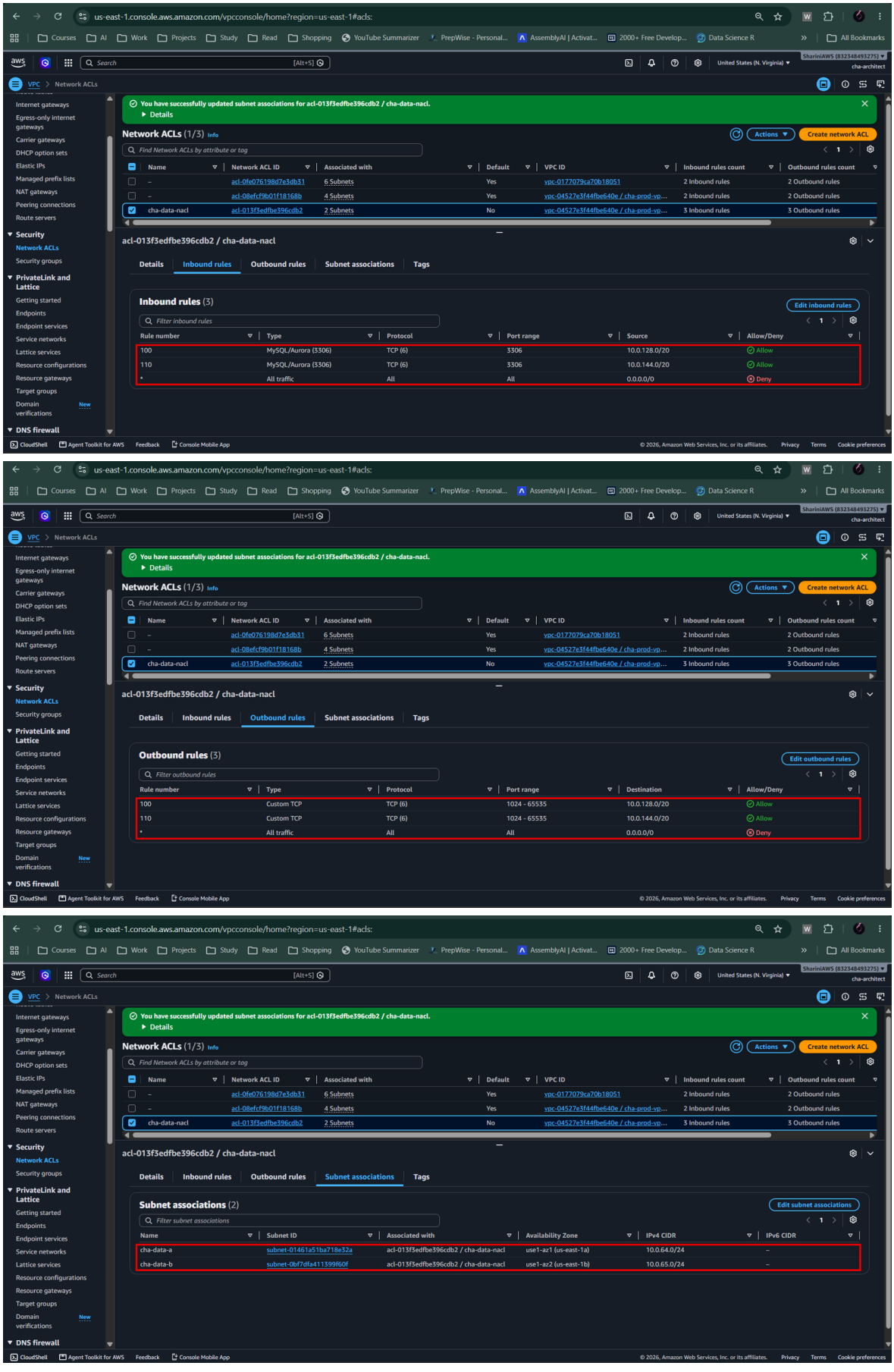


Figure G8: Network ACL for the data subnets

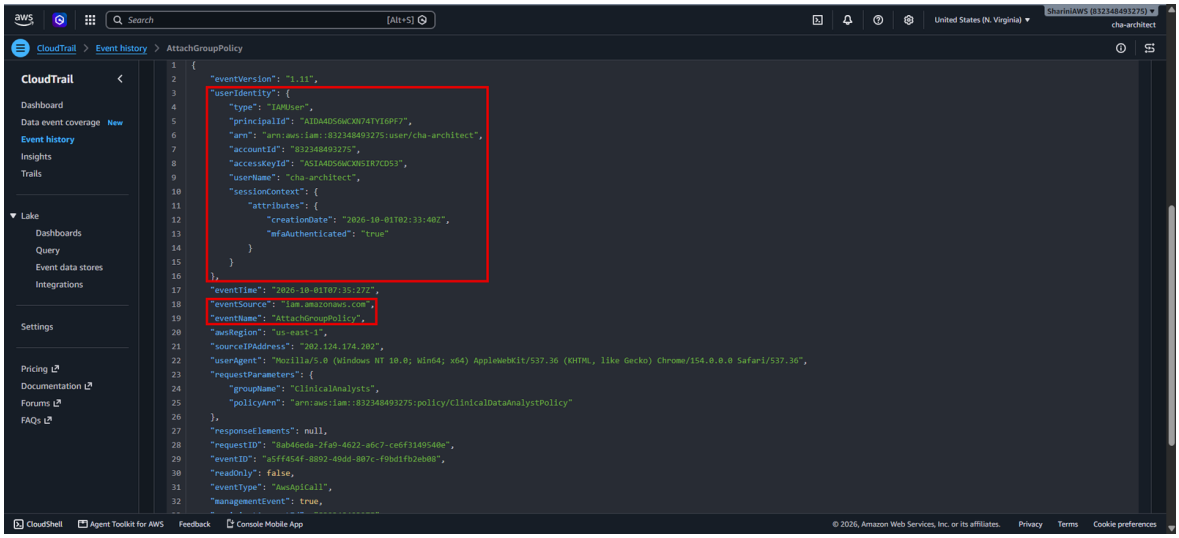


Figure G9: Sample CloudTrail event

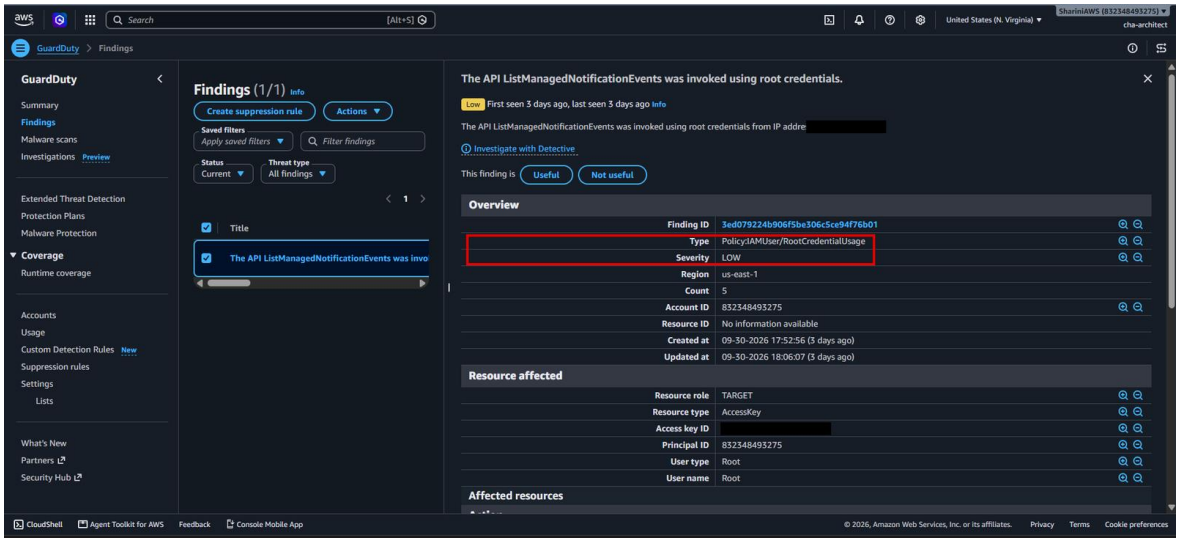


Figure G10: GuardDuty finding for root credential use

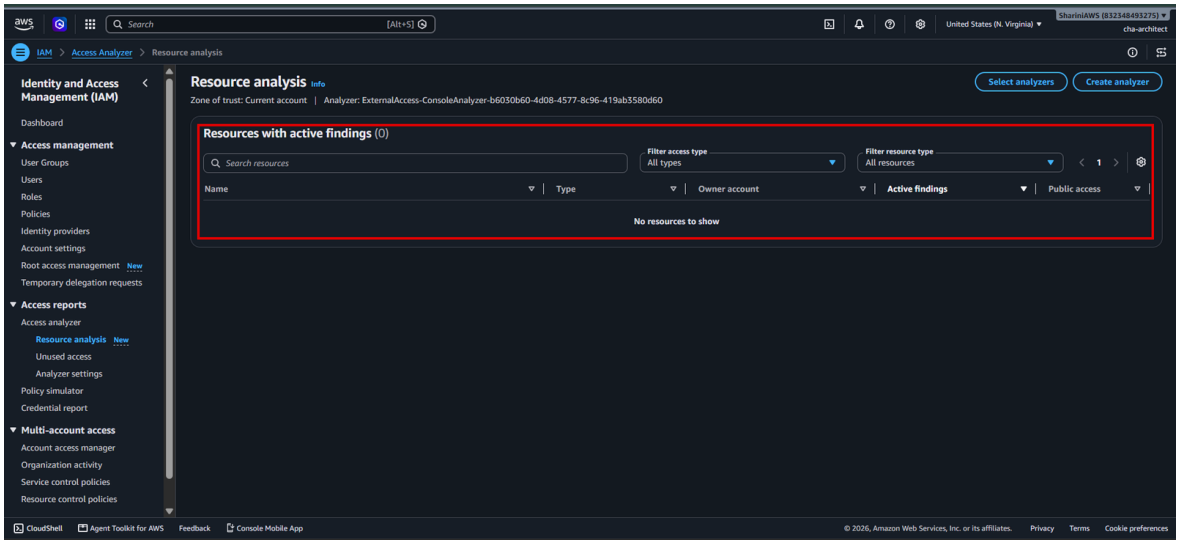


Figure G11: IAM Access Analyzer findings (none external)

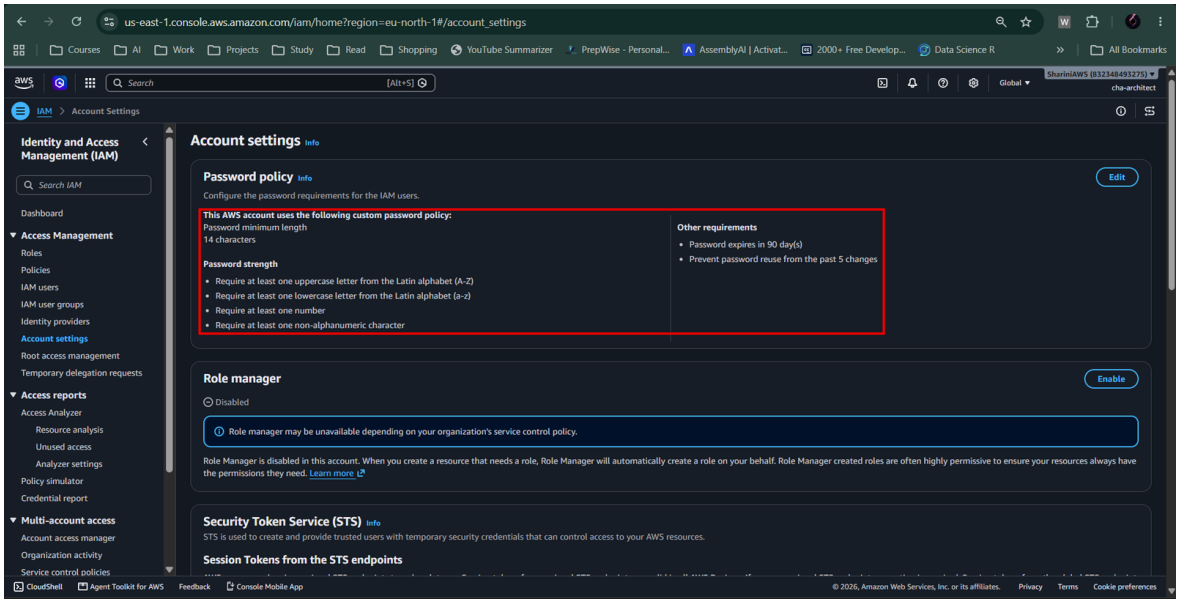


Figure G12: Account password policy

Appendix H: Cost estimation evidence

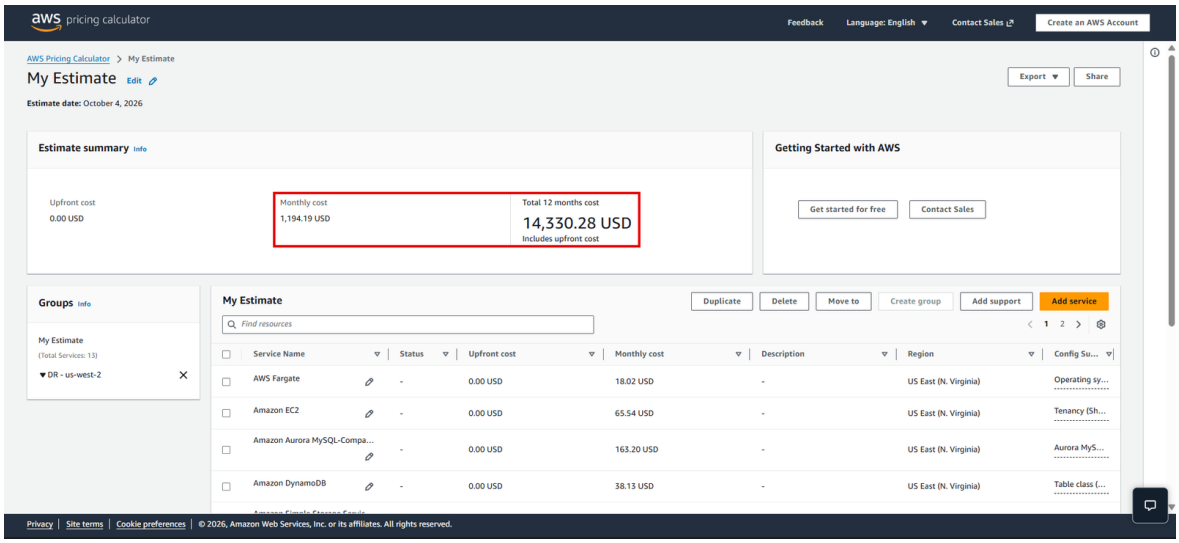


Figure H1: AWS Pricing Calculator estimate summary

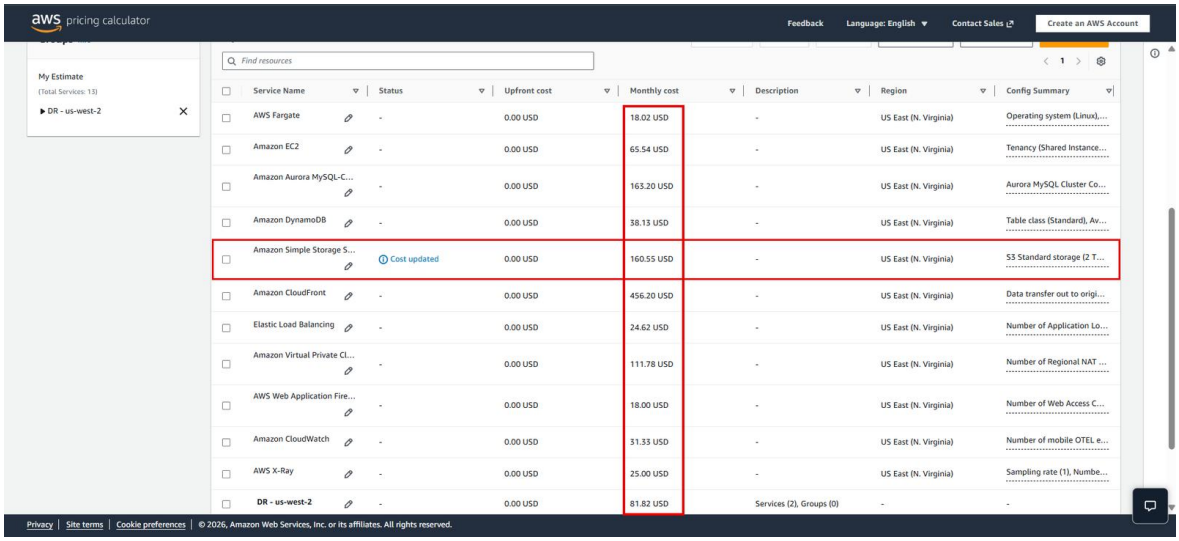
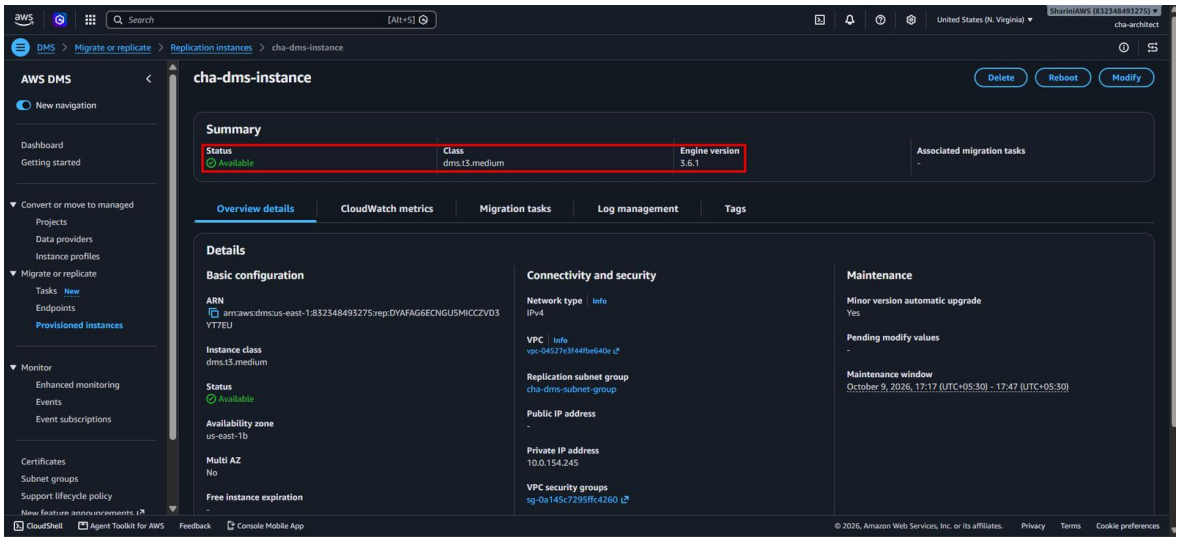
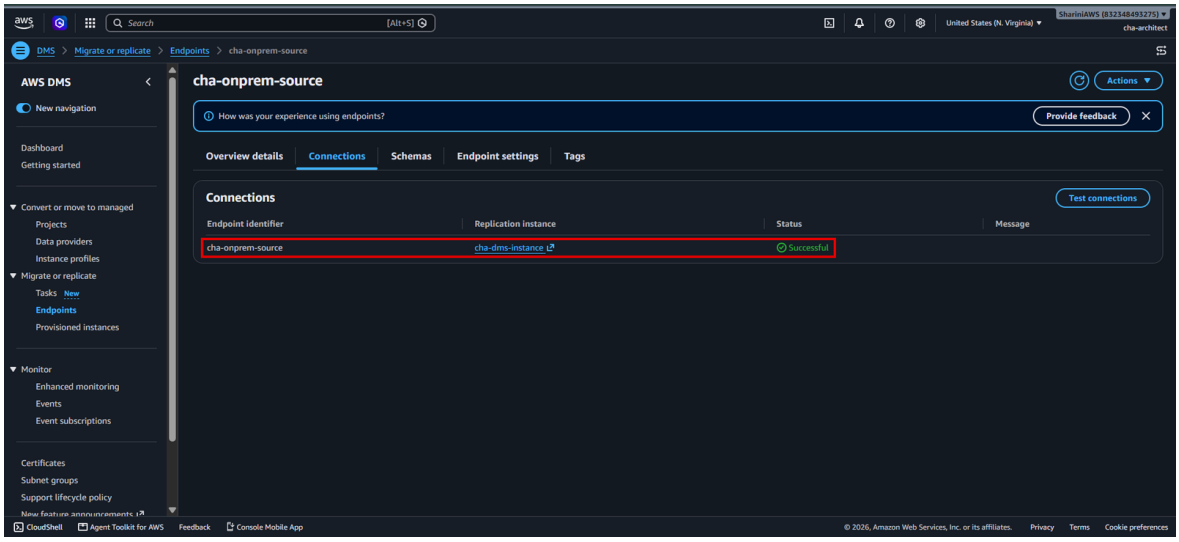
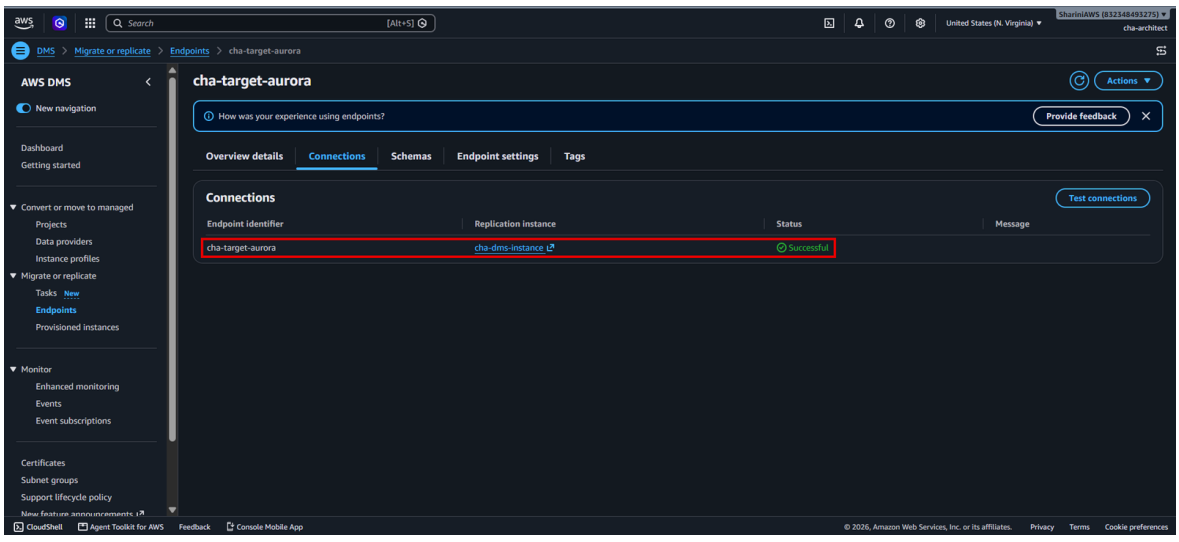


Figure H2: Estimate breakdown by service, including the us-west-2 standby group

Appendix I: Migration and continuity evidence







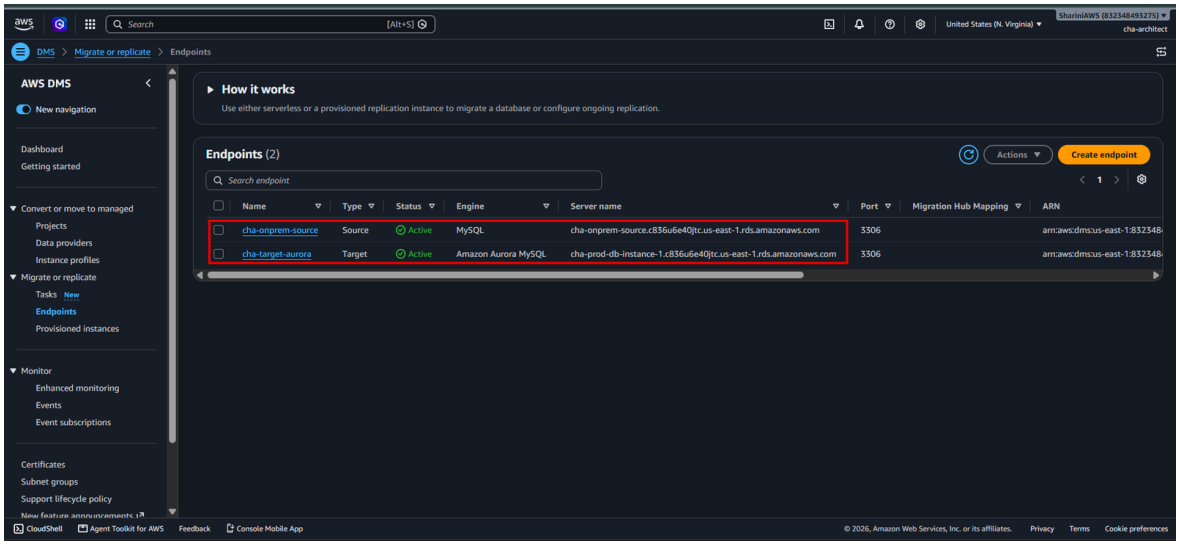
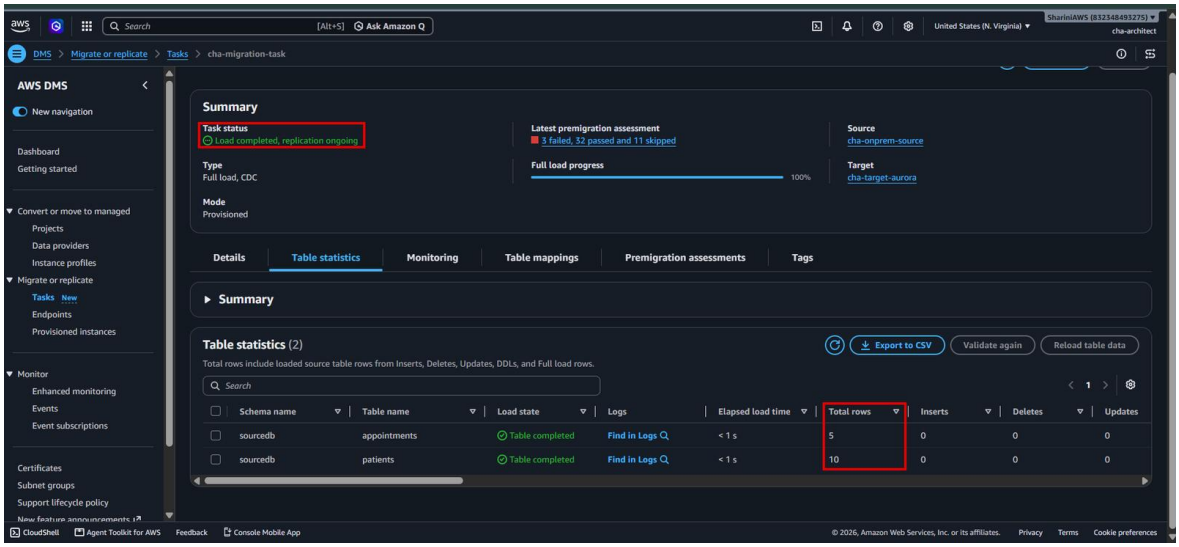
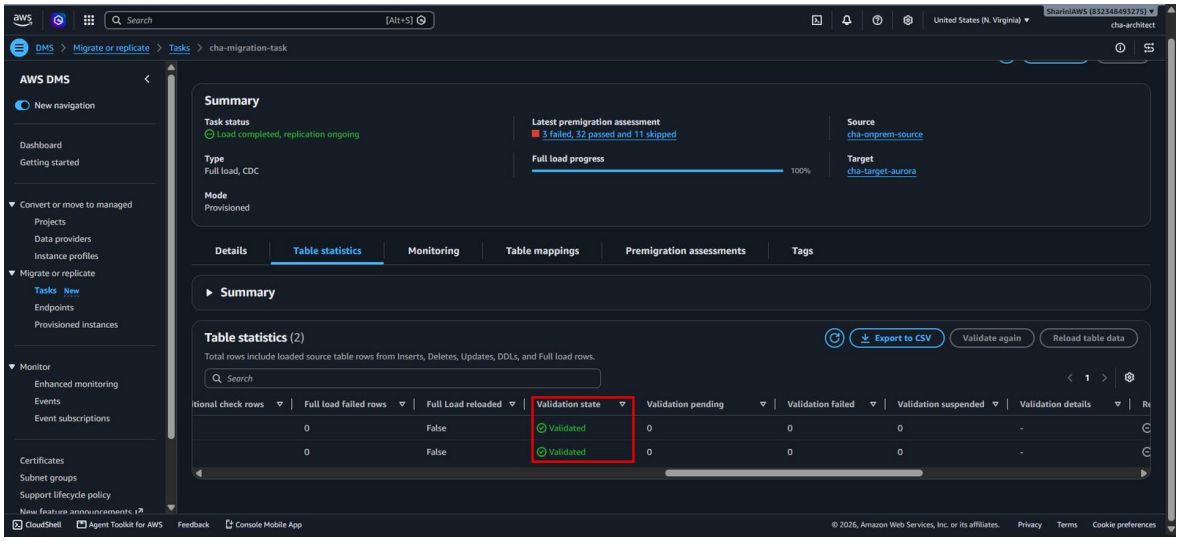


Figure I1: DMS replication instance and endpoints





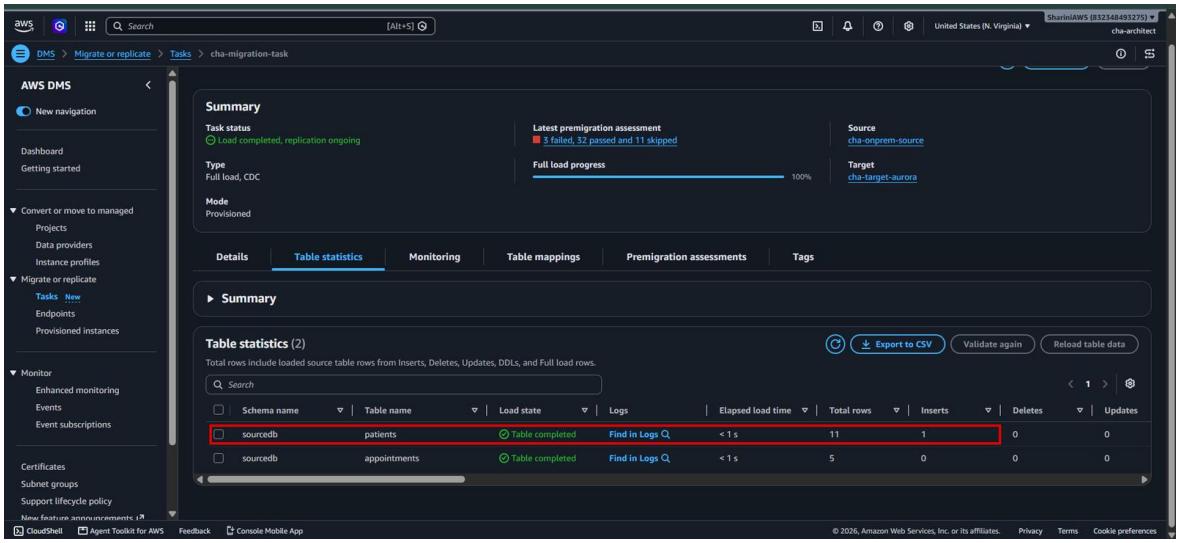


Figure I2: DMS task complete: full load, validation and one CDC insert

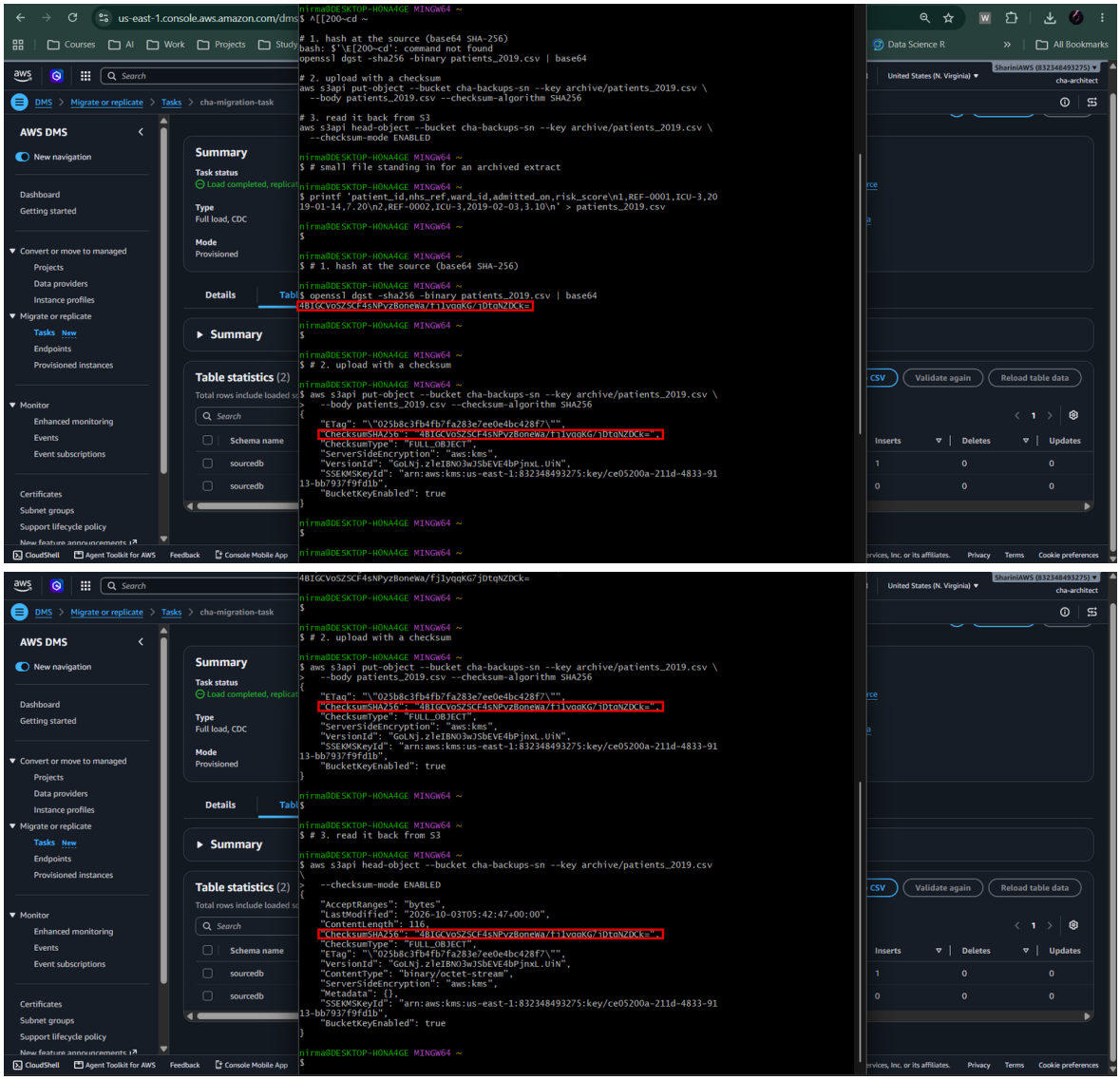


Figure I3: Checksum comparison for an archived file

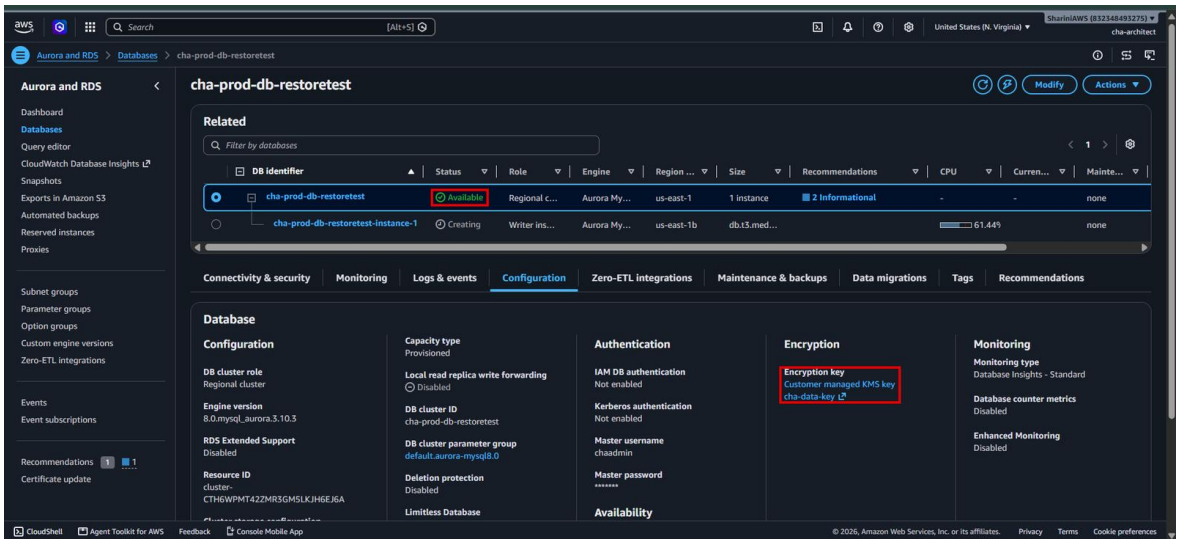


Figure I4: Restore test: cha-prod-db-restoretest built from a snapshot, encrypted with cha-data-key

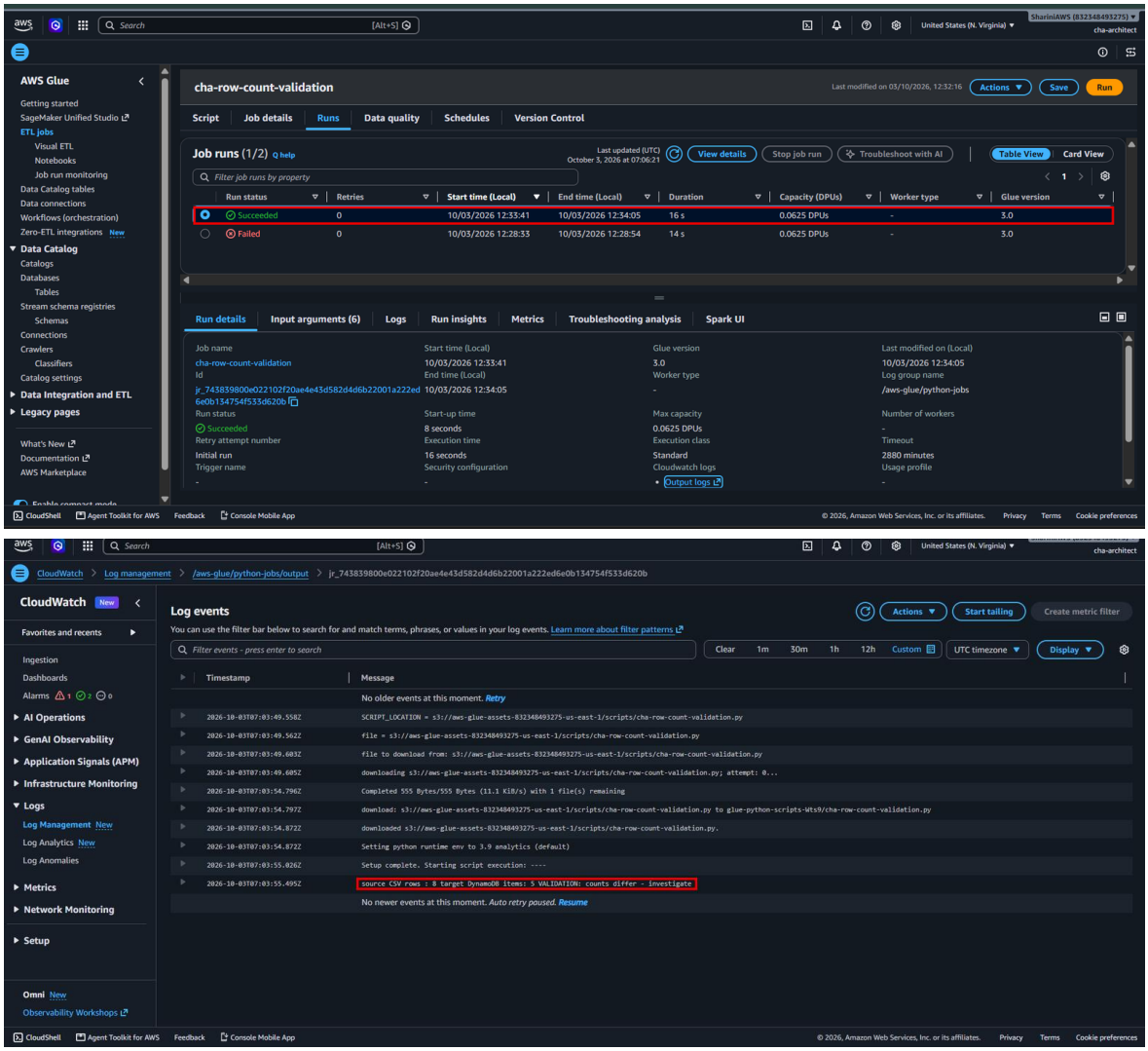


Figure I5: AWS Glue validation job run and its output log

Appendix J: Hybrid connectivity and edge evidence

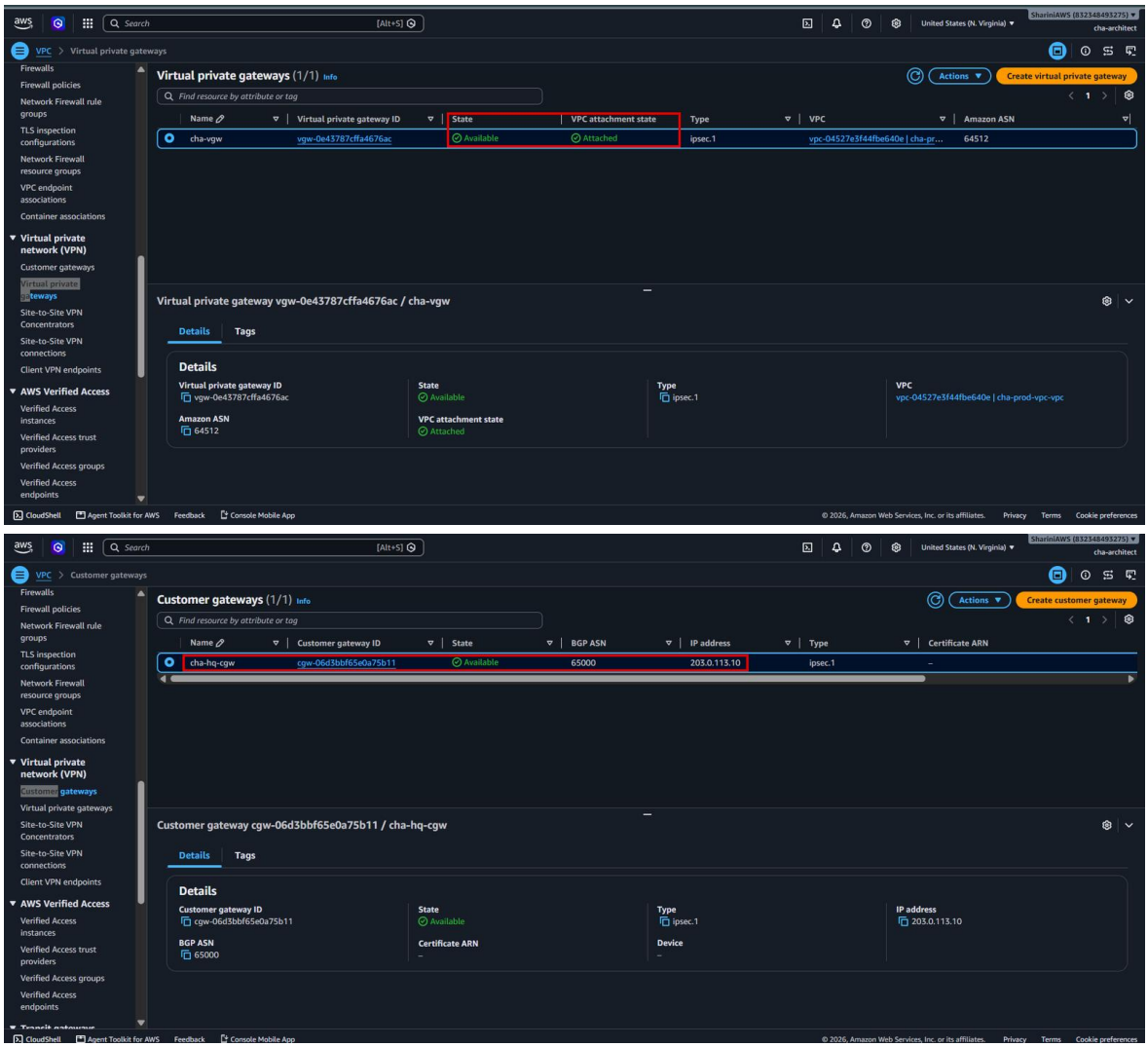


Figure J1: Customer gateway and virtual private gateway

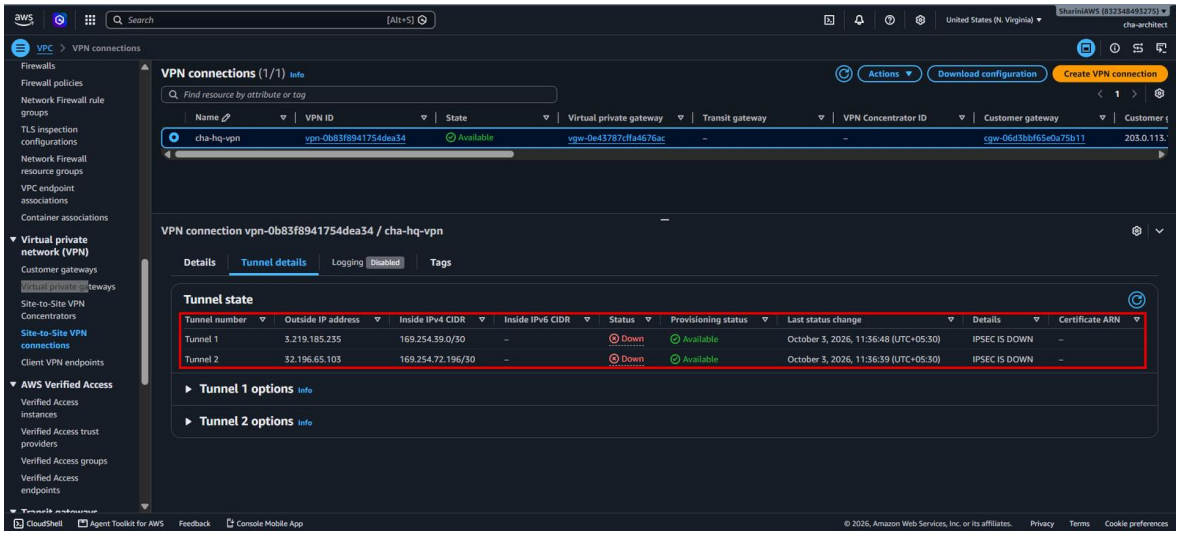


Figure J2: Site-to-Site VPN connection

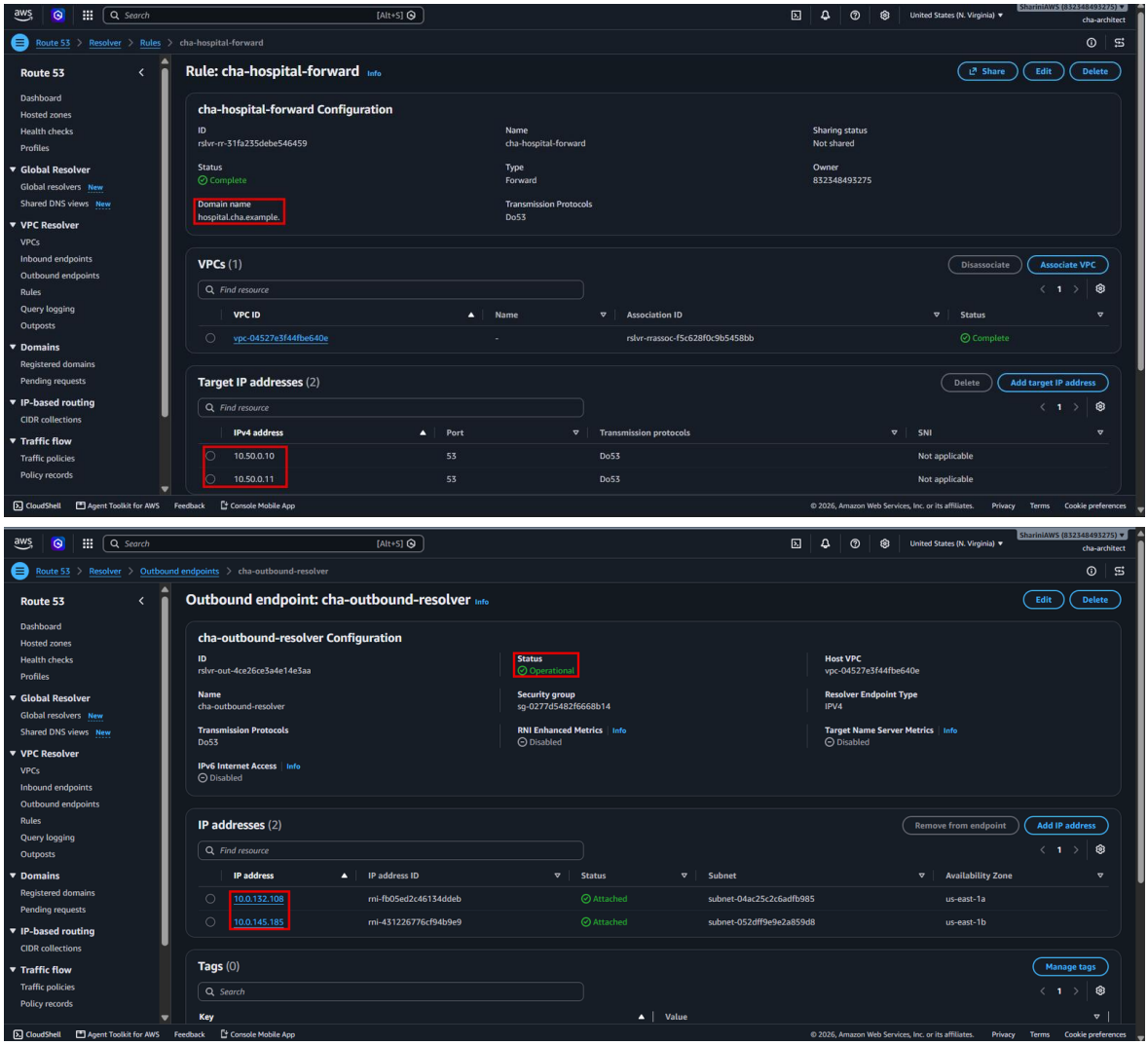


Figure J3: Route 53 Resolver forwarding rule and outbound endpoint

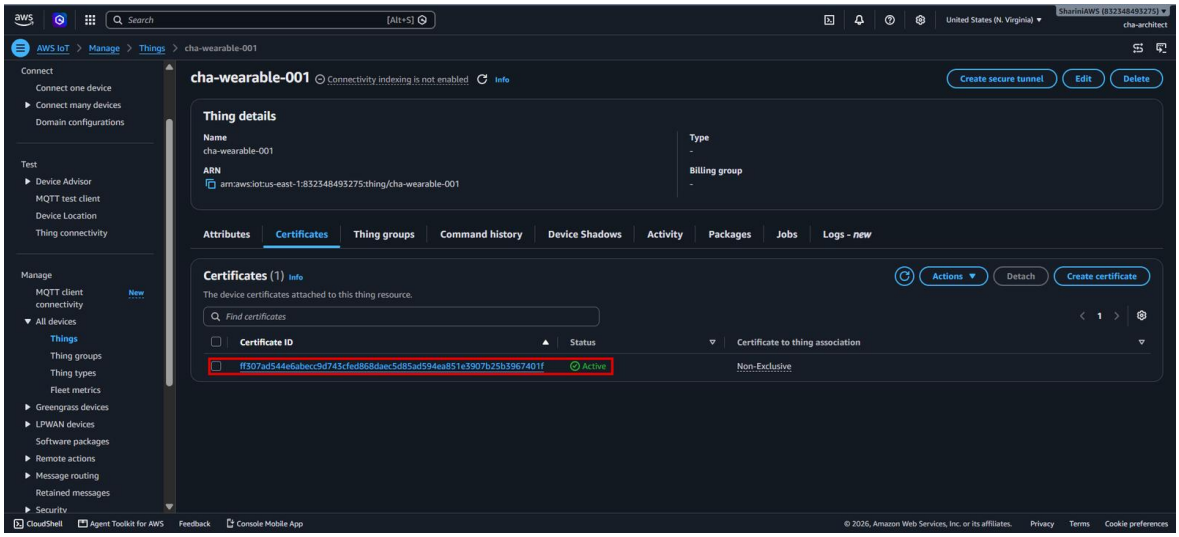


Figure J4: IoT Core thing and certificate

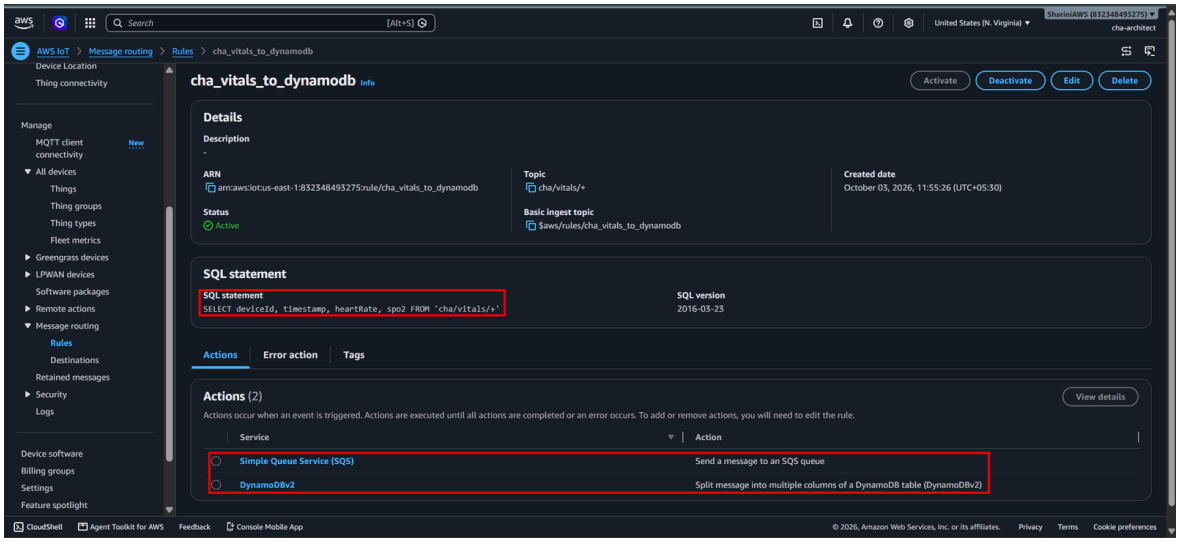


Figure J5: IoT Core rule

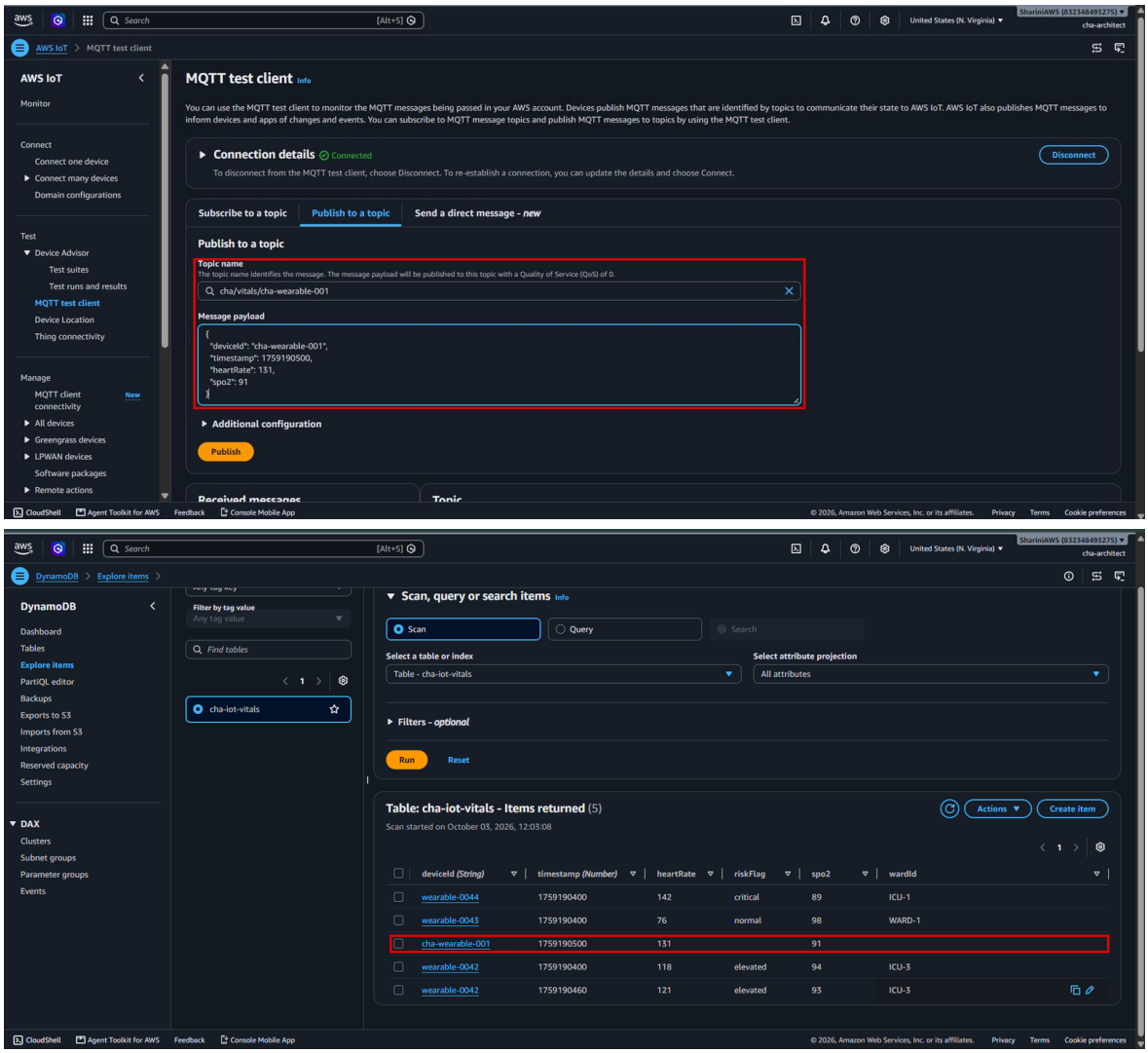


Figure J6: Test message and resulting item

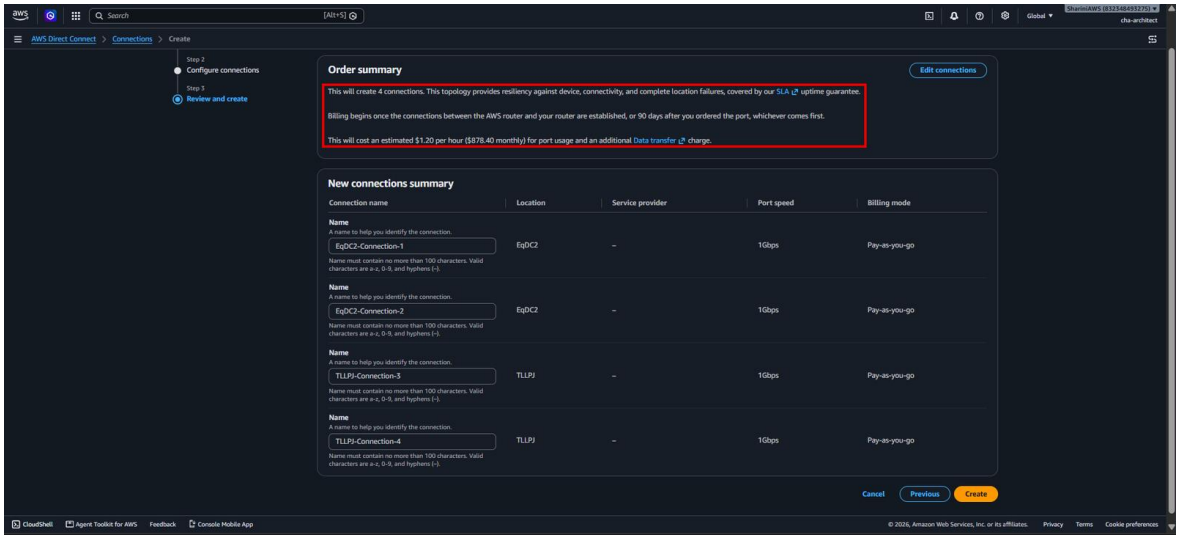


Figure J7: Direct Connect order summary for a maximum-resiliency design (not submitted)

Appendix K: Infrastructure as Code

Listing K1 is the fuller Terraform for the network and data-tier foundations. Compute, Aurora and the load balancer follow the same pattern and are omitted to keep the listing short. The "-tf" suffix on named resources avoids clashing with the console-built PoC, since names such as the DB subnet group, KMS alias and DynamoDB table must be unique in the account and Region.

```
terraform {
  required_providers {
    aws = {
      source  = "hashicorp/aws"
      version = ">= 5.0"
    }
  }
}

variable "region" {
  type    = string
  default = "us-east-1"
}

provider "aws" {
  region = var.region
}

# Network
resource "aws_vpc" "cha_vpc" {
  cidr_block           = "10.0.0.0/16"
  enable_dns_support   = true
  enable_dns_hostnames = true
  tags = { Name = "cha-prod-vpc-tf" }
}

resource "aws_subnet" "cha_data_a" {
  vpc_id            = aws_vpc.cha_vpc.id
  cidr_block        = "10.0.64.0/24"
  availability_zone = "${var.region}a"
  tags = { Name = "cha-data-a-tf" }
}

resource "aws_subnet" "cha_data_b" {
  vpc_id            = aws_vpc.cha_vpc.id
  cidr_block        = "10.0.65.0/24"
  availability_zone = "${var.region}b"
  tags = { Name = "cha-data-b-tf" }
```

```
}

# Security groups (each admits traffic only from the tier before it)
resource "aws_security_group" "alb_sg" {
  name        = "alb-sg-tf"
  description = "Allows inbound web traffic to the ALB"
  vpc_id      = aws_vpc.cha_vpc.id

  ingress {
    from_port   = 80
    to_port     = 80
    protocol    = "tcp"
    cidr_blocks = ["0.0.0.0/0"]
  }
  ingress {
    from_port   = 443
    to_port     = 443
    protocol    = "tcp"
    cidr_blocks = ["0.0.0.0/0"]
  }
  egress {
    from_port   = 0
    to_port     = 0
    protocol    = "-1"
    cidr_blocks = ["0.0.0.0/0"]
  }
}

resource "aws_security_group" "app_sg" {
  name        = "app-sg-tf"
  description = "Allows inbound app traffic from the ALB only"
  vpc_id      = aws_vpc.cha_vpc.id

  ingress {
    from_port       = 8080
    to_port         = 8080
    protocol        = "tcp"
    security_groups = [aws_security_group.alb_sg.id]
  }
  egress {
    from_port   = 0
    to_port     = 0
    protocol    = "-1"
    cidr_blocks = ["0.0.0.0/0"]
  }
}

resource "aws_security_group" "db_sg" {
  name        = "db-sg-tf"
  description = "Allows inbound database traffic from the app tier only"
  vpc_id      = aws_vpc.cha_vpc.id

  ingress {
    from_port       = 3306
    to_port         = 3306
    protocol        = "tcp"
    security_groups = [aws_security_group.app_sg.id]
  }
  egress {
    from_port   = 0
    to_port     = 0
    protocol    = "-1"
    cidr_blocks = ["0.0.0.0/0"]
  }
}

# Data tier
resource "aws_db_subnet_group" "cha" {
  name       = "cha-data-subnet-group-tf"
  subnet_ids = [aws_subnet.cha_data_a.id, aws_subnet.cha_data_b.id]
}
```

```
resource "aws_kms_key" "cha_data_key" {
  description         = "CHA data encryption key"
  enable  key  rotation = true
}

resource "aws_kms_alias" "cha_data_key" {
  name          = "alias/cha-data-key-tf"
  target_key_id = aws_kms_key.cha_data_key.key_id
}

resource "aws_dynamodb_table" "iot_vitals" {
  name         = "cha-iot-vitals-tf"
  billing_mode = "PAY_PER_REQUEST"
  hash  key     = "deviceId"
  range_key    = "timestamp"

  attribute {
    name = "deviceId"
    type = "S"
  }
  attribute {
    name = "timestamp"
    type = "N"
  }

  server_side_encryption {
    enabled     = true
    kms_key_arn = aws_kms_key.cha_data_key.arn
  }
}
```

Listing K1: Terraform for the network and data-tier foundations

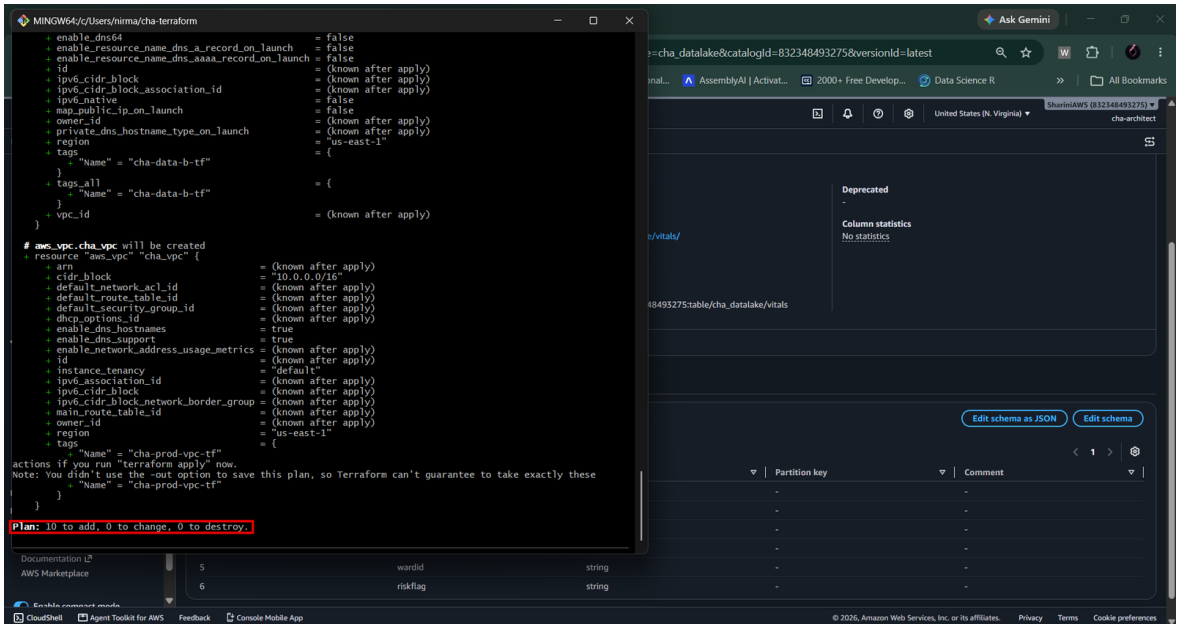


Figure K2: terraform plan output

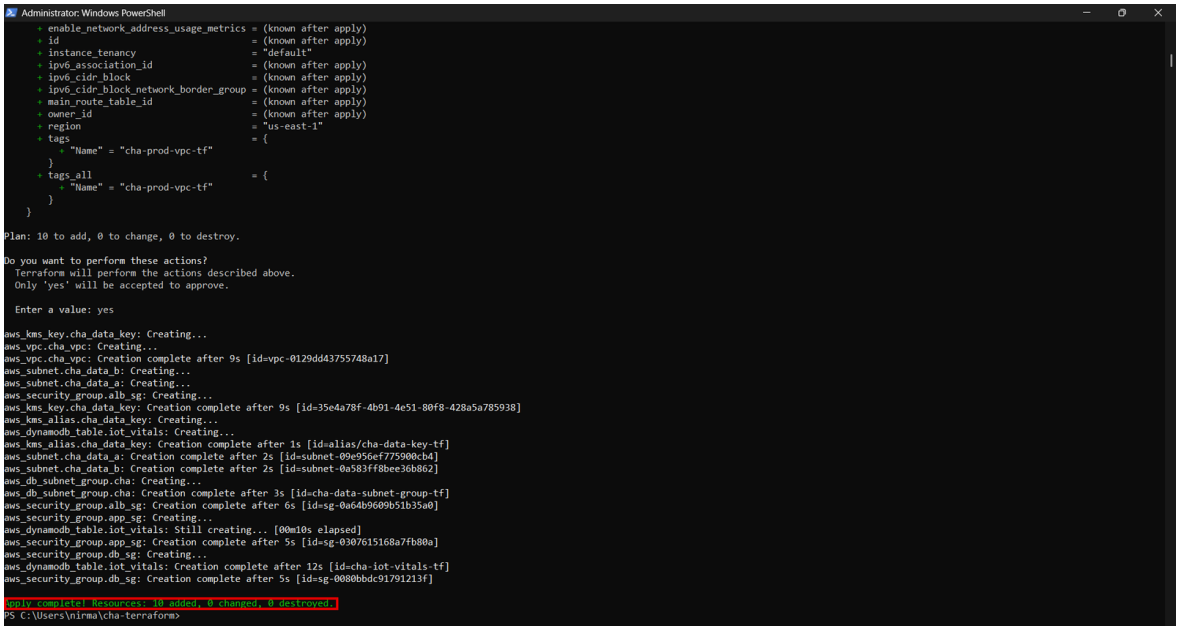


Figure K3: terraform apply output

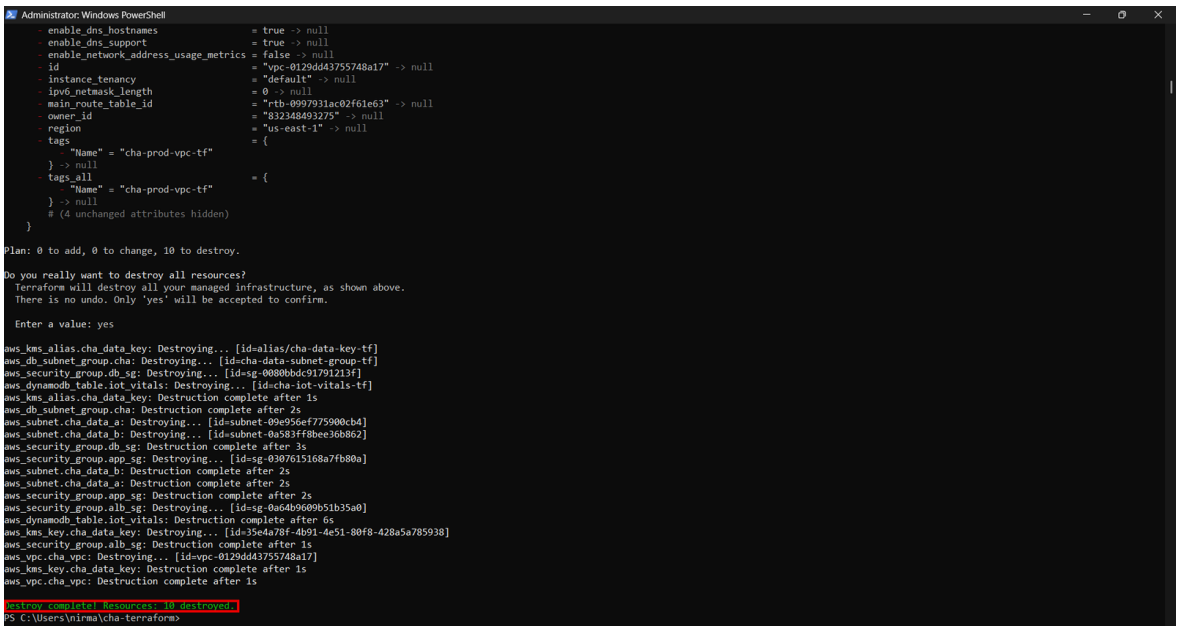


Figure K4: terraform destroy output

Appendix L: Analytics evidence

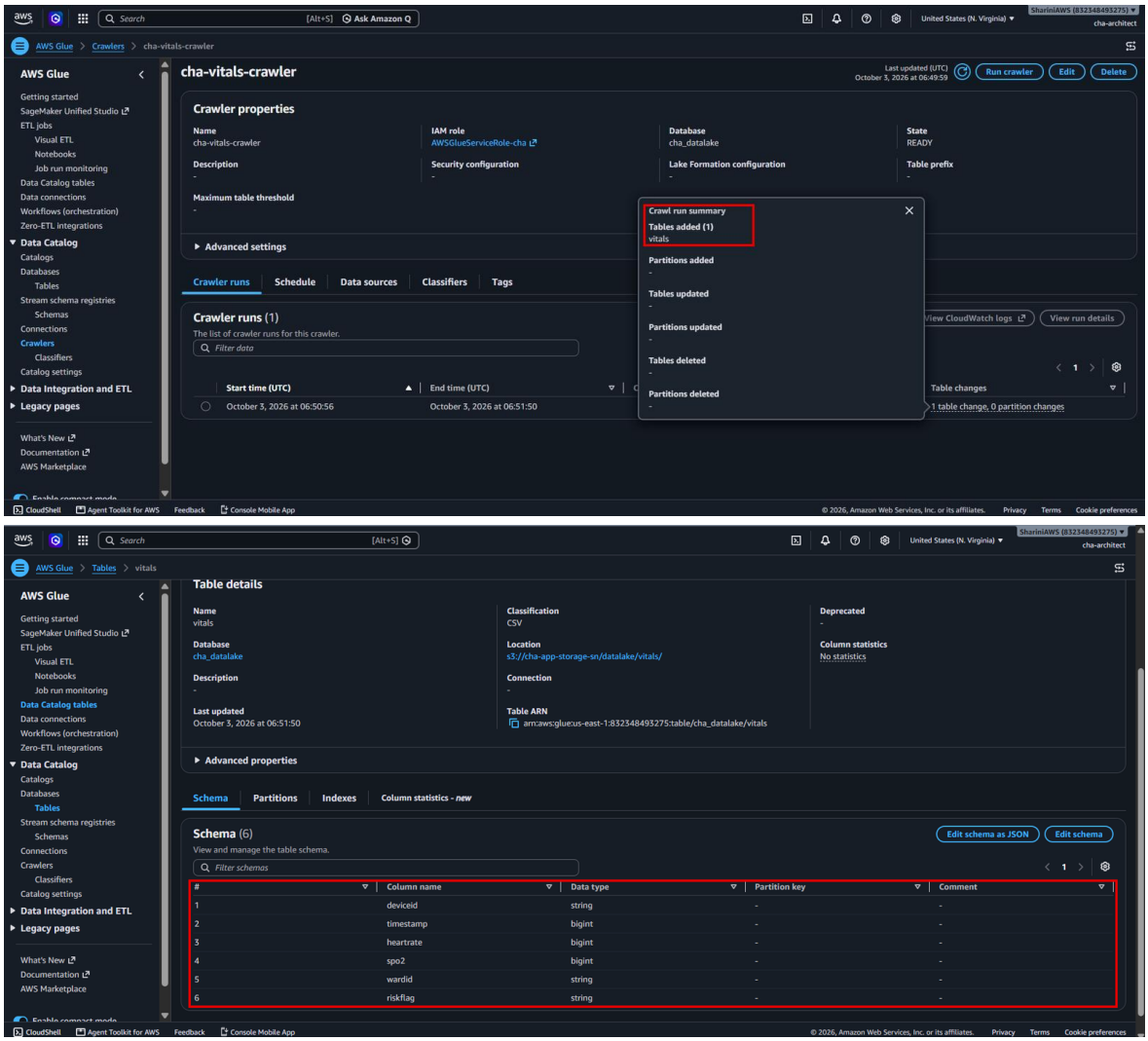


Figure L1: AWS Glue crawler run and the vitals table in the Data Catalog

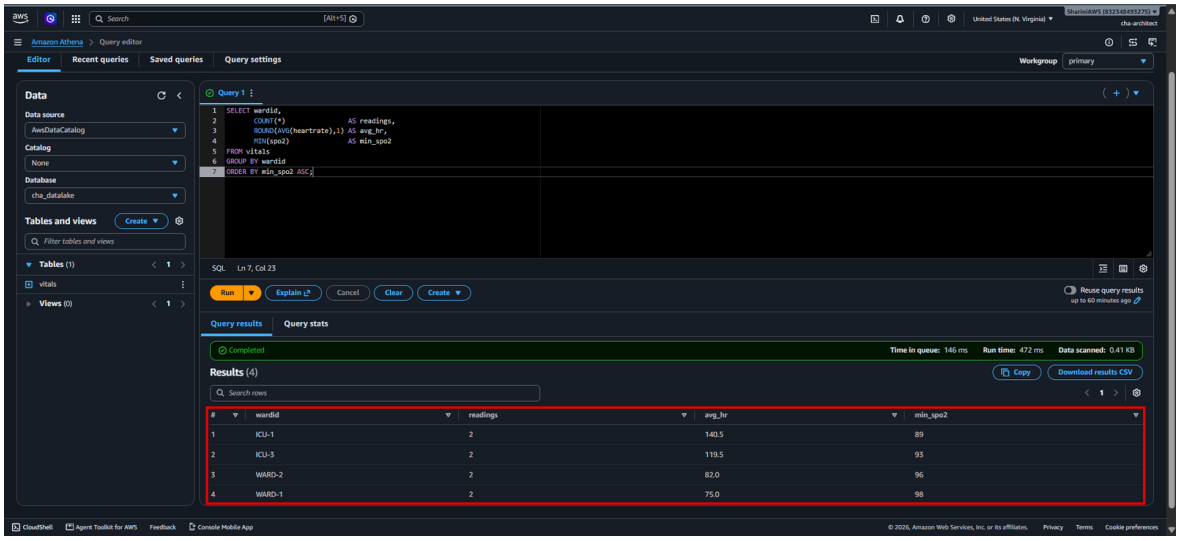


Figure L2: Athena ward-level aggregation over the exported vitals